EXAM STUDY NOTES · CONSOLIDATED EDITION

Data Privacy, Protection & Security

From anonymization, governance and cryptography to India's Digital Personal Data Protection Act, 2023 — rebuilt section-by-section from your source notes, the Act itself and the textbook figures.

10 modules | 26 textbook figures & tables | All 44 sections + Schedule of the DPDP Act | DU syllabus mapped · DU previous-year paper solved | 116 exam questions with model answers

READ ME FIRST

How these notes are built

DEFINITION CARD
Key terms, stated the way an examiner expects them.

STATUTORY PROVISION
Section-by-section text of the DPDP Act, with the section number shown as `s.6(4)`.

KEY TAKEAWAY
The one-line idea to remember if you remember nothing else.

EXAM ALERT
Traps, frequently asked points, and numbers examiners love.

WORKED EXAMPLE
A plain-language illustration, often straight from the Act's own illustrations.

YOUR MARKS
Where you underlined, starred or bracketed a figure in your photos, the notes call it out and explain why it matters.

Badges: HIGH-YIELD likely exam material · CORRECTED fixed against the Act or primary source · ADDED not in your source notes (verify against your syllabus) · YOUR MARK from your annotated photo.

What changed compared with your source notes

Area	What was done
Structure	The source file was several separate AI chats pasted together (data privacy → governance → PbD → DPDP → cryptography → harms → protection → surveillance). Topics are regrouped into 10 modules in a logical teaching order; the source map below shows where everything went. Nothing from the source notes was dropped.

Area	What was done
Visuals	Every ASCII diagram or text-table that had a matching photo in your zip was replaced by that photo (26 of 26 used). Diagrams with no photo (GPS inference, insecure vs imprecise use, DPDP actors, inquiry flow, appeal ladder, penalties chart, consent lifecycle, privacy timeline, etc.) were redrawn as clean vector diagrams.
DPDP Act accuracy CORRECTED	Cross-checked line-by-line with the Gazette text you supplied. Fixed: `s.17(1)` (ss.8(1) and 8(5) still apply); `s.17(3)` (disapplies ss.5, 8(3), 8(7), 10 *and* 11); `s.22(3)` cooling-off (*any* employment needs approval; disclosure duty for Data Fiduciaries who faced the Member); `s.22(1)` (four resignation triggers, earliest wins); `s.12(3)` (retention also allowed if "necessary for the specified purpose"); `s.11(1)` (right is against the Fiduciary to whom she previously gave consent, incl. `s.7(a)`); `s.9(5)` (age *above which* exemption applies); `s.44(1)` (TRAI Act s.14(c) amended); full list of operations in `s.2(x)`.
Other fixes CORRECTED	Sweeney statistic (the standard citation is ≈87%; your source said 83% — both shown); EU Charter article numbers in the GDPR discussion (non-discrimination is Art. 21, not Art. 25); Prosser's four torts named in full; section numbering clashes ("Table 1.2/Figure 1.1" appear in two different books — every figure now carries a source tag).
Added ADDED	k-anonymity / l-diversity / t-closeness primer (your source ended by offering it), DPDP vs GDPR comparison, status of the DPDP Rules 2025, revision toolkit (cheat-sheets, mnemonics, number drill), and a 116-question bank.
Delhi University material ADDED	The DU Data Privacy syllabus (four units) is mapped to the modules in 9.9. Topics the DU paper asks about but your source notes lacked — **HIPAA/COPPA, GDPR principles, what counts as PII, Caesar and rail-fence ciphers, breach vectors and impact, ethics of data use, bias and discrimination, PbD vs privacy engineering** — are written up in 9.10. The one DU Data Privacy end-semester paper I could find online (B.Sc. (H) Computer Science, Sem VII) is reproduced as paraphrased questions with model answers in Module 10, group P; a neighbouring DU Information Security paper is group R. The DU Examination Branch's paper portal could not be searched, so more papers may exist.
Not available	The "screenshot of your guidelines" did not arrive (only the notes PDF, the Act PDF and the photo zip did). If you send it, topics can be re-weighted to match it exactly.

Source map

Topic in your source notes	Now in	Photos used
Fundamentals of data privacy, stakeholders, attribute classes, privacy vs anonymity	Module 1 (1.1–1.4)	Fig 1.1; Tables 1.1–1.5
Methods of protecting data, privacy–utility balance, measuring privacy/utility, design principles, nature of enterprise data	Module 1 (1.5–1.9)	Fig 1.5, 1.6, 1.7/1.8; Tables 1.6–1.10
Data governance & practical data privacy; sensitive data; PII discovery	Module 2	Fig 1-1 (island); Table 1-1
Privacy by Design	Module 3	Fig 2.2
Cybersecurity, security attacks/services/mechanisms, symmetric & asymmetric crypto, hashing, signatures, PKI	Module 4	Fig 1.1–1.9; Tables 1.2–1.3 (security book)
II. Describing the harms from loss of privacy	Module 5	—

Topic in your source notes	Now in	Photos used
III. How does data protection protect against insecure and imprecise use (FIPs, OECD, GDPR, consent)	Module 6	—
IV. Surveillance & automated decision-making (DIIOT)	Module 7	Model surveillance system
The Digital Personal Data Protection Act, 2023 (all sections + Schedule)	Module 8	—
Delhi University syllabus and previous-year paper (online)	9.9–9.10 and Module 10 groups P, R	—

Contents

1 · Data Privacy Fundamentals & Anonymization
Stakeholders · EI/QI/SD · privacy vs anonymity · privacy–utility · 5 data types · k-anonymity primer

2 · Data Governance & Sensitive Data
People–Process–Technology · four pillars · PII tiers · behavioural inference · PII discovery

3 · Privacy by Design
Seven foundational principles with examples

4 · Information Security & Cryptography
CIA+ · attacks · services · mechanisms · symmetric/asymmetric · hashing · signatures · PKI

5 · Harms from Loss of Privacy
History · public perception · privacy paradox · insecure vs imprecise use

6 · Data Protection Law: Insecure vs Imprecise Use
FIPs · OECD · GDPR gaps · notice-and-consent critique · consumer protection

7 · Surveillance & Automated Decision-Making
Surveillance capitalism · DIIOT · net benefit · net harm

8 · The Digital Personal Data Protection Act, 2023
Chapters I–IX, all 44 sections, the Schedule, GDPR comparison, Rules 2025 status

9 · Rapid Revision Toolkit
Cheat-sheets · mnemonics · bridge tables · glossary · number drill · DU syllabus map & gap-fillers (ciphers, GDPR principles, ethics, bias)

10 · Question Bank
DU previous-year paper · direct · short-answer · analytical · case-study · true/false · numerical drills

MODULE 1

Data Privacy Fundamentals & Anonymization

1.1 Why data privacy matters

Organisations in banking, healthcare, retail and manufacturing collect massive volumes of customer data to analyse spending behaviour, health issues and investment patterns. Mining this data creates business value — but it often contains personal details that can be exploited if intercepted.

Driver	Detail
The core threat	According to **IDC** research, **data leakage** — accidental or intentional — ranks as the **number-one security threat**, ahead of traditional malware such as viruses and worms.
Outsourcing exposure	Global enterprises outsource software testing, development and business-process operations to offshore providers (e.g. **India, China, Brazil**), creating third-party exposure risks for sensitive data.
Regulatory compliance	Governments mandate strict penalties for data compromise: **HIPAA** (United States), **FIPPA** (Canada), **Sarbanes–Oxley**, the **EU Data Protection Directive**. Non-compliance → lawsuits, heavy fines, customer attrition, reputational damage.

EXAM ALERT

Remember the trio of reasons **Leakage – Outsourcing – Regulation**. "IDC ranks data leakage above malware" is a classic one-liner.

1.2 Key stakeholders in organisational data privacy

Managing privacy involves distinct roles interacting with **production data** (live operational databases) and **anonymized data** (safe copies for analysis and testing).

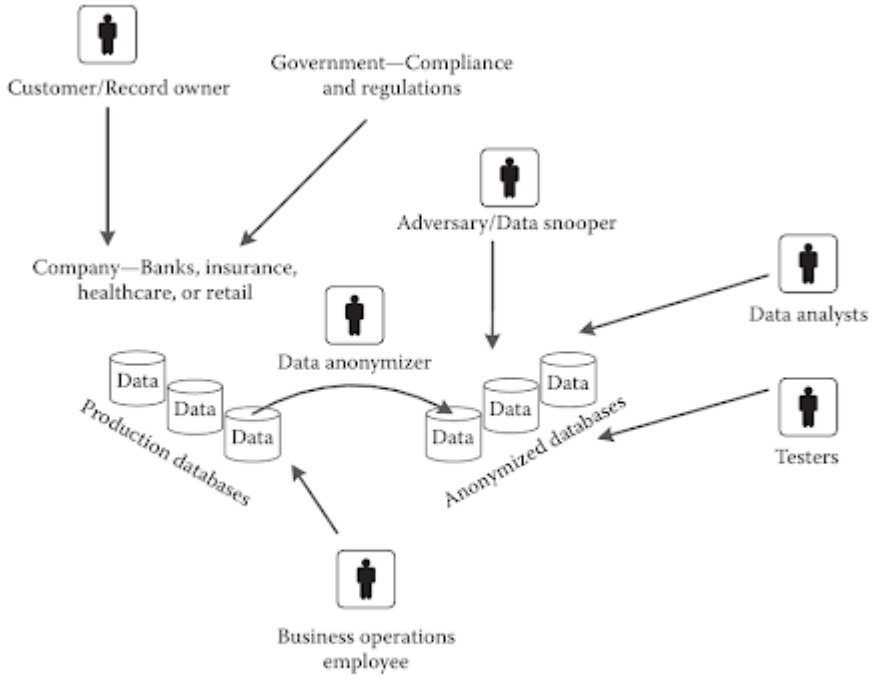


FIGURE 1.1
Data privacy—stakeholders in the organization.

Figure 1.1 — Data privacy: stakeholders in the organisation DATA PRIVACY TEXT

Stakeholder	Who they are	Relationship to the data
Customer / Record owner	The individual or entity who provides Personally Identifiable Information (PII) to the organisation.	Source of the data; entrusts it to the company.
Company (Custodian)	The enterprise — bank, insurance firm, hospital, retail platform — accountable for securing records against unauthorised disclosure.	Holds the **production databases**.
Government	Regulatory authorities enforcing compliance frameworks such as HIPAA and EU directives.	Imposes compliance and penalties on the company.
Business-operations employee	Staff (e.g. BPO agents) handling live customer service.	Works on **data in motion** (run-time data in production) → needs **real-time protection such as tokenization**.
Data anonymizer	Specialist who strips identifiers from production databases to prepare safe datasets.	Transforms production data into the **anonymized database**.
Data analyst	Uses anonymized **static** data for knowledge discovery, clustering and predictive modelling.	Reads anonymized databases.
Software tester	Quality-assurance engineer who needs realistic, production-like test cases without exposing actual customer records.	Reads anonymized databases.
Adversary / Data snooper	Internal or external malicious actor trying to re-identify records or steal confidential facts.	Attacks (esp.) the anonymized database.

KEY TAKEAWAY

Two data worlds: **production** (used by operations staff, protected at run-time by tokenization etc.) and **anonymized** (used by analysts and testers, produced by the anonymizer). The adversary's target is whatever is left identifiable in the second one.

1.3 Data classification and attribute types

Enterprises organise relational datasets into **four attribute classes**:

Attribute class	Definition	Examples
Explicit Identifiers (EI)	Fields that pinpoint a record owner **directly and unambiguously**.	Full name, Social Security Number (SSN), customer ID.
Quasi-Identifiers (QI)	Public/demographic attributes that do **not identify a person alone**, but can identify them **when linked together**.	Date of birth, gender, ZIP code, address, phone number.
Sensitive Data (SD)	Critical, private facts about a person that must not be compromised or leaked.	Account balance, credit limit, medical diagnosis, salary.
Non-Sensitive Data (NSD)	Contextual information that poses no privacy risk if disclosed.	General administrative flags or non-confidential system counters.

TABLE 1.1

Customer Table

Explicit Identifiers		Quasi-Identifiers				
ID	First Name	DOB	Gender	Address	Zip Code	Phone
1	Ravi	1970	Male	Fourth Street	66001	92345-67567
2	Hari	1975	Male	Queen Street	66011	98769-66610
3	John	1978	Male	Penn Street	66003	97867-00055
4	Amy	1980	Female	Ben Street	66066	98123-98765

TABLE 1.2

Account Table

	Sensitive Data				
ID	Account Number	Account Type	Account Balance	Credit Limit	Nonsensitive Data
1	12345	Savings	10,000	20,000	
2	23456	Checking	5,000	15,000	
3	45678	Savings	15,000	30,000	
4	76543	Savings	17,000	25,000	

Tables 1.1 & 1.2 — Customer table (EI: ID, first name; QI: DOB, gender, address, ZIP, phone) and Account table (SD: account number, type, balance, credit limit; NSD column empty)

DATA PRIVACY TEXT

TABLE 1.3

Logical Representation of Customer and Account Tables

Explicit Identifiers		Quasi-Identifiers				Sensitive Data			
ID	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
1	Ravi	1970	Male	Fourth Street	66001	12345	Savings	10,000	20,000
2	Hari	1975	Male	Queen Street	66011	23456	Checking	5,000	15,000
3	John	1978	Male	Penn Street	66003	45678	Savings	15,000	30,000
4	Amy	1980	Female	Ben Street	66066	76543	Savings	17,000	25,000

Table 1.3 — Logical (joined) representation: the shared ID links the two tables into one dataset

DATA PRIVACY TEXT

$$D = [\, D_{EI} \,]\ [\, D_{QI} \,]\ [\, D_{SD} \,]\ (+\ NSD)$$

The linking problem

A customer table of demographics looks harmless alone. But when it is **linked** with transactional account data through an identifier, confidential information is exposed (Tables 1.1 + 1.2 → Table 1.3).

WORKED EXAMPLE — SWEENEY'S RE-IDENTIFICATION RESEARCH

Latanya Sweeney showed that the combination **ZIP code + date of birth + gender** uniquely identifies a very large share of the US population — the standard citation is **≈87%** (your source notes say ≈83%; quote "roughly 85%" if unsure, and always name the three attributes). An adversary holding an "anonymized" hospital database with only age, sex and diagnosis can cross-reference a **public voter-registration list** to learn a neighbour's medical condition. CORRECTED

EXAM ALERT

Be ready to (a) name the four classes with one example each, (b) explain why QIs are dangerous *in combination*, and (c) give the voter-list linkage example. HIGH-YIELD

1.4 Privacy vs anonymity and the transformation process

Privacy and anonymity are **complementary perspectives** on data protection:

Aspect	Privacy	Anonymity
You know...	**Who** the person is	The **sensitive facts**
What is hidden	Sensitive details (balances, card numbers → masked with placeholders)	Identity of the person tied to the facts
Example	Customer list shows identities; account balances and card numbers are masked	Medical researchers see disease statistics and treatment outcomes but cannot tell which patient is which
Which columns carry the X	Sensitive-data columns (Table 1.5)	Personal-identity columns (Table 1.4)
Utility	Identity visible, confidential figures masked	Research utility remains intact

TABLE 1.4

Example of Anonymity

Personal Identity						Sensitive Data			
SSN	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
X	X	X	X	X	X				
X	X	X	X	X	X				
X	X	X	X	X	X				
X	X	X	X	X	X				

Note: X, identity is protected.

TABLE 1.5

Example of Privacy

Personal Identity						Sensitive Data			
SSN	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
						X	X	X	X
						X	X	X	X
						X	X	X	X
						X	X	X	X

Note: X, sensitive data are protected.

Tables 1.4 & 1.5 — Anonymity: identity columns (SSN, name, DOB, gender, address, ZIP) are X-ed, sensitive data is visible. Privacy: identity is visible, sensitive columns (account number, type, balance, credit limit) are X-ed. DATA PRIVACY TEXT

The two-step anonymization pipeline

To prepare static datasets for research or testing without losing customer trust, organisations apply a transformation function **T**:



Two-step anonymization pipeline — T drops EI, transforms QI, and leaves SD untouched so analytic value survives.

1. **Data masking (EI elimination)** — explicit identifiers such as names and SSNs are scrambled, substituted or suppressed; they are **completely dropped** from the transformed dataset D′.

2. **De-identification (QI modification)** — techniques such as **generalization** (e.g. exact birth date → age range) and **suppression** are applied to quasi-identifiers.

$$D' = [\, T(D_{QI}) \,] \; [\, D_{SD} \,]$$ (EI dropped; SD retained in authentic form)

KEY TAKEAWAY

By transforming QI while keeping SD authentic, analytical utility is preserved for data mining while adversaries cannot re-identify record owners.

1.5 Methods of protecting data

Protecting sensitive data inside complex, distributed enterprise applications is one of the hardest problems in information security. Three primary methods exist — **cryptography, anonymization, tokenization** — alongside one-way functions such as **hashing**.

Cryptography

- **Concept:** one of the oldest and most established techniques; when implemented correctly it protects data **in transit** (across networks) and **at rest** (on servers/disks).
- **Limitation 1:** encrypted data is unreadable ciphertext → analytical queries, data mining and software testing cannot run directly on it.
- **Limitation 2:** depends entirely on **key management**; if a key is leaked, all protection collapses.
- **Advanced variants: Secure Multiparty Computation (MPC)** — parties jointly compute a result without revealing private inputs; **Zero-Knowledge Proofs (ZKP)** — prove a statement is true without revealing the underlying data.

EXAMPLE

Encrypting a customer database with AES-256 stops hackers reading account records if a hard drive is stolen — but analysts cannot run demographic segmentation without first decrypting.

Anonymization

- **Concept:** techniques that alter original values so they no longer point to an identifiable individual, while preserving **syntax** (data format) and **semantics** (contextual meaning and analytical value).
- **Trade-off (optimisation problem):** balance **data privacy** (defined by data owners and compliance rules) against **data utility** (defined by data scientists and analysts). Modifying data protects privacy; excessive modification degrades utility.

EXAMPLE

Replace an exact birthdate (14/05/1982) with an age range (40–45): identity is hidden, yet researchers can still study disease prevalence by age band.

Tokenization

- **Concept:** replaces sensitive values with non-sensitive surrogate placeholders called **tokens**.
- **Key distinction from cryptography:** tokens are **not mathematically derived** from the data — arbitrary substitutes with no algorithmic relationship to the plaintext.
- **Format preservation:** tokens keep the exact syntax and length of the field, so legacy systems work without schema redesign.
- **Domain scope:** a token works inside its native application via an internal **lookup vault**, but is useless to an attacker outside that system.

EXAMPLE (PCI DSS)

Card number 4111 2222 3333 4444 → token 9876 5432 1098 7654. Billing applications route the token; real credentials stay isolated in an encrypted vault.

Comparison of the three methods

Feature	Cryptography	Anonymization	Tokenization
Core idea	Scramble with algorithm + key	Alter values so they no longer identify; keep syntax & semantics	Swap value for arbitrary surrogate
Mathematical link to original	Yes (reversible with key)	No exact link (values distorted/generalised)	**None** (lookup vault only)
Format preserved?	Normally no (opaque ciphertext)	Yes (syntax kept)	Yes (exact syntax and length)
Analytical utility	Zero until decrypted (binary)	Tunable ("shades of gray")	Works for routing/processing; limited analytics
Weak point	Key leakage / key management	Over-modification kills utility; under-modification allows re-identification	Security of the vault
Typical use	Data in transit & at rest	Test/analytics datasets	Run-time protection (payments, BPO agents)

1.6 Balancing data privacy and utility

Enterprises provision production data for software testing, analysis and knowledge discovery. Protection must mask **EI**, de-identify **QI** via transformation functions, and keep **SD** in original form to preserve business value. The core challenge is preserving the **statistical correlation between QI and SD**.

- If the transformation distorts QI too aggressively, the correlation between demographic markers and sensitive outcomes is lost → the dataset becomes analytically useless.
- **HIPAA conflict:** HIPAA classifies **18 specific fields** as PII (names, geographic markers, hospital admission dates...). If researchers study recovery over time, anonymizing the admission date prevents measuring recovery timelines — strict privacy can undermine research utility.

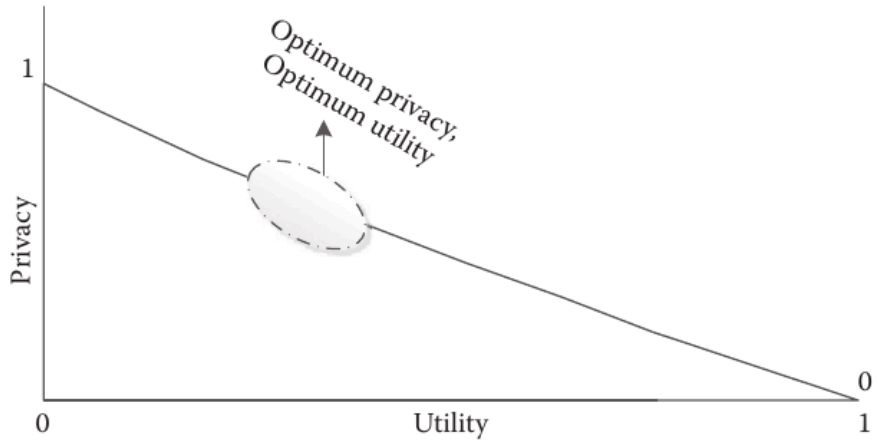


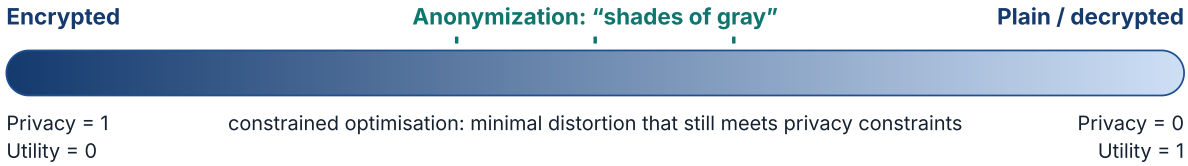
FIGURE 1.5
Privacy versus utility map.

TABLE 1.6

Original Table with Strong Correlation between QI and SD

Name	Zip Code	Gender	Income
Chen	56001	Male	25K
Jenny	56015	Female	8K
Alice	56001	Female	30K
Ram	56011	Male	5K

Figure 1.5 — Privacy versus utility map (privacy falls as utility rises; the shaded ellipse is the "optimum privacy, optimum utility" zone) and **Table 1.6** — original table with strong correlation between QI and SD (high income concentrated in ZIP 56001). DATA PRIVACY TEXT



Binary vs. shades of gray — cryptography sits at the two ends; anonymization lives on the continuum between them.

- **Binary trade-off in cryptography ("black or white"):** encrypted → maximum privacy (1), zero utility (0); decrypted → maximum utility (1), zero privacy (0).
- **Shades of gray in anonymization:** a continuous spectrum; the objective is **constrained optimisation** — minimal distortion that still satisfies privacy constraints.

Evaluating anonymization trade-offs

TABLE 1.7

Anonymized Table with Generalized Values—Correlation between QI and SD Is Broken

Name	Zip Code	Gender	Income
Yang	56000	Male	25K
Emma	56010	Female	8K
Olivia	56000	Female	30K
Krishna	56010	Male	5K

Table 1.7 — Anonymized table with generalised values (names replaced; ZIPs generalised to 56000 / 56010; incomes kept). The textbook titles it "correlation between QI and SD is broken".

DATA PRIVACY TEXT

Design 1 — Table 1.7

Privacy gain: names substituted, geography generalised, identities shielded.

Utility loss: demographic granularity reduced; exact geographic correlation to income brackets weakened.

Design 2 — extreme suppression

All names "XXXX", all ZIPs "56001", all genders "Male".

Privacy gain: maximum; re-identification nearly impossible.

Utility loss: severe — female representation eliminated, geographic variance flattened, analytics destroyed.

CORE GOALS OF ANONYMIZATION TECHNIQUES

1. Prevent an adversary from **deducing or linking Sensitive Data (SD)** fields.
2. **Minimise utility loss** by preserving the statistical correlations between QI and SD.

1.7 Measuring privacy and utility of anonymized data

Measuring privacy

Privacy is a **relative** metric: compare candidate datasets D_1', D_2', ..., D_n'. Two families of approach:

Approach	How privacy is measured	Where used
Statistical methods	Variance introduced into perturbed attributes — **larger variance ⇒ higher privacy**.	Statistical databases
Probabilistic methods	Privacy **loss** modelled by an adversary who combines dataset distributions with **background knowledge** to re-identify records.	Adversary-model analysis

TABLE 1.8

Background Knowledge of the Adversary about the Distribution of SD Fields

Name	Zip Code	Gender	Disease
John Smith	46001	Male	Hypertension
Tom Henry	46005	Male	Gastritis
Alice Williams	46001	Female	Cancer
Little Wood	46011	Male	Asthma

Table 1.8 — Background knowledge of the adversary about the distribution of SD fields (John Smith 46001 M Hypertension · Tom Henry 46005 M Gastritis · Alice Williams 46001 F Cancer · Little Wood 46011 M Asthma). DATA PRIVACY TEXT

PROBABILISTIC ATTACK SCENARIO

Bob knows his neighbour Alice lives in ZIP **46001**, is **female** and smokes. Cross-referencing Table 1.8, he sees only **one female** in ZIP 46001 ⇒ Alice has **Cancer**. The record is *unique* on its QI values — exactly the weakness that group techniques such as k-anonymity are designed to remove.

Measuring utility

When original D becomes D′ = T(D), QI attributes are distorted; utility is judged by comparing statistical properties of D′ against D.

- **Statistical distance:** if Q is the QI distribution in D and Q′ in D′, the distance between Q and Q′ measures **utility loss**.
- **Impact on software testing:** test data need high utility to exercise edge cases; over-anonymising degrades structural fidelity → lower **test coverage** → defects slip into production.

1.8 Anonymization design principles

Anonymization design is not purely tool-driven. Blindly applying commercial software or setting over-strict filters to satisfy regulations (e.g. **HIPAA**, the **Swiss Data Protection Act**) often destroys utility. Effective design needs structured principles.

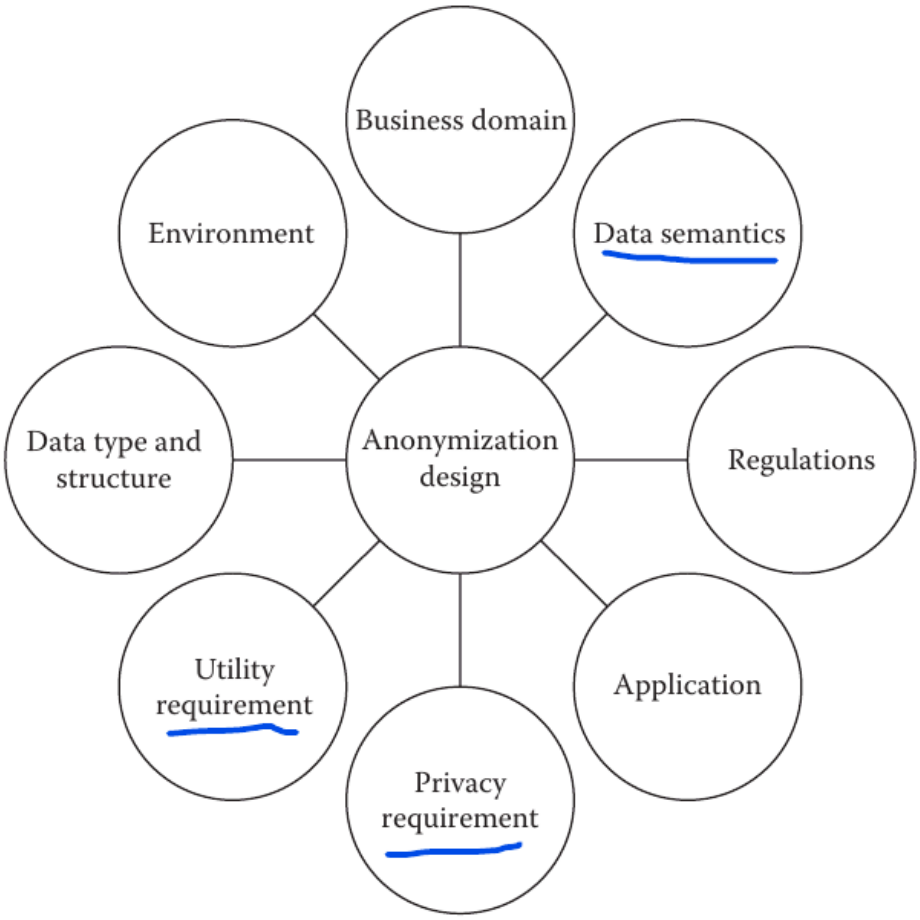


FIGURE 1.6
Drivers for anonymization design.

Figure 1.6 — Drivers for anonymization design: business domain · environment · data semantics · regulations · application · privacy requirement · utility requirement · data type and structure.
DATA PRIVACY TEXT

YOUR MARKS YOUR MARK

You underlined **Data semantics**, **Utility requirement** and **Privacy requirement**. Why they matter: **privacy requirement** (what must stay hidden — set by data owners/compliance) and **utility requirement** (what analysis must survive — set by data scientists) are the two opposing forces of the optimisation; **data semantics** (what each attribute *means*) decides which modifications keep the data valid and meaningful (e.g. generalising a ZIP keeps meaning; random digits do not).

Classification	Meaning
Scientific principles	Foundational truths and laws of nature that give universal theoretical baselines.
Normative principles	Enforceable operational rules and design criteria guiding architects in balancing privacy and utility.

THREE-PART STRUCTURE OF EVERY DESIGN PRINCIPLE

Principle name (identifying label) · **Rationale** (why the rule is needed) · **Implications** (operational impact and implementation considerations).

1.9 Nature of data in the enterprise

Different data structures raise different privacy problems; relational techniques cannot be applied uniformly to graphs, transaction logs or time series.

Five data types at a glance

Type	Structure	Examples	Why standard relational anonymization fails / key difficulty
Multidimensional	Table; each row an independent entity vector, columns = attributes (EI/QI/SD/NSD)	Customer–account tables	Works best; main issues: QI/SD boundary, high dimensionality, clusters in SD
Transaction	Sparse, high-dimensional binary records	Supermarket baskets, clinical diagnosis histories	Thousands of items, mostly zeros; fixed-schema techniques do not apply
Longitudinal	Repeated measurements of the same individual over time (clustered, correlated, time-ordered)	Clinical trials (blood pressure series)	Must keep temporal trends; sequences can be linked to external records
Graph	G = (V, E): nodes and edges	Social, financial, telecom networks	Structure itself identifies nodes; editing edges alters network properties
Time series	Continuous values at regular intervals; high-dimensional, unbounded	IoT sensor logs, stock prices, weekly sales	Rows are linked mathematically (trend, seasonality); must retain statistics & queries

1.9.1 Multidimensional data

Relational data in tables; each row is an entity vector. **Standard rule:** mask EI entirely, transform QI with anonymization techniques, preserve SD in original form.

- Each record is **independent** → anonymizing a few records does not affect others.
- Anonymizing one cell/tuple in a record does not corrupt neighbouring tuples.

Primary approaches: (1) **Random perturbation** — adding statistical noise or swapping values; (2) **Group anonymization** — generalising and suppressing to meet criteria such as **k-anonymity** (each record indistinguishable from at least k−1 others) and **l-diversity** (diverse sensitive values within each group).

CHALLENGES

1. **QI/SD boundary is hard to draw** given the adversary's background knowledge — an attribute that looks harmless can become identifying when joined with an external registry (e.g. voter list + hospital data).
2. **High dimensionality** — more columns make records more unique, so heavy distortion is needed to stop linkage.
3. **Clusters in sensitive data** — SD values concentrated in groups can expose identities even when demographics are generalised.
4. **Realistic privacy–utility balance** — finding a transformation that preserves statistical validity without risking re-identification.

1.9.2 Transaction data

Sparse, high-dimensional records — supermarket logs, clinical histories.

TABLE 1.9

Sample Sparse High-Dimensional Transaction Database in a Supermarket

Name	P_1	P_2	P_3	P_4	P_5	P_6	P_n
Hari			1			1	
Nancy	1			1			
Jim		1					1

Table 1.9 — Sample sparse high-dimensional transaction database in a supermarket (Hari: P3, P6 · Nancy: P1, P4 · Jim: P2, Pn). DATA PRIVACY TEXT

Privacy threat: buying common items (bread, cheese — P3, P6) is non-sensitive, but specialised purchases (a blood-glucose monitor, an HIV test kit) reveal confidential health information. **Failure of relational techniques:** retail databases have thousands of possible items → wide, sparse binary records that break standard relational anonymization.

CHALLENGES

1. **High dimensionality** — tens of thousands of product codes (P_1...P_n) → vast combinations.
2. **Sparsity** — most customers buy a tiny fraction of products; rows are mostly zeros.
3. **Conventional relational techniques (fixed schema) are not applicable** — they destroy transactional patterns.

1.9.3 Longitudinal data

Repeated measurements from the same individual over an extended period — typical of clinical trials assessing treatment efficacy.

TABLE 1.10

Sample Longitudinal Data Set in the Healthcare Domain

ID	Name	DOB	ZIP	Service Date	Diseases	Systolic (mmHg)	Diastolic (mmHg)
1	Bob	1976	56711	30/05/2012	Hypertension	180	95
2	Bob	1976	56711	31/05/2012	Hypertension	160	90
3	Bob	1976	56711	01/06/2012	Hypertension	140	85
4	Bob	1976	56711	02/06/2012	Hypertension	130	90
5	Bob	1976	56711	03/06/2012	Hypertension	125	85
6	Bob	1976	56711	04/06/2012	Hypertension	120	80
7	Alice	1969	56812	31/03/2012	Hypertension	160	90

Table 1.10 — Sample longitudinal data set (healthcare): Bob's blood pressure falls from 180/95 to 120/80 across six days (30/05–04/06/2012); Alice has a single reading. DATA PRIVACY TEXT

Clustered

Multiple repeated measurements per individual across time.

Correlated

Day-3 reading relates directly to day-2 reading.

Temporally ordered

Strict chronological sequence: Day 1 → Day 2 → Day 3.

CHALLENGES

1. **Preserve the characteristics of longitudinal data in D′** — sequential trends and clinical correlations; flattening readings destroys medical utility.
2. **Prevent identity *and* attribute disclosure** — masking names and generalising ZIP/DOB stops direct identity disclosure, but an adversary can still link a sequence of medical events or service dates to public records (e.g. insurance claims) → attribute disclosure. Protection must guard identity and sequence without altering time trends.

1.9.4 Graph data

Graph data models relationships as networks **G = (V, E)**: V = vertices/nodes (entities), E = edges (connections). Examples: social networks (Facebook, LinkedIn), financial transaction graphs, telecom networks.

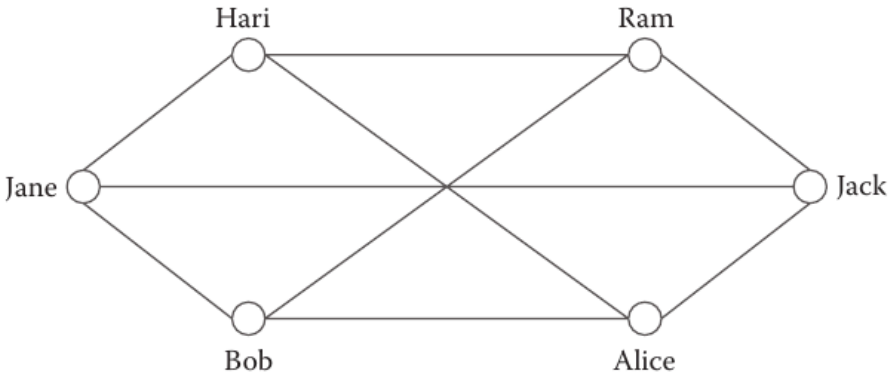


FIGURE 1.7
Graph network with original data.

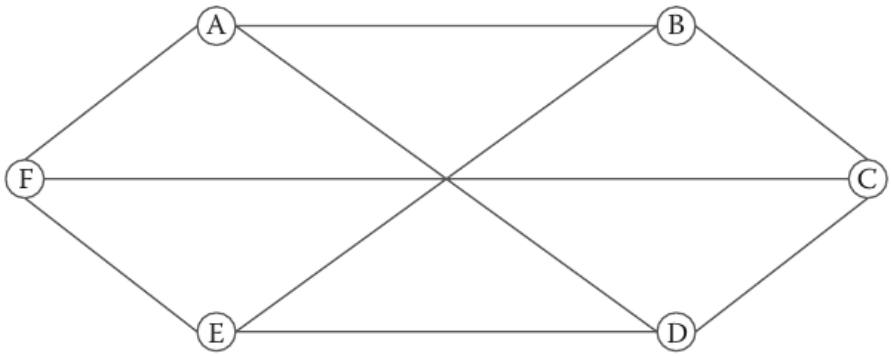


FIGURE 1.8
Modified graph network.

Figures 1.7 & 1.8 — Original network (Hari, Ram, Jane, Jack, Bob, Alice) and the "modified" network with names replaced by A–F. The edge structure is identical. DATA PRIVACY TEXT

RE-IDENTIFICATION VULNERABILITY

Replacing names (Hari, Ram) with anonymous labels (A, B) does **not** prevent re-identification: the **topology** (connections and degree counts) is intact, so an adversary who knows a target's number of friends can map the identity back onto the graph.

THREE CATEGORIES OF GRAPH PRIVACY DISCLOSURE

1. **Identity disclosure** — an individual is re-identified behind a node.
2. **Link disclosure** — private relationships between two individuals are discovered.
3. **Content / attribute disclosure** — private information or node attributes of an individual are deduced.

Structural metrics exploited by adversaries: betweenness centrality, closeness, reachability, path lengths, node-degree distributions. **Trade-off:** adding, deleting or rewiring edges to hide identities can alter fundamental network properties and invalidate social-network or cluster analysis.

1.9.5 Time series data

Continuous measurements at regular intervals from a continuous process — IoT sensor logs, daily stock prices, weekly corporate revenue.

Longitudinal vs time-series data

	Longitudinal	Time series
What it is	Repeated clinical measurements evaluated as responses to specific treatments	Ongoing measurements of continuous variables at fixed intervals
Dimensionality	Low overall dimensionality	High-dimensional; grows indefinitely over time
Purpose	Track response to an intervention	Need not track a response to an intervention

Table 1.11 — Sample time-series table: weekly sales of companies DATA PRIVACY TEXT

ID	Company	Address	Week 1	Week 2	Week 3	Week 4	Week 5
1	ABC	Park Street, 56001	10,000	12,000	17,000	8,000	11,000
2	ACME	Kings Street, 56003	15,000	17,000	18,000	20,000	21,000
3	XYZ	Main Street, 56022	20,000	23,000	25,000	26,000	30,000
4	PQR	Queen Street, 56021	14,000	18,000	19,000	19,500	21,000

Relational distinction: although it looks like a normal table with EI/QI/SD, its records **cannot be anonymized independently** — the sequential numbers form trajectories, trends and seasonal cycles that link across rows and periods.

CHALLENGES

- **High dimensionality** — continuous streams make row-by-row masking ineffective.
- **Retaining statistical properties** — mean, variance, autocorrelation, trend lines must survive.
- **Supporting analytical queries** — range queries and pattern matching must still work.
- **Preventing identity disclosure and linkage attacks** — public financial disclosures or news can be matched to specific curves to re-identify companies/individuals.

1.10 Primer: the techniques your notes pointed to ADDED

Your source notes ended by offering k-anonymity, l-diversity and t-closeness. A compact, standard primer is given here so the Module is self-contained — check it against your lecture slides.

Technique / model	Idea	Defends against	Known weakness
Generalization	Replace a value by a broader one (age 34 → 30–39; ZIP 46001 → 460**).	Linkage via QI	Loses precision.
Suppression	Remove a value or record entirely.	Unique/outlier records	Loses data; bias if overused.
Perturbation (noise / swapping)	Add random noise or swap values between records.	Direct attribute disclosure	Distorts statistics; variance = privacy measure.

Technique / model	Idea	Defends against	Known weakness
k-anonymity	Every combination of QI values appears in **at least k** records, so each person hides among ≥ k–1 others.	Identity disclosure via linking	If all k records share the same sensitive value, it is still disclosed (homogeneity attack); background knowledge attacks.
l-diversity	Each k-anonymous group must contain **at least l "well-represented" distinct sensitive values**.	Homogeneity / background-knowledge attacks	Ignores how skewed the sensitive distribution is.
t-closeness	Distribution of the sensitive attribute in each group must be **within distance t** of its distribution in the whole table.	Skewness and similarity attacks	Harder to achieve; larger utility loss.
Differential privacy	Query results are randomised so that adding/removing **one person** barely changes the output (privacy budget ε).	Inference about any single individual	Noise reduces accuracy for small datasets.
Pseudonymization	Replace identifiers with pseudonyms; the key is held separately.	Casual identification	Still personal data — it can be re-linked with the key or extra information. Not the same as anonymization.

MINI EXAMPLE — 2-ANONYMITY

Raw rows (ZIP, gender, age, disease): (46001, F, 34, Cancer), (46001, F, 38, Flu), (46005, M, 29, Asthma), (46011, M, 31, Asthma). Generalise ZIP → 460** and age → 20–39: the QI groups become (460**, F, 20–39) ×2 and (460**, M, 20–39) ×2, so the table is **2-anonymous** and Bob can no longer single out Alice by "ZIP 46001 + female". But both males have **Asthma** — the sensitive value is revealed for the whole group (a *homogeneity attack*), which is what l-diversity is designed to prevent.

MODULE 1 IN FIVE LINES

1. Four attribute classes: **EI, QI, SD, NSD**; QI are dangerous *when linked*.
2. Anonymization pipeline: **mask EI → de-identify QI → keep SD**.
3. Privacy hides *sensitive facts*; anonymity hides *identity*.
4. Cryptography is **binary**; anonymization is **shades of gray**; tokenization uses **arbitrary surrogates + vault**.
5. Five data types need five different anonymization strategies — graph, time-series and transaction data break relational techniques.

MODULE 2

Data Governance & Sensitive Data

2.1 What is data governance?

DEFINITION

Data governance is the overarching framework that defines how an organisation **manages, protects, enhances and disposes of data** across its lifecycle.

The “transfer of rights” metaphor

In civic society, citizens elect officials and entrust them with legal rights and responsibilities. Data governance works the same way:

- When a customer uses an app, website or service, they agree to terms, conditions and privacy policies.
- Through that agreement the individual **transfers** their personal data to the organisation.
- The organisation assumes a **custodial obligation** to govern and protect that data under established rules and laws.

The core triad: People · Process · Technology

People

Cross-functional governance councils, compliance committees, legal advisors, security analysts, data scientists.

Process

Formal standards, data-handling policies, audit workflows, lineage documentation.

Technology

Software engines, automated pipelines, access controls, masking tools and storage architectures that enforce compliance policy directly in code.

2.2 Visualising privacy, security and governance

Figure 1-1 uses an **island-fortress metaphor** to show how security, privacy design, regulation and privacy technology work together.

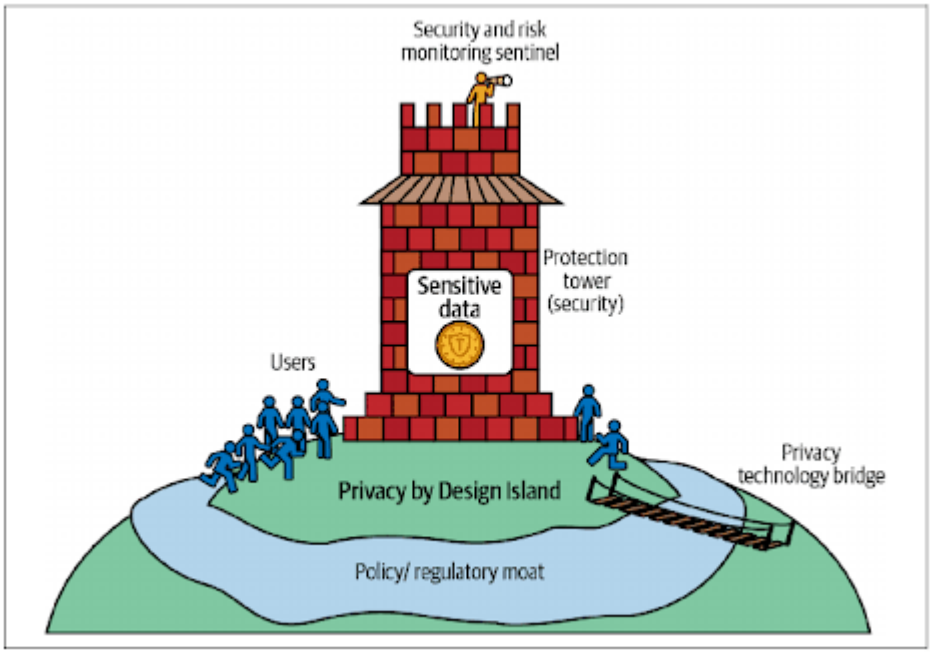


Figure 1-1. Mapping data governance

Figure 1-1 — Mapping data governance (island fortress) GOVERNANCE TEXT

Element in the picture	What it represents
Protection tower (security)	Safeguards the sensitive data inside via physical defences, network perimeters, encryption and strict storage permissions.
Security & risk-monitoring sentinel	Continuously watches for vulnerabilities, unauthorised access and operational risk.
Privacy by Design island	Systems architected from day one to **minimise exposure**, not patched reactively.
Policy / regulatory moat	External barrier of statutory mandates (HIPAA, GDPR, regional privacy acts) keeping data boundaries legally and structurally maintained.
Privacy technology bridge	Lets users, business analysts and data scientists safely cross the moat and extract analytics **without exposing identities**.
Users	The people (analysts, scientists, staff) who need to reach insights from the data inside.

2.3 Data governance for data scientists — four pillars

Models need reliable, legally compliant data. Table 1-1 breaks governance into four operational pillars.

Table 1-1. Data governance in data science

Data lineage/Origin	Policies and controls
Where did the data come from?	What laws or internal policies apply to this data?
Whose data is it? Is it possible to contact them?	Where, when, and how was it collected?
Was this data acquired from someone else, and if so, did they document how it was processed and who it belongs to?	What privacy or security concerns do you need to address when using this data?
How did the processing change the data?	What was the privacy policy and terms at collection time?
Is the metadata for lineage information easily accessible and queryable?	Did the data come from a third party? If so, what are the restrictions and obligations, contractual or otherwise, for this data?

Data reliability/Knowledge	Data privacy and security
What are the concerns around understanding the data and systems (i.e., including collection, transformation, and downstream systems)?	How is access to sensitive data managed and monitored?
Does the data have an understandable documentation trail from the moment it was collected?	Does the organization know if and when data has been breached? How?
When there are data quality problems, do you know how to diagnose and resolve them?	Who is responsible for managing privacy controls? Security controls?
Are there data storage infrastructure or old data stores that are undocumented or even unknown?	When someone invokes their data rights (i.e., GDPR), is there a system that is well documented and understood to apply these rights?
Is the data well documented and understood? (Know your data.)	What data loss prevention technologies and privacy technologies do you use and how?

Table 1-1 — Data governance in data science GOVERNANCE TEXT

Pillar	Focus & key questions	Practical data-science example
Data lineage & origin	• Where did the data originate? • Whose data is it? Can they be contacted? • Was it acquired from someone else — did they document how it was processed and whether it belongs to them? • How did processing change the data? Did transformations alter its meaning? • Is lineage metadata easily accessible and queryable?	Tracing a training dataset from an external partner back to its initial collection source to confirm the customer permitted downstream ML use.
Policies & controls	• What laws or internal policies apply? • Where, when and under what terms/privacy policy was it collected? • What privacy or security concerns must be addressed when using it? • If from a third party — what contractual constraints and obligations exist?	Checking whether user terms permitted targeted advertising when telemetry was collected through a mobile app.

Pillar	Focus & key questions	Practical data-science example
Data reliability & knowledge	• Is there an end-to-end, understandable documentation trail from the moment of collection? • When data-quality bugs occur, do you know how to diagnose and resolve them? • Are there undocumented or legacy data stores lurking in the system? • Is the data well documented and understood ("know your data") across collection, transformation and downstream systems?	Preventing training bias by auditing automated transformation scripts for unintended missing values or altered labels.
Data privacy & security	• How is access to sensitive data managed and monitored? • Does the organisation know if/when it has been breached, and how? • Who is responsible for privacy controls? For security controls? • When someone invokes data rights (e.g. GDPR) is there a well-documented system to apply them (deletion/opt-out)? • What data-loss-prevention and privacy technologies are used, and how?	An automated pipeline step that honours a user's "right to be forgotten" without breaking upstream predictive models.

MEMORY HOOK

L-P-R-P — **L**ineage · **P**olicies · **R**eliability · **P**rivacy & security. Ask "where from? – what rules? – can I trust it? – is it protected?".

2.4 Redefining "sensitive data"

Sensitive data goes beyond demographic tables into **three interconnected tiers**:

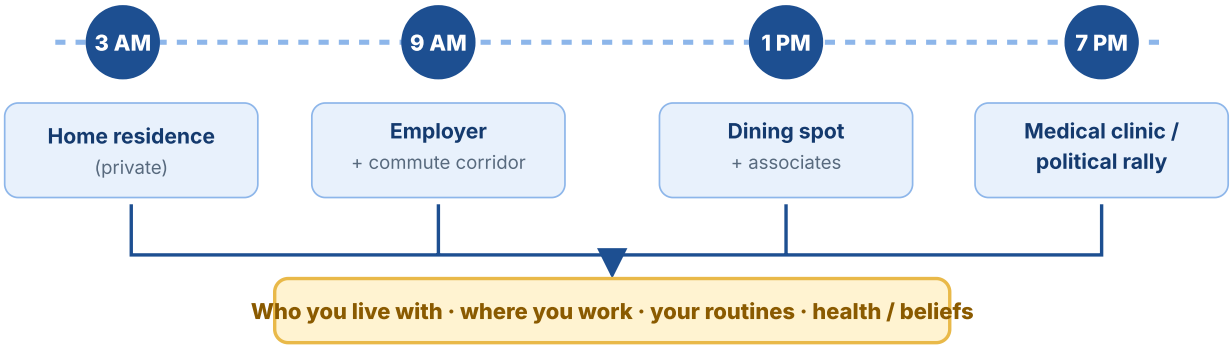
Tier	Description	Examples
1. Personally Identifiable Information (PII)	Attributes that point **directly or nearly directly** to a specific individual.	Full legal name, SSN, biometric data (fingerprints, retina patterns, gait), IP addresses, email addresses, national ID cards.
2. Person-related data	Not an identity marker alone, but can **reveal identity when aggregated or analysed across time**.	GPS breadcrumbs, device types, shopping transaction histories, web-search queries, entertainment subscriptions.
3. Proprietary & confidential data	Non-personal **business** information that would damage legal standing, competitiveness or contractual obligations if exposed.	Proprietary trade algorithms, internal operational benchmarks, merger records, inter-subsidiary communications.

EXAM ALERT

Tier 2 is the "trap": a single GPS point or purchase is harmless, but the *pattern* identifies you. Contrast with the four EI/QI/SD/NSD classes of Module 1 — these three tiers are a *broader* lens (includes business secrets). HIGH-YIELD

2.5 Behavioural inference and contextual privacy

A single data point looks harmless in isolation, but linking multiple person-related streams creates clear profiles.



The GPS tracking problem — four innocuous location points (3 AM, 9 AM, 1 PM, 7 PM) combine into a detailed personal profile. Vehicle speed, commute routes and periodic stops reveal the same.

Digital footprints and social inference

Kosinski et al. (2013) showed that analysing social-media interactions (e.g. Facebook "likes") lets one predict personal attributes with high statistical confidence:

- Sexual orientation
- Political opinions and voting likelihood
- Religious convictions
- Parental marital status (the study also predicted traits such as personality, ethnicity and substance use) ADDED

CONTEXTUAL PRIVACY

Privacy preferences depend heavily on **context**. A person may happily share location while on a delivery job but see location monitoring at home or at the weekend as an intrusion. (Same idea as Facebook's 2010 FTC testimony in Module 5.)

2.6 Discovering and managing PII in complex systems

PII often slips into unstructured places — error logs, support tickets, chat histories — without standard metadata tags.

Technical discovery methods

Method	How it works	Strength / limitation

Method	How it works	Strength / limitation
Regular expressions (regex)	Pattern-matching rules that flag predictable strings — card numbers, SSNs, email formats.	Fast and simple; **prone to false positives and misses irregular personal data**.
String entropy analysis	Measures randomness within strings.	Finds hard-coded passwords, encrypted secrets, API access tokens.
Deep learning & NLP models	Context-aware language models trained to recognise names, addresses and medical narratives in raw, conversational text.	Handles free text that regex cannot.
Dedicated toolkits	Open-source frameworks such as **Microsoft Presidio**.	Automate PII detection, redaction and pseudonymization across mixed file types.

BEST PRACTICES FOR PRIVACY ENGINEERING

1. **Never assume human-input data is clean** — free-text comment boxes, feedback fields and support chats are treated as sensitive PII by default until reviewed.
2. **Shift privacy left** — rather than relying on reactive scanners over sprawling data lakes, **tag, document and pseudonymize at the point of ingestion**.
3. **Build lineage tracking into pipelines** — automated metadata recording who contributed each field, the applicable privacy policy and which downstream models consume it.

MODULE 3

Privacy by Design (PbD)

3.1 What is Privacy by Design?

DEFINITION

Privacy by Design (PbD) is an engineering and operational philosophy ensuring privacy protections are built directly into the architecture of a system **before implementation begins**, rather than added as an afterthought.

- **Holistic scope:** applies across software architecture, IT infrastructure, physical facilities, business processes and corporate workflows.
- **Origin:** developed by **Dr. Ann Cavoukian**, Information and Privacy Commissioner of Ontario, Canada; formally recognised as a global standard at the **32nd International Conference of Data Protection and Privacy Commissioners** (Jerusalem, 2010) ADDED.

3.2 The seven foundational principles

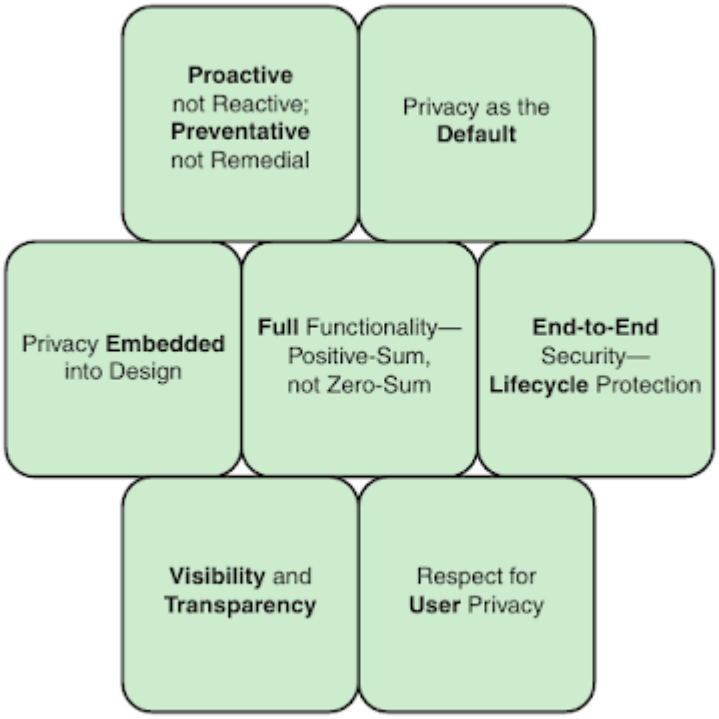


FIGURE 2.2 Foundational Principles of Privacy by Design

Figure 2.2 — Foundational principles of Privacy by Design PRIVACY ENGINEERING TEXT

MNEMONIC

P · D · E · F · E · V · R

Proactive · **D**efault · **E**mbedded · **F**ull functionality · **E**nd-to-end security · **V**isibility & transparency · **R**espect for user privacy

Principle 1 — Proactive not Reactive; Preventative not Remedial

Anticipate risks and prevent privacy incidents *before* they occur rather than reacting after a breach.

Core requirement: architects evaluate vulnerabilities, threat models and misuse cases at the planning stage and deploy preventive controls early.

Example: a mobile healthcare app runs automated code audits and architectural risk assessments in the design phase instead of waiting for an exploit.

Principle 2 — Privacy as the Default

Personal data is protected **automatically**, without the user adjusting complicated settings or opting in.

Core requirement: collect and process only the **minimum** data required for the primary service; keep data guarded across collection, storage, use and transmission by default.

Example: on registration, optional fields (phone number, geolocation sharing) are **off by default**.

Principle 3 — Privacy Embedded into Design

Privacy is an essential, **core feature** of IT systems and business operations — not an add-on module tacked on after deployment.

Core requirement: privacy mechanisms are integral components of workflows and database schemas.

Example: instead of storing raw SSNs in plaintext and writing an external script to mask them later, the database is built from day one to **encrypt and tokenize sensitive fields at ingestion**.

Principle 4 — Full Functionality: Positive-Sum, not Zero-Sum

Privacy must not compromise utility or security; both can be achieved without unnecessary trade-offs.

Core requirement: avoid binary "either/or" compromises; robust safeguards should *enhance* user trust while preserving business features.

ZERO-SUM (TRADE-OFF)

"To give you useful fraud detection, we must monitor and store every detail of your unmasked shopping habits."

POSITIVE-SUM (WIN-WIN)

"We use privacy-preserving analytics and tokenization to identify fraudulent transactions accurately while keeping your identity masked."

Principle 5 — End-to-End Security: Lifecycle Protection

Personal information stays secure throughout its **entire lifecycle** — no gaps from collection to secure disposal.

Lifecycle phase	Controls (confidentiality, integrity, availability)
Collection	Secure channels and encrypted transmission
Storage & processing	Strict role-based access control and audit logging
Retention & disposal	Automated retention schedules and cryptographically secure destruction

Example: a banking app encrypts applications in transit (TLS), stores records in encrypted partitions (AES-256), and purges archives with automated overwrites once the legal retention period ends.

Principle 6 — Visibility and Transparency

Operations must be open so users and regulators can **independently verify** privacy commitments. Three components:

1. **Accountability** — explicit, documented ownership of privacy management, data controls and compliance across teams.
2. **Openness** — clear privacy notices for consumers; detailed internal governance policies.
3. **Compliance** — accessible dispute-resolution paths, audit logs and redress mechanisms.

Example: a fitness service offers a plain-language privacy dashboard explaining what telemetry is gathered, who can access it and whom to contact to complain.

Principle 7 — Respect for User Privacy

Prioritise the individual's right to **control** their personal information. Four operational requirements:

1. **Consent** — individuals can grant or withdraw consent to collection, use or disclosure (unless law requires otherwise).
2. **Accuracy** — records are kept accurate, complete and current.
3. **Access** — individuals can review stored records, see how data was shared, and challenge errors.
4. **Compliance & redress** — clear channels to resolve discrepancies or report improper disclosure.

Example: a patient portal lets patients download diagnostic records, correct outdated contact details, and choose whether anonymized records may go to university research labs.

3.3 Quick reference — the 7 principles at a glance

#	Principle	Primary objective	Key implementation action
1	**Proactive / Preventative**	Stop privacy harms before they occur	Threat modelling, architectural risk reviews
2	**Privacy as Default**	Protect data without requiring user action	Data minimisation, pre-checked opt-outs
3	**Embedded into Design**	Make privacy a foundational system feature	Native database encryption, integrated tokenization
4	**Positive-Sum**	Avoid choosing between privacy and functionality	High-utility privacy-preserving analytics
5	**End-to-End Security**	Protect records across their entire lifecycle	Access controls, audit logs, secure data shredding
6	**Visibility & Transparency**	Keep processes verifiable and open	Readable privacy notices, documented ownership
7	**Respect for User Privacy**	Keep the individual in control of their data	Consent portals, self-service data corrections

EXAM ALERT

- Principle 2 (**Default**) is about *settings* (privacy on without user effort); Principle 3 (**Embedded**) is about *architecture* (built into schemas and workflows). Don't blur them.
- "Positive-sum, not zero-sum" = no forced trade-off between privacy and functionality/security.
- Principle 6's three parts (accountability, openness, compliance) vs Principle 7's four parts (consent, accuracy, access, compliance/redress) — a favourite 4-mark question. HIGH-YIELD

MODULE 4

Information Security & Cryptography

4.1 Cybersecurity, information security and network security

CYBERSECURITY

Safeguarding electronic communications, digital equipment and stored data from harm, unauthorised intrusion and exploitation — and **restoring** systems when incidents occur. Its goal is five qualities: **availability, integrity, authentication, confidentiality, nonrepudiation**.

Plain words: the overall digital shield for computers, mobile networks and internet-connected systems. *Example:* firewalls + multi-factor authentication + automated backups so a ransomware attack can be survived by restoring from clean backups.

INFORMATION SECURITY

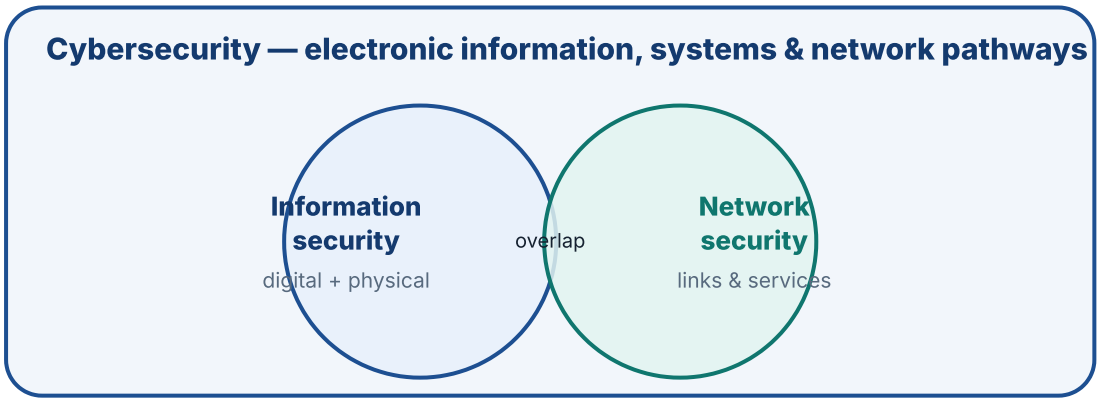
Preservation of **confidentiality, integrity and availability** of information; may also include authenticity, accountability, nonrepudiation and reliability. Covers information in **any format — digital or physical**.

Example: locking paper files in a secure room and restricting database records with strong access privileges.

NETWORK SECURITY

Protection of networks and network services from unauthorised **modification, destruction or disclosure**, ensuring network paths perform their critical functions reliably without unintended side effects.

Example: firewalls and VPNs shielding office traffic from eavesdroppers on public Wi-Fi.



Scope distinction — cybersecurity is the broad umbrella; information security also covers paper/physical assets. In business talk the terms are often used interchangeably.

4.2 Security objectives

The **CIA triad** — Confidentiality, Integrity, Availability — is the foundation of information and network security (formalised in NIST FIPS 199). Two further concepts, **authenticity** and **accountability**, complete the picture (Figure 1.1).

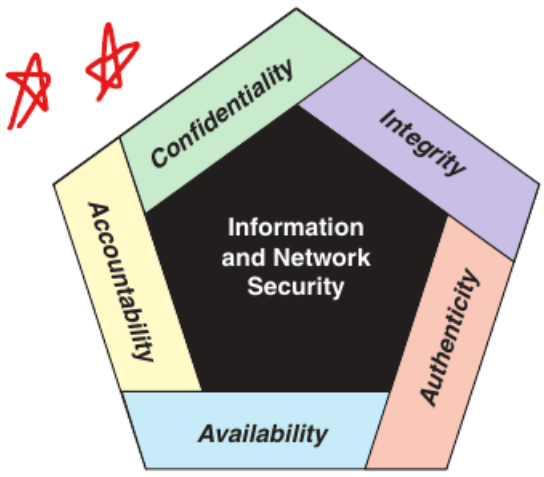


FIGURE 1.1 Essential Information and Network Security Objectives

Figure 1.1 — Essential information and network security objectives: confidentiality · integrity · authenticity · availability · accountability SECURITY TEXT

YOUR MARKS YOUR MARK

You starred **Confidentiality**. It is the first CIA goal and the one most tied to privacy: *loss of confidentiality = unauthorised disclosure*. Expect questions that pair confidentiality with encryption, access control and traffic padding.

Objective	Meaning	A loss means…	Example
Confidentiality	Information is never made available or revealed to unauthorised individuals, entities or processes (data confidentiality).	Unauthorised disclosure	Encrypting card details at online checkout.
Integrity — *data*	Data (stored on disk or sent in packets) and programs are altered **only in an authorised, specified manner**.	Unauthorised modification or deletion	A $50 bank transfer cannot become $5,000 in transit.
Integrity — *system*	A system performs its intended function smoothly, free of deliberate or accidental unauthorised manipulation.	System manipulated/tampered	OS verifying that a malicious script hasn't disabled antivirus.
Availability	Systems respond promptly; authorised users are never blocked from necessary services.	Disruption of access to information or systems	Hospital database reachable 24/7 despite traffic spikes.
Authenticity	Being genuine, verifiable and trustworthy — confidence in the validity of a transmission, message or identity claim; users are who they claim to be.	Forgery / spoofing accepted as real	2-factor prompt (SMS code / authenticator app) before account access.

Objective	Meaning	A loss means…	Example
Accountability	Every action is traced uniquely back to the actor. Enables **nonrepudiation, deterrence, fault isolation, intrusion detection, forensics and legal action**.	Actions cannot be attributed	Audit log: “Admin_Bob modified user permissions at 10:14 from 192.168.1.15.”

> **NOTE ON “DATA” VS “INFORMATION”**
> **Information** = knowledge, facts, data or opinions conveyed in any medium (written, visual, spoken). **Data** = information structured to be processed, generated or stored by computers. Security literature treats the two as practically identical.

4.3 The challenges of information security

#	Challenge	Explanation	Example
1	**Not as simple as it appears**	Goals like confidentiality fit in a word, but the mechanisms and algorithms enforcing them are intricate.	“Keep this file secret” across networks needs key exchange, cipher modes, IVs.
2	**Designers must anticipate novel attacks**	Attackers don’t follow rules; they probe from unforeseen angles for subtle flaws.	Inferring keys via cache-timing or memory leaks instead of breaking the cipher maths.
3	**Countermeasures are counter-intuitive**	Complex mechanisms seem convoluted until every attack path is analysed.	Salting passwords looks redundant but defeats precomputed rainbow tables.
4	**Where to place defences**	Choosing the physical and logical position of safeguards is hard.	Encrypt at web tier vs isolate VMs vs role-based DB access.
5	**Secrets and protocols create dependencies**	Mechanisms depend on safeguarding keys (generation, distribution, storage); unreliable transport can break time-sensitive validation.	A 30-second token locks out legitimate users on laggy networks.
6	**Asymmetric battle of wits**	Attacker needs **one** weakness; defender must secure **every** entry point.	99 patched services, 1 forgotten test server with a default password.
7	**Perceived lack of immediate ROI**	Seen as overhead until a breach occurs.	“We’ve never been breached” → intrusion detection delayed.
8	**Constant, demanding monitoring**	Networks change constantly; real-time log review is hard for overloaded teams.	Tens of thousands of alerts a day hide the real threat.
9	**Treated as an afterthought**	Security is bolted on to finished designs instead of integrated from the start (cf. Privacy by Design).	Retrofitting authentication into a live production codebase.
10	**Seen as an obstacle to usability**	Strict measures are viewed as productivity hurdles.	Staff write 20-character rotating passwords on sticky notes.

4.4 Security attacks

ITU-T X.800 (Security Architecture for OSI) organises security frameworks into three concepts:

Concept	Definition	Example
Security attack	Any action that compromises the security of information owned by an organisation.	SQL injection into a web form to extract user records.
Security mechanism	A process (or device incorporating it) designed to **detect, prevent or recover** from an attack.	Encryption algorithms, intrusion detection, digital signatures.
Security service	A processing/communication service that enhances security and thwarts attacks using one or more mechanisms.	Authentication service combining hashing and password validation.

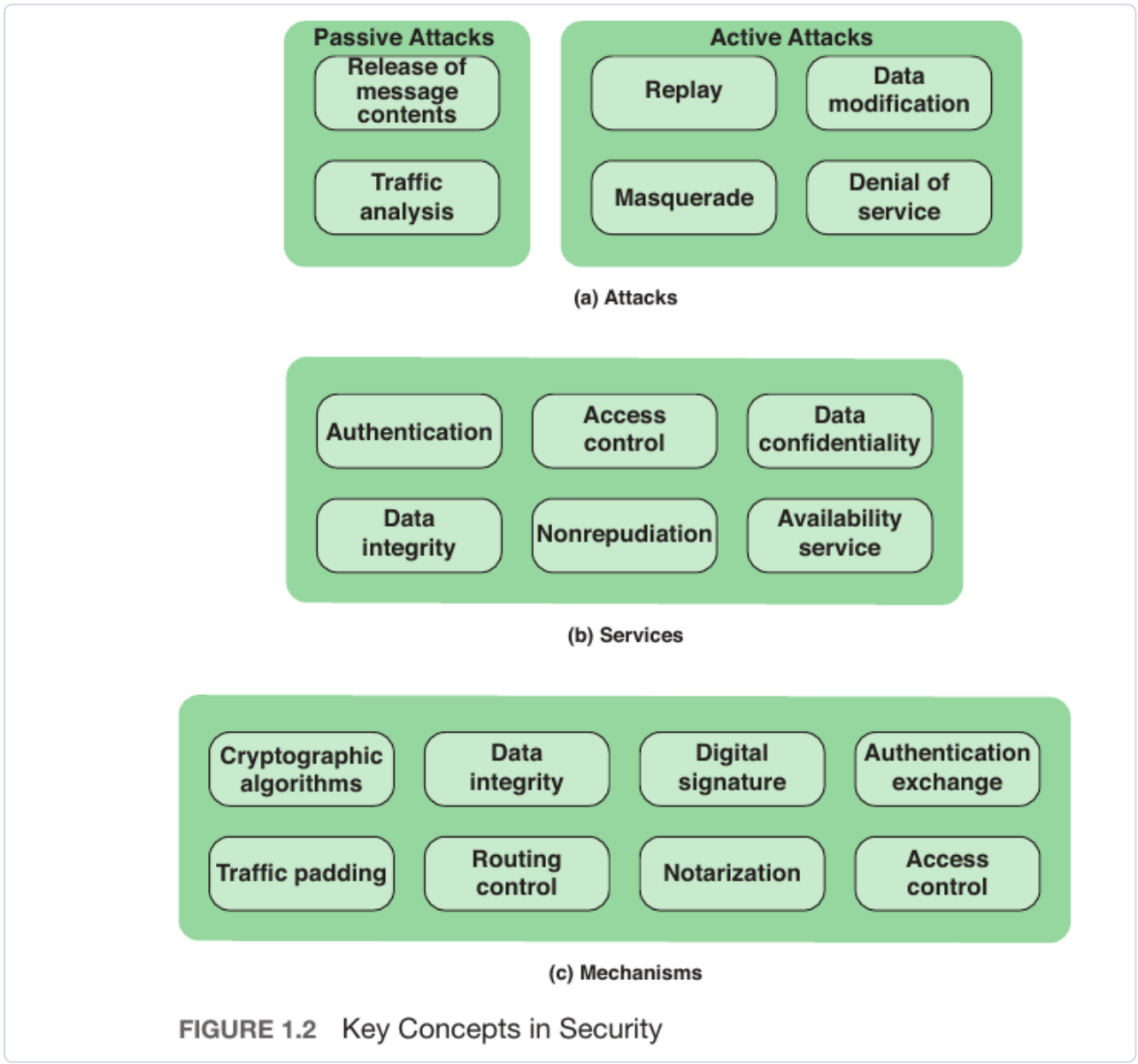


Figure 1.2 — Key concepts in security: (a) attacks — passive (release of message contents, traffic analysis) and active (replay, data modification, masquerade, denial of service); (b) services — authentication, access control, data confidentiality, data integrity, nonrepudiation, availability service; (c) mechanisms — cryptographic algorithms, data integrity, digital signature, authentication exchange, traffic padding, routing control, notarization, access control. SECURITY TEXT

THREAT

A **potential** circumstance or event that can harm operations, assets or people through unauthorised access, destruction, disclosure or denial of service.

Example: sensitive backups stored on an unpatched server.

ATTACK

An **actual** malicious attempt to collect, disrupt, deny, degrade or destroy resources or data.

Example: an intruder running exploits against that unpatched server to download the backups.

Under X.800 attacks are classified as **Passive** or **Active** (Figure 1.2a).

Passive attacks

Eavesdropping on or monitoring transmissions to harvest information **without altering** system resources. Two types:

Type	Description	Example
Release of message contents	Adversary intercepts and reads sensitive communications on the path.	Reading an unencrypted email, phone call or file transfer.
Traffic analysis	Adversary watches **patterns** — frequencies, packet lengths, host locations — to infer context even when content is encrypted.	A surge of encrypted messages between a company HQ and a law firm → impending acquisition or lawsuit.

DEFENCE STRATEGY — PASSIVE

Passive attacks alter nothing and leave no trace, so they are **extremely hard to detect**. Neither party notices interruption. Effort therefore goes to **prevention** (primarily **encryption**), not detection.

Active attacks

Altering stored or transmitted data, delaying packets, or generating unauthorised communications. Four categories:

Type	Description	Example
Masquerade	One entity pretends to be another, often with captured credentials to gain unauthorised privileges.	Presenting a stolen administrator login cookie to alter database settings.
Replay	Passive capture of a legitimate communication followed by **retransmission**.	Re-sending a valid $100 transfer authorisation five times.
Data modification	Altering, delaying or reordering portions of a legitimate message.	"Approve $5,000 to Vendor A" → "Approve $50,000 to Account X".
Denial of service (DoS)	Preventing or inhibiting normal use or management of communications, servers or facilities.	Flooding a web service with millions of dummy connection requests per second.

DEFENCE STRATEGY — ACTIVE

Absolute **prevention** across every link and device is practically impossible, so the strategy is **detection and rapid recovery** (which also deters future intrusions).

Passive vs active attacks — one-glance comparison

	Passive	Active
Effect on data	None — only observed	Altered, delayed, injected
Detectability	Very difficult	Detectable
Types	Release of contents; traffic analysis	Masquerade; replay; modification; DoS
Main defence	**Prevention** (encryption)	**Detection & recovery**

Client/server attack topologies (Figure 1.3)

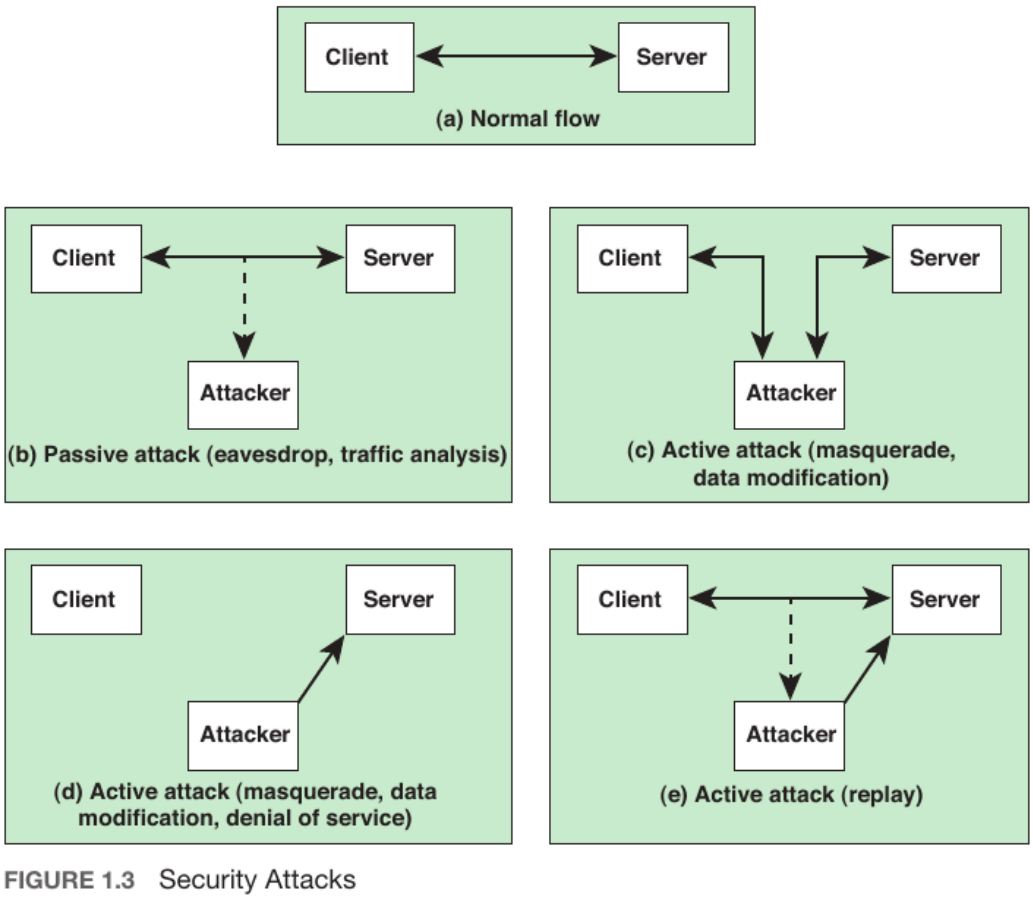


FIGURE 1.3 Security Attacks

Figure 1.3 — Security attacks SECURITY TEXT

	Panel (label in figure)	What happens
(a)	**Normal flow**	Legitimate two-way communication between client and server.
(b)	**Passive attack (eavesdrop, traffic analysis)**	Attacker taps the link (dashed line), observing content or patterns while the stream flows undisturbed.
(c)	**Active attack (masquerade, data modification)**	Man-in-the-middle: attacker sits between client and server, impersonating each to the other, enabling interception and arbitrary modification.
(d)	**Active attack (masquerade, data modification, denial of service)**	Attacker interacts **directly with the server**, posing as an authorised user to tamper with records, or exhausting resources to cause DoS.
(e)	**Active attack (replay)**	Attacker captures legitimate packets (dashed) and retransmits them later to repeat an action.

4.5 Security services

A security service implements security policy to support the requirements (confidentiality, integrity, availability, authenticity, accountability) using underlying mechanisms.

Table 1.1 — Security services summary

Service	Description	Practical example
Authentication	A person's identity is determined before access is granted.	Verifying password + smart card before system entry.
Access control	Persons are allowed or denied access to resources for specific purposes.	HR managers may view salary sheets; other staff may not.
Data confidentiality	Information is available only to persons intended to see/use it.	Encrypting medical files so only treating physicians read them.
Data integrity	Information is modified only in appropriate ways by authorised persons.	Checksums/hashes to ensure a downloaded update is unaltered.
Nonrepudiation	A person cannot perform an action and later deny it.	Digitally signing a contract so the signer cannot dispute it.
Availability	Apps, services and hardware are ready when needed and perform acceptably.	Load-balanced clusters keep a shop reachable in traffic surges.

Detailed service breakdowns

Authentication

Ensures communications come from legitimate sources. For a single message (e.g. an alarm) it confirms the sender; for a continuous session it prevents third parties from hijacking or masquerading. X.800 distinguishes two kinds:

- **Peer entity authentication** — corroborates the identities of two communicating entities running the same protocol, at connection establishment or during transfer; prevents masquerades and connection replays. *Example:* SSL/TLS handshake between browser and bank server.

- **Data origin authentication** — corroborates the **source of an individual message** without tracking sessions or preventing duplication. *Example:* verifying an email's sender via cryptographic signatures (DKIM).

Access control

Limits and regulates who can reach applications, servers and network resources. Entities must be **authenticated first** so individual rights can be applied. *Example:* a directory validates an employee login and allows engineering documents but blocks payroll databases.

Data confidentiality

Shields transmitted data from passive inspection. It can cover all user data over a whole session, or specific fields in single transmissions, and can also mask **message-flow patterns** (against traffic analysis). *Example:* full-session TLS.

Data integrity

- **Connection-oriented integrity** — protects an active data stream: messages arrive without duplication, insertion, alteration, reordering or deletion (mitigates stream modification and DoS effects).
- **Connectionless integrity** — protects individual isolated messages, primarily against content modification.
- **Detection vs recovery:** for active attacks the priority is detection; systems can report violations for manual fixing or trigger automated recovery.

Nonrepudiation

- **With proof of origin** — protects the **receiver** by proving who sent it.
- **With proof of delivery** — protects the **sender** by proving it reached the recipient.

Availability service

Keeps systems, applications and hardware accessible to authorised entities on demand at expected performance; mitigates DoS by controlling and safeguarding infrastructure. *Example:* intrusion-prevention appliances filtering DoS traffic.

EXAM ALERT

Proof of **origin** protects the **receiver**; proof of **delivery** protects the **sender**. Peer-entity = *connection*; data-origin = *single message*. HIGH-YIELD

4.6 Security mechanisms

Underlying processes, algorithms or devices implemented to detect, prevent or recover from attacks (Figure 1.2c).

Mechanism	What it does	Example
Cryptographic algorithms	Mathematical procedures to scramble text, generate keys, secure storage and transit.	Encrypting an archive with AES.
Data integrity	Checksums, cryptographic hash values and check sequences confirm data wasn't altered.	Appending an HMAC to a message.
Digital signature	Cryptographic transformation added to a data unit that lets the recipient verify origin and integrity and guards against forgery.	Signing a PDF with a private key.
Authentication exchange	Verifies claimed identity through an exchange of information.	Challenge–response: server sends a random number; client signs it with its secret key.
Traffic padding	Inserts dummy bits into streams to level traffic volume and thwart traffic analysis.	Constant dummy packets on an idle link.
Routing control	Selects trusted physical/logical paths for sensitive data, or reroutes when a link is suspect.	Confidential traffic only over dedicated encrypted links.
Notarization	A trusted **third party** verifies properties of an exchange — origin, recipient, timing.	Digital timestamping of an IP document.
Access control	ACLs and role-based permissions regulate who may use which resources.	Directory "Read-only" for users, "Full control" for admins.

4.7 Cryptographic algorithms

CRYPTOGRAPHY

The discipline covering principles, means and methods for transforming data to **hide semantic content, prevent unauthorised use and prevent undetected alteration**. Ensures confidentiality, data integrity, nonrepudiation and authenticity.

CRYPTOGRAPHIC ALGORITHM

A computational procedure that takes variable inputs — often including a **cryptographic key** — and produces a transformed output.

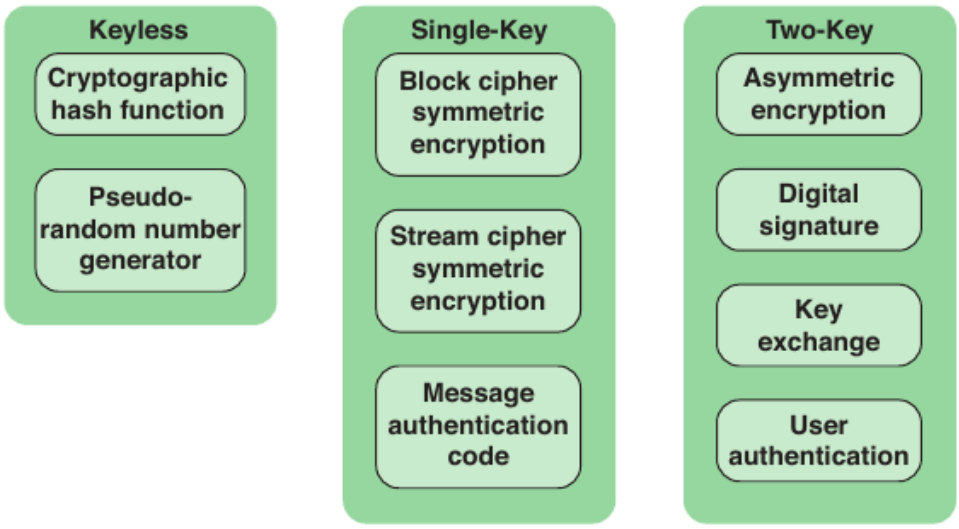


FIGURE 1.4 Cryptographic Algorithms

Figure 1.4 — Cryptographic algorithms. Three architectural classes: **Keyless** (hash function, pseudorandom number generator) · **Single-key** (block cipher, stream cipher, message authentication code) · **Two-key** (asymmetric encryption, digital signature, key exchange, user authentication).
SECURITY TEXT

Class	Algorithm	Definition	Example
Keyless	Cryptographic hash function	Converts variable-length input into a **fixed-length** output: hash value / hash code / message digest.	SHA-256 gives a 256-bit fingerprint of an OS image.
	Pseudorandom number generator (PRNG)	Deterministic algorithm producing bit/number sequences that **appear statistically random**.	Random session tokens that prevent hijacking.
Single-key (symmetric)	Block cipher	Encrypts data in fixed-size blocks with a shared secret key.	AES, 128-bit blocks.
	Stream cipher	Encrypts continuously bit-by-bit / byte-by-byte.	ChaCha20.
	Message authentication code (MAC)	Cryptographic checksum from the message + a **shared secret key** (often built on a hash); lets key-holders confirm the message wasn't tampered with.	HMAC-SHA256 on wire-transfer instructions.

Class	Algorithm	Definition	Example
Two-key (public/private pair)	Asymmetric encryption	Uses the key pair in two configurations: confidentiality (encrypt with recipient's public key) or source verification (encrypt with sender's private key).	Encrypting an email with Bob's public key.
	Digital signature	Sender signs a document's **hash** with the private key; anyone verifies with the public key.	Software publisher signing an installer.
	Key exchange	Protocols letting two remote parties establish a shared symmetric session key over an insecure channel **without exposing it**.	Diffie–Hellman in an HTTPS handshake.
	User authentication	Validates a client/service identity using asymmetric cryptographic challenges.	SSH login with a key pair instead of a password.

4.8 Symmetric encryption

DEFINITION

Also called **secret-key encryption**: both encryption and decryption use the **exact same secret key**.

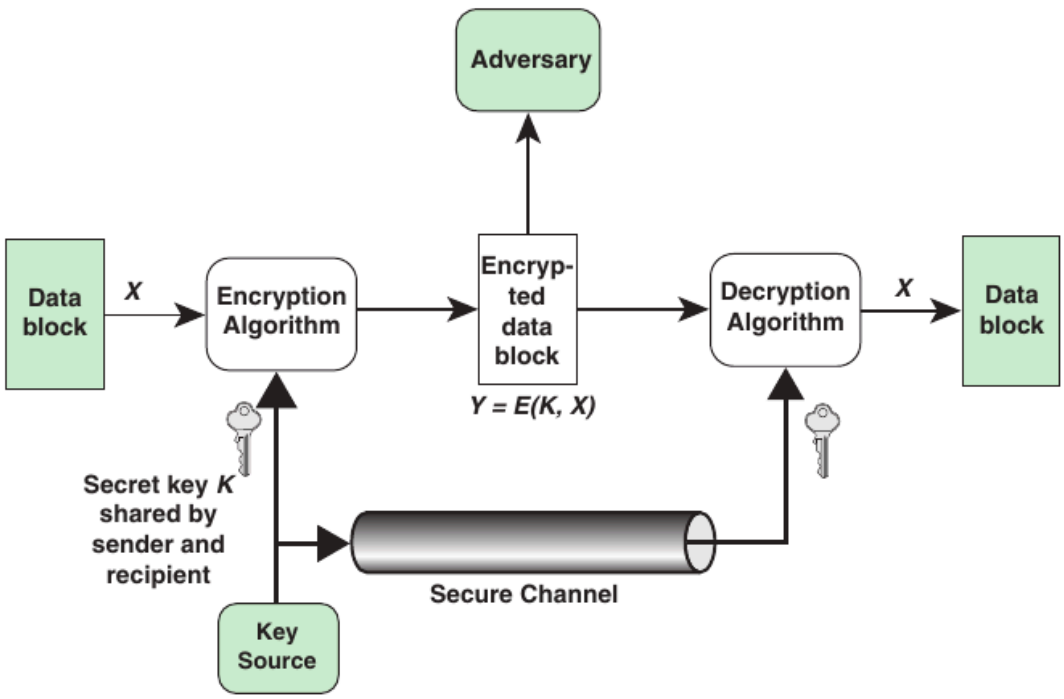


FIGURE 1.5 Model of Symmetric Cryptosystem

Figure 1.5 — Model of a symmetric cryptosystem: data block X → encryption algorithm → encrypted block Y = E(K, X) → decryption algorithm → X; the secret key K is shared by sender and recipient over a secure channel from a key source; an adversary may observe Y. SECURITY TEXT

Five fundamental ingredients

Ingredient	Meaning	Example
Plaintext	The original readable message/data block fed into the algorithm.	"Transfer $500 to Alice".
Encryption algorithm	Performs substitutions and transformations on the plaintext.	AES on 128-bit blocks.
Secret key	An independent input that dictates the exact substitutions/transformations.	Random 256-bit string shared by bank and ATM.
Ciphertext	Scrambled output — depends on both plaintext and key.	8f4b2c99a...
Decryption algorithm	The inverse of encryption; uses ciphertext + the same key to restore plaintext.	AES in reverse recovering the message.

TWO REQUIREMENTS FOR SECURE USE

1. **A strong encryption algorithm.** At minimum, an opponent who knows the algorithm and has one or more ciphertexts must be unable to decrypt the message or deduce the key. Stronger form: the key stays undiscoverable even given **multiple ciphertext–plaintext pairs**.
2. **Sender and receiver must obtain and maintain the key securely.** If an unauthorised party gets the key and knows the public algorithm, everything encrypted with it is compromised (e.g. a key pushed to a public GitHub repo).

Key generation and distribution

A key-generation algorithm produces a random number and derives the secret key from it. Three options to share it:

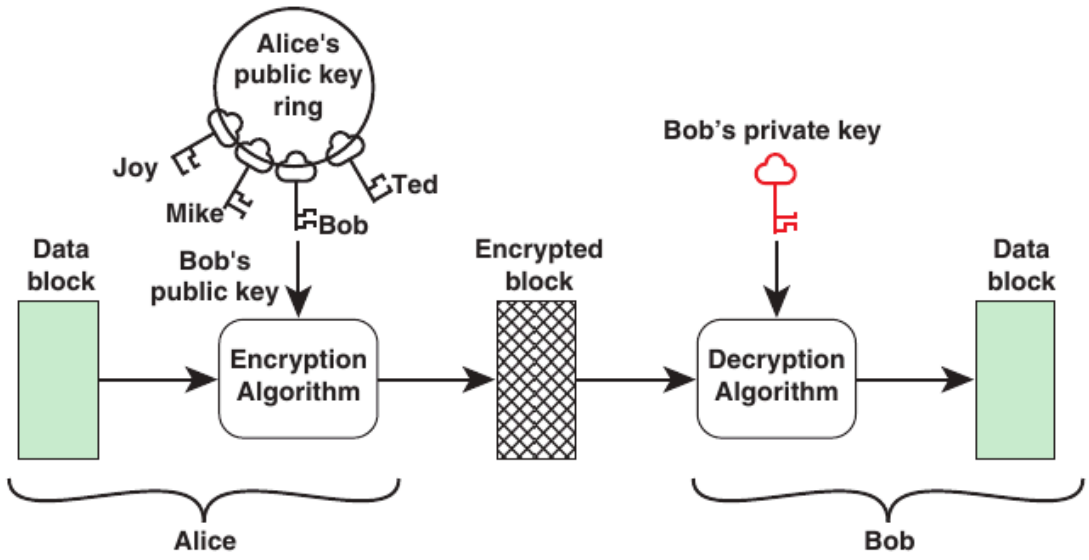
1. **One party generates the key and securely transfers it** to the other (e.g. a hardware token hand-delivered).
2. **Both parties run a secure key-exchange protocol** that computes a shared key without sending it (e.g. Diffie–Hellman in TLS).
3. **A third party generates and securely delivers the key to both** (e.g. a Kerberos Key Distribution Centre issuing a session key).

Attacks an eavesdropper can attempt

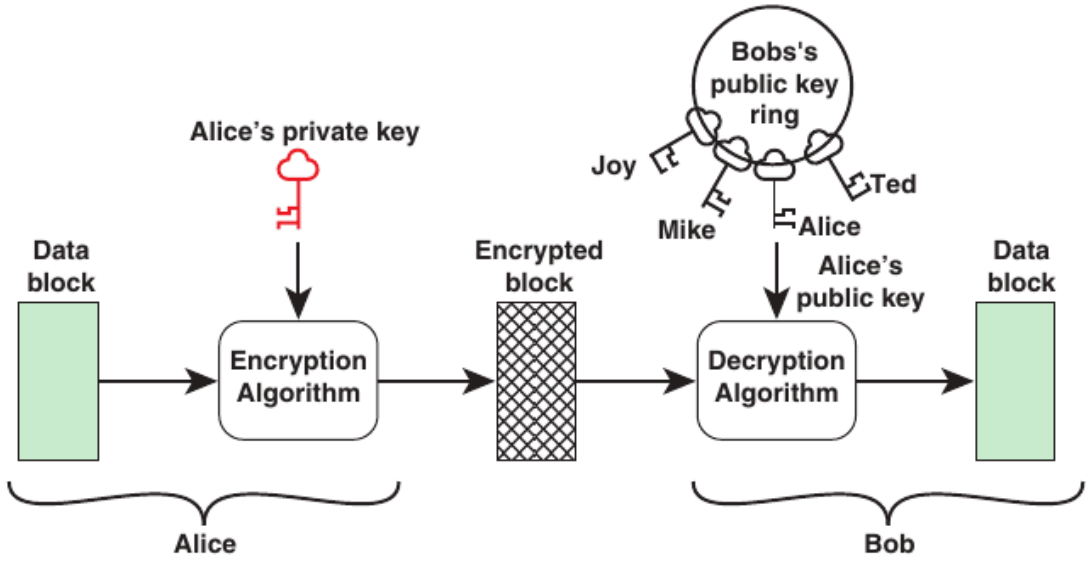
Attack	Description
Cryptanalysis	Exploits algorithm characteristics, plaintext patterns or known plaintext/ciphertext pairs to deduce key or message. If the key is found, **all past and future messages** are compromised.
Brute-force	Tries every possible key until intelligible plaintext appears. On average **half the key space** must be tried. A long key (e.g. 256 bits) makes it computationally infeasible.

4.9 Asymmetric (public-key) encryption

Uses two mathematically related but distinct keys: a **public key** (distributed openly) and a **private key** (kept strictly confidential by its owner).



(a) Public-key encryption/decryption (Alice encrypts block for Bob only)



(b) Public-key encryption/decryption (Alice authenticates block for any recipient)

FIGURE 1.6 Model of Asymmetric Cryptosystem

Figure 1.6 — Model of an asymmetric cryptosystem. (a) Public-key encryption/decryption — **Alice encrypts a block for Bob only** (Bob's public key from Alice's key ring; Bob decrypts with his private key). (b) **Alice authenticates a block for any recipient** (Alice's private key encrypts; anyone decrypts with Alice's public key). SECURITY TEXT

Six fundamental ingredients

Ingredient	Meaning
Plaintext	The readable message/data fed into the algorithm (e.g. a confidential PDF contract).
Encryption algorithm	Performs transformations on the plaintext using one of the keys (e.g. RSA).
Public key & private key (the pair — counted as two ingredients)	Chosen so that if one encrypts, the other decrypts. Public key shared with the world; private key held only by the owner.
Ciphertext	Scrambled output depending on the plaintext and whichever key was supplied.
Decryption algorithm	Takes ciphertext and the **complementary** key to recover plaintext.

Steps for confidential communication (Figure 1.6a)

1. **Key generation** — each user generates a pair of complementary keys locally.
2. **Key publishing** — each publishes the public key in an accessible register/ring; the private key stays secret.
3. **Encryption for confidentiality** — Alice encrypts the plaintext with **Bob's public key**.
4. **Decryption** — Bob decrypts with **Bob's private key**; only Bob holds it, so no eavesdropper can read it.

Source authentication (Figure 1.6b)

If secrecy is not required but Bob must be certain the message came from Alice: (1) Alice encrypts with **Alice's private key**; (2) Bob decrypts with **Alice's public key**; (3) only Alice has her private key, so success proves Alice authored it.

EXAM ALERT — WHICH KEY?

Goal	Encrypt with	Decrypt with
Confidentiality (only Bob can read)	Bob's **public** key	Bob's **private** key
Authentication (proves Alice sent)	Alice's **private** key	Alice's **public** key

TABLE 1.2 Symmetric and Asymmetric Encryption

Symmetric Encryption	Asymmetric Encryption
Needed to Work:	***Needed to Work:***
The same algorithm with the same secret key is used for encryption and decryption.	One algorithm is used for encryption and a related algorithm for decryption, with a pair of keys, known as the public key and the private key. The two keys can be used in either order, one for encryption and one for decryption.
The sender and receiver must share the algorithm and the secret key.	The sender and receiver must each have a unique public/private key pair.
Needed for Security:	***Needed for Security:***
The key must be kept secret.	The private key must be kept secret.
It must be impossible or at least impractical to decipher a message if the key is kept secret.	It must be impossible or at least impractical to decipher a message if the private key is kept secret.
Knowledge of the algorithm plus samples of ciphertext must be insufficient to determine the key.	Knowledge of the algorithm plus the public key plus samples of ciphertext must be insufficient to determine the private key.

Table 1.2 — Symmetric and asymmetric encryption SECURITY TEXT

Symmetric vs asymmetric — extended comparison

Aspect	Symmetric	Asymmetric
Needed to work	Same algorithm with the same secret key for encrypt and decrypt; sender and receiver share algorithm **and** key.	One algorithm for encryption and a related one for decryption with a **key pair**; keys usable in either order; each party needs its own unique pair.
Needed for security	Key must be secret; impossible/impractical to decipher without it; algorithm + ciphertext samples must not reveal the key.	Private key must be secret; impractical to decipher without it; algorithm + public key + ciphertext samples must not reveal the private key.
Speed (performance)	Fast — suited to bulk data.	Complex modular maths, considerably slower — used for **small payloads** (encrypting a symmetric session key, signing a hash digest).
Key distribution	Hard: must share the secret securely beforehand.	Easier: public key can be published (but needs PKI to trust it).

4.10 Cryptographic hash functions

DEFINITION

A hash function **H** maps an arbitrary-length message x to a small fixed-length block **h = H(x)** — the hash value, hash code or digest. It is **many-to-one**: infinitely many inputs map to a finite range of outputs.

TABLE 1.3 Requirements for Cryptographic Hash Function H

Requirement	Description
Variable input size	H can be applied to a block of data of any size.
Fixed output size	H produces a fixed-length output.
Efficiency	H(x) is relatively easy to compute for any x, making both hardware and software implementations practical.
Preimage resistant (one-way property)	For any given hash value h, it is computationally infeasible to find y such that H(y) = h.
Second preimage resistant (weak collision resistant)	For any given block x, it is computationally infeasible to find $y \neq x$ with H(y) = H(x).
Collision resistant (strong collision resistant)	It is computationally infeasible to find any pair (x, y) such that H(x) = H(y).
Pseudorandomness	Output of H meets standard tests for pseudorandomness; that is, the output appears to be a random sequence of bits.

Table 1.3 — Requirements for a cryptographic hash function H SECURITY TEXT

Requirement	Description	Plain explanation & example
Variable input size	H can be applied to a block of data of any size.	Works for a word or a 10 GB OS image.
Fixed output size	H produces fixed-length output.	Always 256 bits for SHA-256, whatever the input.
Efficiency	H(x) is relatively easy to compute for any x; practical in hardware and software.	Fast on laptops and phones.
Preimage resistant (one-way)	For any given h, it is computationally infeasible to find y with H(y) = h.	Cannot reverse a hash to the original password.
Second-preimage resistant (weak collision resistant)	For any given x, it is computationally infeasible to find y ≠ x with H(y) = H(x).	Given a specific document, an attacker cannot forge a second one with the same hash.
Collision resistant (strong collision resistant)	Infeasible to find **any** pair (x, y) with H(x) = H(y).	No two different files anywhere can be made to share a hash.
Pseudorandomness	Output passes standard tests for pseudorandomness.	Changing one input character changes ~half the output bits (avalanche).

YOUR MARKS YOUR MARK

You bracketed **preimage resistant** and **second-preimage resistant**. The distinction examiners test: preimage = given only the *hash* h, find an input; second preimage = given a *specific input* x, find another input with the same hash; collision = find *any* two colliding inputs (attacker chooses both, so it is the easiest to break). ADDED Collision resistance *implies* second-preimage resistance, and for an n-bit hash a generic collision needs ≈ $2^{n/2}$ work (birthday bound) versus ≈ 2^{n} for a preimage.

Common uses of secure hash functions (Figure 1.7)

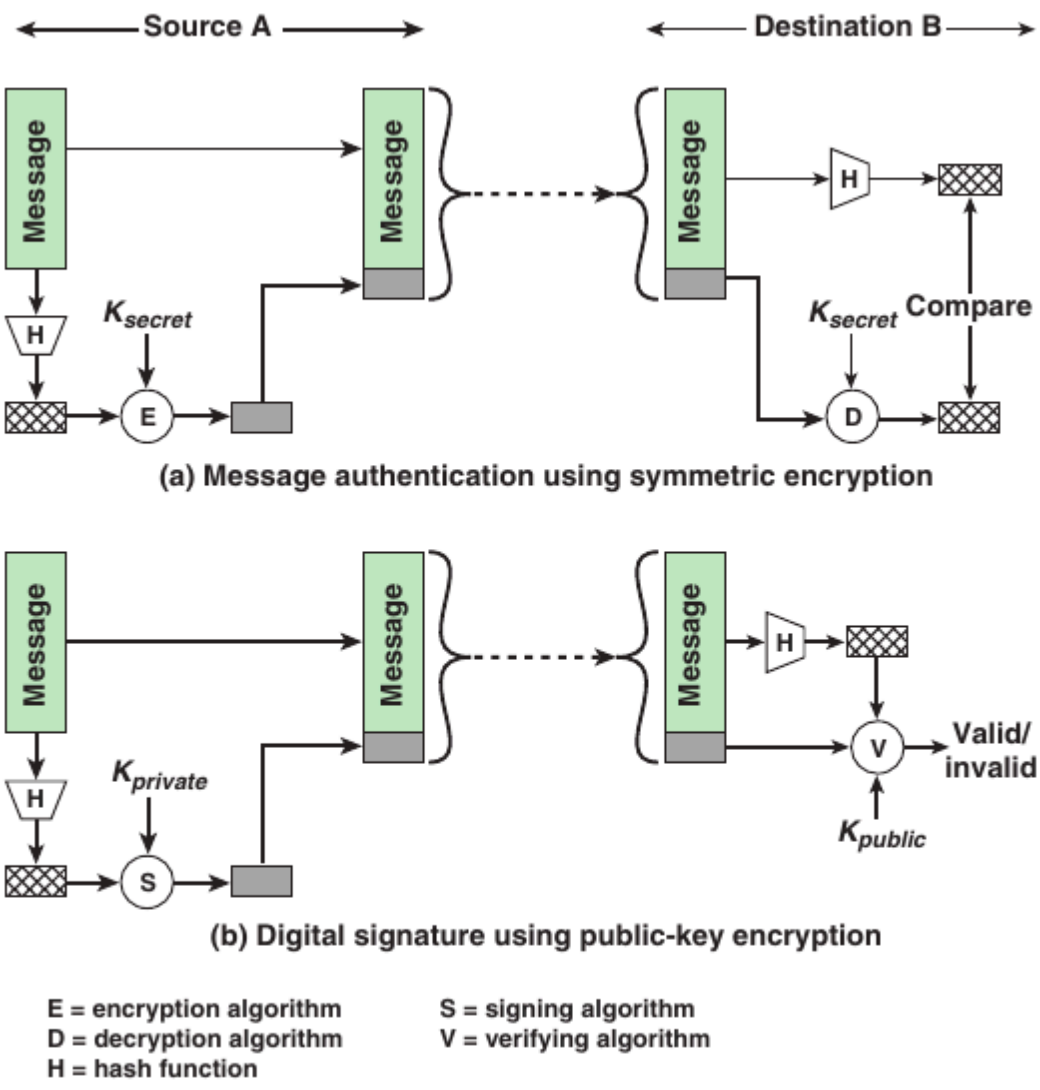


FIGURE 1.7 Uses for a Secure Hash Function

Figure 1.7 — Uses for a secure hash function: (a) message authentication using symmetric encryption; (b) digital signature using public-key encryption. E = encryption algorithm · D = decryption algorithm · H = hash function · S = signing algorithm · V = verifying algorithm. SECURITY TEXT

(A) MESSAGE AUTHENTICATION USING SYMMETRIC ENCRYPTION

1. **Hash generation** — sender computes h = H(M).
2. **Hash encryption** — sender encrypts h with the shared secret key K_{secret} → the encrypted digest (the "code").
3. **Transmission** — message M plus the encrypted digest are sent.
4. **Verification** — receiver decrypts the digest with K_{secret}, independently computes H(M) from the received message, and **compares**.

ALTERATION ASSURANCE
If the message is altered, the computed hash won't match the decrypted hash.

AUTHENTICITY ASSURANCE
Only the legitimate sender has K_{secret}, so only they could produce a matching encrypted hash.

SEQUENCE ASSURANCE
Timestamps or sequence numbers inside the message defeat replay and reordering.

(B) DIGITAL SIGNATURE

The hash is signed with the sender's **private** key (asymmetric) — see 4.11.

4.11 Digital signatures

DEFINITION (NIST FIPS 186-4, DIGITAL SIGNATURE STANDARD)
The result of a cryptographic transformation of data that provides **origin authentication, data integrity and signatory nonrepudiation**.

Signing (Bob)

1. Pass the message through a secure hash H to produce a digest.
2. Feed the digest and **Bob's private key** ($K_{private}$) into signing algorithm S → the signature.
3. Transmit the message with the signature attached.

Verifying (any recipient)

1. Hash the received message with the same H.
2. Feed the hash, the attached signature and **Bob's public key** (K_{public}) into verification algorithm V.
3. If valid: Bob signed it, it wasn't modified, and Bob cannot repudiate it.

Five core applications of digital signatures

Application	Plain explanation	Example
Signing email to authenticate the sender	Proves who sent it; stops spoofing.	S/MIME-signed corporate email from the CEO.
Signing software to authenticate source and counter tampering	Downloaded code is from the real developer, malware-free.	OS verifies Microsoft/Apple installer signatures.
Verifying authorship/origin of digital data	Confirms who created a file.	Signed e-prescription from a licensed physician.
Ensuring integrity against tampering	Change in transit is detectable.	Altering a figure in a signed PDF breaks the seal.
Authenticating online entities	Confirms a remote service is legitimate.	Client validating a server during a TLS handshake.

4.12 Practical considerations

Selecting algorithms and key lengths

Advances in computing and cryptanalysis make older ciphers and key lengths obsolete. Organisations follow guidance from **NIST** (SP 800-131A, FIPS 140-2) and **ENISA**.

Purpose	NIST recommendation
Symmetric encryption	**AES** with **128, 192 or 256-bit** keys — the globally accepted standard.
Hash functions	**SHA-2 and SHA-3**, digest lengths **224–512 bits**. SHA-3 has an entirely different internal structure from SHA-2 (a fallback if SHA-2 weakens) and a compact hardware profile suiting constrained devices (sensors, smart appliances).
Digital signatures	Three alternatives: **DSA 2048-bit**, **RSA 2048-bit**, **ECDSA 224-bit** (equivalent strength with far shorter keys).

Implementation considerations (NIST SP 800-12)

Consideration	Meaning	Example
Selecting design and implementation standards	Use open, vetted standards (AES, SHA, DSS), not proprietary secret algorithms.	Standard AES-256 instead of an in-house scrambling formula.
Hardware vs software vs firmware	Weigh security, performance, cost and ease of deployment.	Keys in a Hardware Security Module (HSM) instead of server memory.
Managing keys	Full lifecycle: generation, storage, exchange, access control, revocation, logging.	A KMS that rotates keys every 90 days.
Security of cryptographic modules	Hardware/software modules must resist physical and logical tampering — validated via NIST's **CMVP** under **FIPS 140-2** (**four increasing levels** of assurance).	A FIPS 140-2 Level 3 smart card that zeroises memory if the chip is cut open.

LIGHTWEIGHT CRYPTOGRAPHIC ALGORITHMS

Objective: minimise execution time, memory and power while keeping security. **Target:** constrained hardware — IoT sensors, embedded microcontrollers, RFID tags. **Focus:** lightweight symmetric ciphers and hash functions (NISTIR 8114).

POST-QUANTUM CRYPTOGRAPHIC ALGORITHMS

Objective: new asymmetric algorithms resistant to large-scale quantum computers. **Problem:** Shor's algorithm can efficiently break RSA, DSA and ECDSA. **Effort:** NIST is standardising replacements (e.g. lattice-based) — NISTIR 8105.

4.13 Public-key infrastructure (PKI)

DEFINITION

A **PKI** is the combined framework of policies, hardware, software and procedures used to **create, manage, distribute, evaluate and revoke public-key certificates**. It binds public keys to verified human or system identities.

Public-key certificates

A **public-key certificate** is a digital document that uniquely identifies an entity, contains that entity's public key, and is **digitally signed by a trusted third party — the Certification Authority (CA)**. Standard: **ITU-T X.509**.

THE PROBLEM IT SOLVES

If public keys were simply broadcast, an attacker could publish *their own* key while claiming it belongs to someone else; and a phonebook look-up for every transaction doesn't scale. **Solution:** a certificate bundles owner identity + public key + CA details + expiry; the CA hashes the bundle and signs it with the **CA's private key**; anyone verifies using the CA's widely published public key.

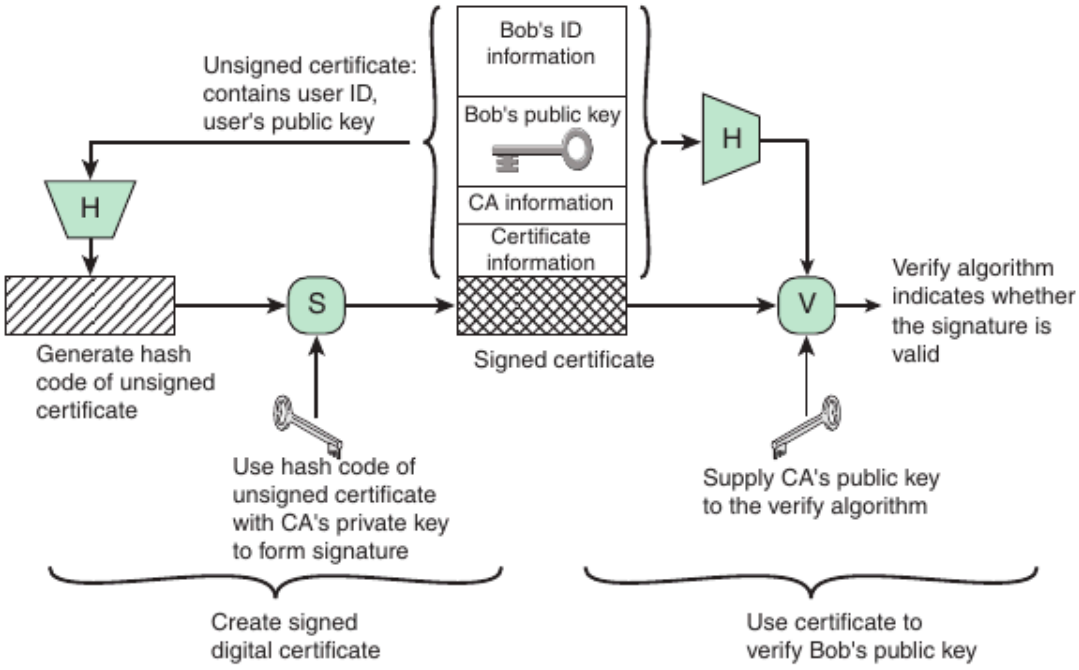


FIGURE 1.8 Public-Key Certificate Use

Figure 1.8 — Public-key certificate use. Left: generate hash of the unsigned certificate (Bob's ID, Bob's public key, CA information, certificate information) and sign it with the CA's private key. Right: recipient hashes the certificate, supplies the CA's public key to the verify algorithm V, which indicates whether the signature is valid. SECURITY TEXT

PKI architecture — four requirements

1. Any participant can read a certificate to learn the owner's name and public key.
2. Any participant can verify the certificate came from the CA and is not counterfeit.

3. Only the CA can create and update certificates.
4. Any participant can verify the certificate is currently valid (not expired, not revoked).

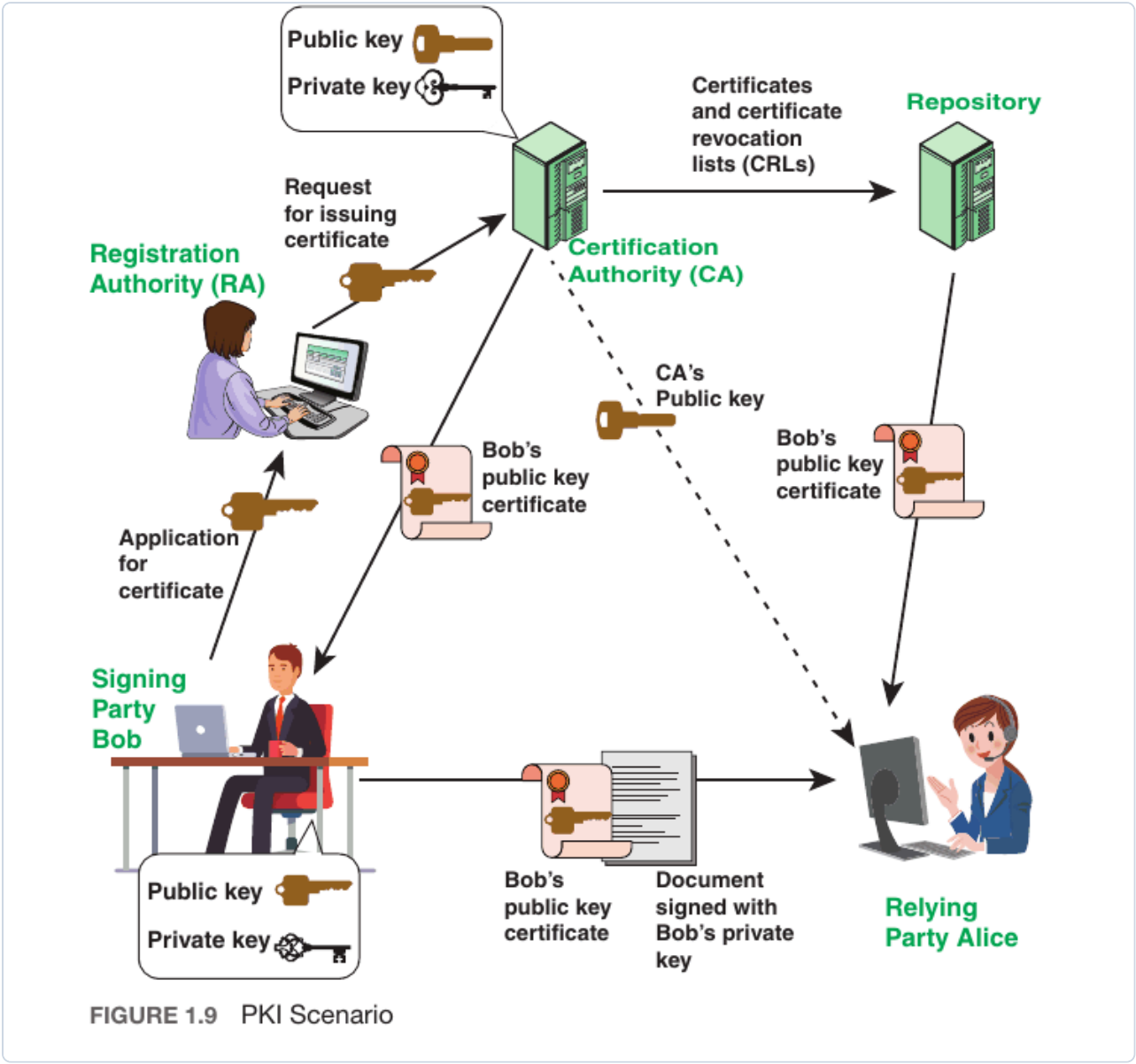


Figure 1.9 — PKI scenario: Bob applies for a certificate via the Registration Authority; the CA issues it and publishes certificates and CRLs to the repository; Alice (relying party) checks the certificate and CA's public key to verify a document Bob signed with his private key. SECURITY TEXT

The five PKI components

Component	Role	Example
End entity	An end user, device (router, firewall, server) or software process named as the **subject** of a certificate.	An e-commerce server, or employee Bob requesting a certificate.
Certification authority (CA)	Trusted by users to create, sign and issue certificates; also publishes **Certificate Revocation Lists (CRLs)** for certificates revoked before expiry.	DigiCert, Let's Encrypt.
Registration authority (RA)	**Optional** administrative component that takes over identity verification from the CA during enrolment.	Company HR verifying a passport before approving a certificate request.

Component	Role	Example
Repository	Directory service/network location where certificates and CRLs are stored and retrieved.	LDAP directory or HTTP endpoint hosting .crl files.
Relying party	Any user/system that relies on a certificate's data to verify a signature or encrypt communications.	Alice checking Bob's certificate before processing his e-invoice.

Operational interaction flow (Figure 1.9)

1. **Certificate issuance** — Bob submits his public key to the RA/CA; the RA verifies identity; the CA issues a signed certificate with Bob's public key.
2. **Revocation publishing** — the CA publishes issued certificates and periodic CRLs to the repository.
3. **Encrypted communication** — Alice checks the repository that Bob's certificate is active and unrevoked, takes Bob's public key from it, and encrypts.
4. **Signature verification** — for a document Bob signed, Alice verifies the CA's signature on Bob's certificate with the CA's public key, then verifies Bob's signature with Bob's public key.
5. **Hierarchical trust** — large enterprises use hierarchical CAs: a trusted **Root CA** signs certificates for subordinate CAs; browsers, OSs and phones ship with **trust stores** of root certificates so certificate chains validate worldwide.

MODULE 4 IN FIVE LINES

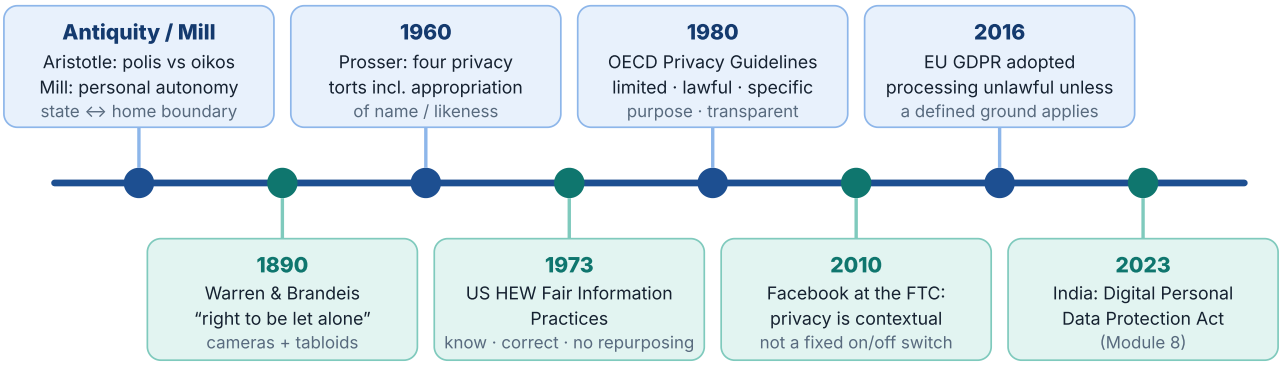
1. Objectives: **C-I-A** + authenticity + accountability.
2. Passive attacks → **prevent** (encrypt); active attacks → **detect & recover**.
3. Symmetric = one shared key, fast; asymmetric = key pair, slow, solves key distribution and gives signatures.
4. Hash = fixed-size one-way fingerprint; signature = **hash signed with private key**.
5. PKI binds public keys to identities through CA-signed **X.509 certificates**.

MODULE 5

Describing the Harms from Loss of Privacy

5.1 History: how ideas of privacy harm evolved

Ideas about privacy — and the harms from losing it — have evolved over centuries, shifting with major technological change.



Privacy timeline — from the state/home boundary of antiquity, via information privacy (1890) and data-protection principles (1973, 1980, 2016), to India's 2023 Act. Dates for 2010 and 2016 are those given in your notes (Facebook's FTC testimony; GDPR).

Era	Thinker / event	Idea of privacy & harm	Simple example
Antiquity	**Aristotle** — public polis vs private oikos (household); **J. S. Mill** — principle of autonomy	Privacy = boundary where the **state and public have no legitimate right to interfere**. In personal spheres, intrusion or public judgement lowers well-being; freedom and autonomy should be protected. Legal descendants: reproductive autonomy, contraception, personal relationships.	A municipality cannot install cameras inside private living rooms or dictate how couples run their household.
Late 19th century	**Warren & Brandeis**, "The Right to Privacy", *Harvard Law Review*, **1890**	Privacy shifts from physical autonomy to **control over personal information**, provoked by portable cameras and sensationalist tabloids that turned neighbourhood gossip into a commercial enterprise. Law must recognise a **"right to be let alone"**. The harm is **not slander or economic defamation** but humiliation, injured self-esteem and disturbed peace of mind.	A tabloid photographer secretly photographs a private citizen in a private garden and publishes it to boost sales.

Era	Thinker / event	Idea of privacy & harm	Simple example
Mid-20th century	**William Prosser, 1960**	Reviewed decades of US case law and organised recognised harms into **four privacy torts**: (1) **intrusion** upon seclusion (physical intrusion); (2) **public disclosure** of embarrassing private facts; (3) depiction in a **false light**; (4) **appropriation** of name or likeness — unauthorised commercial exploitation of identity (e.g. photo in an ad without consent). Identity impersonation was rare then; today identity theft is a daily threat. CORRECTED	A company uses a stranger's street photograph on a billboard campaign without permission or payment.

THE DISCONNECT ACROSS HISTORICAL PRIVACY HARMS

The harms grouped under "privacy" share few practical characteristics: a state criminalising consensual adult relationships; an aggressive journalist publishing embarrassing family photos; a cybercriminal stealing card digits via a database exploit. So the **remedies differ completely**:

Harm	Appropriate remedy
Interference with physical/personal autonomy	Constitutional limits on government
Sensationalist reporting	Press ethics and civil torts
Digital theft	Cybersecurity safeguards and data-protection statutes
AI, big-data analytics, algorithmic profiling	**New** harms that cannot be solved with 19th/20th-century remedies

CONTEXTUAL PRIVACY — FACEBOOK BEFORE THE FTC (2010)

Facebook argued that static definitions of privacy (e.g. Brandeis's) cannot be applied rigidly to the social internet: online privacy is not a fixed on/off switch; it depends on the **context of the relationship, the platform and the user's expectations**. *Example:* sharing holiday photos with 20 friends is fine; selling them to facial-recognition advertisers is not.

5.2 Public perceptions of privacy-related harm

The consumer dilemma

- **Alan Westin** told the US Congress that citizens balance two competing desires: protecting privacy *and* enjoying the conveniences, personalisation and efficiency of a consumer-driven digital society.
- **UK studies** agree: citizens know sharing carries security risks, treat them as a necessary compromise and accept them when personal benefits are clear.

Public benefits vs personal benefits

The public supports sharing for the collective good (research, infrastructure planning, crime prevention), but **personal advantage** is the main incentive. A **Deloitte** study: "more tailored services" was the top

reason to share data, outranking “public benefit” by **two to one**.

PERCEIVED BENEFITS

- Cheaper or free digital services and goods
- Highly personalised recommendations and communications
- Faster, more convenient checkouts and transactions
- Better crime detection, fraud prevention, public security

IDENTIFIED DANGERS

- Loss of personal control over private records
- Economic injury — identity theft, account takeover, fraud
- Intrusive marketing and unwanted advertising
- Unfair discrimination in insurance, lending, employment
- Distrust of data handlers who conceal how records are shared and monetised

The “privacy paradox”

DEFINITION

The disconnect where people express **high concern** for privacy in surveys yet readily adopt online services, apps and loyalty cards that require sharing extensive personal data.

Survey contradictions cited

Finding	The contradiction
Consumers love personalised recommendations…	…yet are widely annoyed by the browsing trackers that make them possible.
41% agreed companies clearly explain why they collect data…	…yet most admitted hesitating to share because they had no idea what companies actually do with it.
Consumers trust public/governmental institutions most to safeguard data…	…despite those bodies’ frequently poor breach and leak records.
Annenberg School: **55%** disagreed with stores building predictive behavioural profiles…	…but **43%** of the same people agreed to share grocery purchase histories for discounts.

Reinterpreting the paradox: resignation, not contradiction

- The behaviour doesn’t necessarily reflect ignorance or irrationality.
- **Resignation:** consumers know the deal is unfair but, because opting out is impractical, participate out of necessity while staying dissatisfied.
- **“Take-it-or-leave-it” trap:** policies are all-or-nothing; users accept them to reach essential utilities, banking and social platforms, knowing data is pooled and analysed behind the scenes.

EXAMPLE

A young parent suspects a retail loyalty card tracks purchases to predict life changes (e.g. pregnancy). They dislike it but keep scanning because they can’t afford to forfeit grocery discounts.

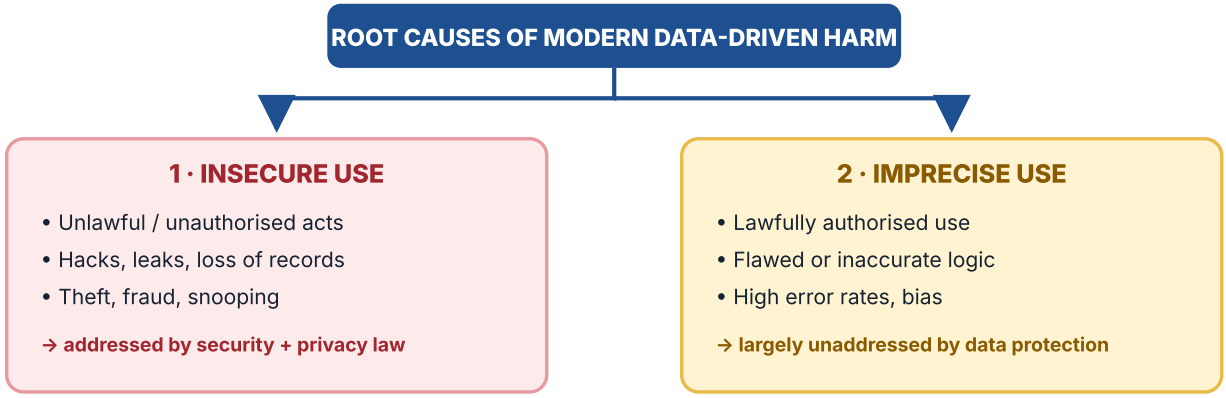
EXAM ALERT

If asked to "explain the privacy paradox", define it, give a statistic (Annenberg 55% vs 43%), then **critique it**: it is better explained as **resignation** under take-it-or-leave-it terms than as hypocrisy.

HIGH-YIELD

5.3 Insecure use and imprecise use of data

Public debate often misses the root causes of harm by focusing on two narrow mechanisms: (1) **informed consent**, which gives little real protection when every available choice is poor; and (2) regulating only the **legal purpose** of collection while ignoring the **quality, accuracy and precision** of the algorithms that process the data.



Root causes of harm — insecure use (illegal/unauthorised) vs imprecise use (legal but inaccurate).

	1 · Insecure use	2 · Imprecise use
Definition	Harm from **unauthorised, illegal or accidental** access to, loss of, or theft of personal records — cyberattacks, poor security, or controllers sharing beyond legal authority.	Harm when an organisation processes data for a **fully authorised, lawful purpose** but produces damaging, incorrect or misleading results because of flawed algorithms, poor logic or inaccurate data.
Resulting harms	Financial theft, identity fraud, unauthorised broker disclosures, exposure of confidential records, targeted scams.	Unfair financial rejection, incorrect medical diagnoses, nuisance advertising, systemic discrimination.
Example	A hospital leaves an unencrypted drive with hundreds of thousands of records and SSNs exposed online → criminals steal identities, file fraudulent tax returns.	A bank legally uses an ML model for loan decisions; faulty statistical proxies misclassify a creditworthy borrower as high-risk and deny a mortgage without human review.

Everyday examples of imprecise use

- **Nuisance marketing vs helpful personalisation:** users share interests for relevant recommendations but inaccurate targeting floods them with repetitive promotions; configuring ad preferences by hand makes users do the algorithm's work.
- **Fraud detection vs unfair discrimination:** people support catching tax cheats and insurance fraudsters, but imprecise scoring produces **false positives** that flag honest applicants — the difference is decided entirely by statistical accuracy and margin of error.

Documented harms of imprecise software systems

System	Finding
Mental-health apps	Clinical reviews: multiple therapy apps relied on weak scientific methods, risking more harm than good for vulnerable patients.
Melanoma-detection scanners	Audit: **three of four** diagnostic apps misidentified **at least 30%** of actual melanomas as "unconcerning".
Automated symptom checkers	Triage apps often give incorrect recommendations, steering patients away from urgent care.
Wearable fitness trackers	Trials: some weight-loss trackers hindered long-term progress compared with standard counselling.
News/information platforms	Recommendation engines favour sensational headlines → ideological **filter bubbles** that reinforce false beliefs and leave users less informed.
Algorithmic price discrimination	E-commerce platforms use browsing history and hardware profiles to charge some customers higher prices for flights/goods — exploiting data shared in hope of better deals.

THE GROWING THREAT OF IMPRECISE AUTOMATED SYSTEMS

Breaches get attention because they are clearly criminal. But as AI and automated decision-making spread through credit scoring, medicine, hiring and policing, the risk from **imprecise algorithms** grows. Market incentives often reward rapid, cheap automation over rigorous accuracy. Legal but poorly designed "**rogue algorithms**" operating invisibly at scale are a societal risk comparable to cybersecurity breaches; without transparency individuals cannot tell whether an algorithm is helping or quietly working against them.

MODULE 6

How Does Data Protection Protect Against Insecure and Imprecise Use?

6.1 Evolution of foundational frameworks

Data-protection frameworks have historically controlled *how personal data is collected and processed*.

Framework	Core content	Plain explanation & example
US HEW Fair Information Practices (1973)	Individuals have a right to know what data is collected, understand how it will be used, correct inaccurate records, and ensure data is not repurposed without consent.	If a school takes your postal address for enrolment it cannot hand it to a marketing firm without asking you.
OECD Privacy Guidelines (1980)	Collection must be **limited, lawful, bound to a specific purpose, transparent**, with the individual's right to inspect and correct.	An employer collects only tax/identity details needed for payroll, not browsing histories.
EU regulation & the GDPR (2016)	All processing is **unlawful unless** it fits clearly defined statutory grounds, is proportionate, and respects rights to access, rectify and withhold consent.	Processing is banned by default unless the company meets strict legal justifications and gives users control.

THE FUNDAMENTAL DESIGN LIMITATION

- These frameworks were designed to prevent **insecure use** — unauthorised access, leaks, hacking, unlawful repurposing.
- They were **not** designed to protect people from **imprecise use** in modern automated decision-making and AI.

Static vs complex decision systems

	Static, simple logic	Complex AI algorithms
Why it matters	Explaining the rule lets citizens and regulators judge precision and risk.	High-dimensional statistical correlations can't be evaluated by reading a collection policy.
Example	"Income under $25,000 → reject the loan." The logic is visible to the applicant.	A neural network using thousands of variables (browsing, typing cadence, shopping) to predict credit risk — hard to tell if it is accurate or biased.

6.2 The GDPR and the problem of imprecision

The GDPR introduced modern digital rights, but it does not solve harms from imprecise algorithmic decision-making.

A · Protection of fundamental rights — Recital 4

- GDPR exists to protect rights under the **EU Charter**: private and family life, home, communications, personal data, freedom of expression, thought, religion, non-discrimination.
- Most commonly enforced: Charter **Art. 8** (protection of personal data) and **Art. 21** (non-discrimination) (your source notes say "Art. 25", which in the Charter is the rights of the elderly — likely a slip) CORRECTED.
- *Example:* penalising a hiring platform that systematically filters out applicants by race or gender.

B · Broader protection against adverse consequences — Recitals 75 & 85

- List processing harms: discrimination, identity theft, fraud, financial loss, reputational damage, breach of confidentiality, unauthorised reversal of pseudonymization, and "**any other significant economic or social disadvantage**".
- **Ambiguity:** that last phrase sounds wide enough to cover poor-quality automated decisions, yet enforcement focuses on unauthorised use and unlawful discrimination.

C · The problem of "inaccuracies" in profiling — Recital 71

- Controllers must use **appropriate mathematical or statistical procedures** for profiling and technical measures to correct inaccuracies and minimise the risk of errors.
- **The legal gap (doctor analogy):** in data-protection law an "inaccuracy" is an incorrect *factual record* (misspelt name, wrong age). An imprecise statistical *prediction* or propensity score is not a factual inaccuracy. If a poor doctor misdiagnoses you, the note "Doctor diagnosed patient with Disease X" is still an accurate record of what the doctor said — even though the judgement was wrong.
- *Example:* an algorithm says there is a 70% risk you will default; the bank satisfies Recital 71 merely by logging that it generated 70%, even if the model is flawed.

D · Limits of existing GDPR rights against imprecision

Right	What it gives	Why it doesn't fix imprecision
Right to an explanation (Arts 13–15 & 22)	A high-level explanation of the *consequences* of processing.	Not an audit of algorithmic precision. A lender need only say "we use an automated credit score; if low, no loan".
Right not to be subject to automated decisions (Art. 22)	Lets individuals opt out entirely.	Doesn't help people who *want* the automated service but need assurance it is accurate (e.g. an X-ray scanner).
Right of access (Art. 15)	Inspect the personal data held about you.	Your own file cannot show whether an algorithm is broken — that needs performance analysis across large populations.

PECULIAR LEGAL OUTCOMES — DISCRIMINATION VS UNIFORM IMPRECISION

The GDPR prohibits discrimination against protected characteristics but not general imprecision, so loopholes appear:

- **Case 1 — insurance pricing:** an algorithm that overcharges one ethnic group breaches anti-discrimination rules; one that is badly calibrated and overcharges *everyone* equally stays legal.
- **Case 2 — targeted ads:** a travel service sending irrelevant, intrusive ads that annoy only women risks penalties; sending the same bad ads to men and women alike does not violate the law.

6.3 Transparency, consent and fair processing

Transparency and informed consent are the primary legal mechanisms of fair processing worldwide.

- **Regulatory assumption:** informing users about privacy policies lets them weigh risks and benefits and choose rationally.
- **Canadian standard:** the Privacy Commissioner of Canada — understanding an organisation's practices lets individuals assess risk and freely decide whether to share.

CRITIQUE OF "NOTICE AND CONSENT"

1. Notices are overly complex, in dense legal jargon.
2. Severe **power imbalance** between individuals and multinational platforms.
3. Consents are **bundled and broad**; hard to foresee what they enable.
4. Disclosures create a **false sense of security** — they act as liability shields, not consumer protection.
5. Smart devices and **IoT** collect continuously in the background, making it unclear *when* consent should be sought.
6. *Example:* clicking "Accept all" on a 40-page smart-speaker agreement because refusal means no device.

Shift toward regulatory accountability: critics argue the law should stop loading the whole burden of risk evaluation onto consumers and place legal responsibility on **service providers**. GDPR introduced audit-trail duties for controllers, but audits mainly verify security controls and rights compliance, not algorithmic precision.

Medical-ethics consent vs data-protection consent

	Medical ethics consent	Data-protection consent
What it tells you	What will happen and why.	What data is collected and the legal purpose.
Risks disclosed	Inherent risks **even if the procedure goes 100% as intended**.	Only the risk of unauthorised breaches or unlawful leaks.
Oversight	Clinical oversight, professional standards, auditing.	No mechanism to evaluate whether algorithms decide precisely or flawedly.

THE ANALOGY

Medical: before knee surgery you are warned not just of errors but of known side-effects when all goes to plan (stiffness, long recovery). **Data:** privacy notices don't warn about what happens when an algorithm works *as intended* — false predictions, biased pricing, unhelpful recommendations. Healthcare consent works because patients trust regulators to hold doctors to account; privacy regimes can't build that trust until they regulate the **precision** of automated systems.

6.4 Privacy vs consumer protection

A common view splits risks into two legal categories:

Privacy regulators

Handle **unauthorised** use: hacking, security lapses, leaks, unlawful processing.

Consumer-protection agencies

Handle **authorised** use: is a legal, consented digital service harmful, low-quality or unfair?

Market-competition assumption: proponents say competition will weed out imprecise algorithms as consumers leave inaccurate services. **Why it fails:** markets often reward algorithms that maximise engagement or profit over accuracy.

THREE ARGUMENTS AGAINST SEPARATING THEM

1. **Public perception** — consumers don't distinguish privacy harms from consumer harms; they care about bad outcomes from data use.
2. **Shared remedies** — both rely on clear notices, transparency and meaningful consent; splitting them across agencies adds bureaucracy.
3. **Access to underlying datasets** — judging precision requires auditing training data and behavioural logs; consumer agencies often lack the expertise and data access privacy regulators have.

Limits of external consumer auditing

- **External scenario testing:** regulators run dummy profiles through an app and observe outputs. *Real example:* the **European Commission** analysed Google's external search outputs to confirm it gave its own comparison-shopping service an unfair advantage.
- **Limitation for dynamic AI:** outside audits struggle with adaptive models that update continuously; measuring precision without inspecting the training data is inefficient and unreliable.

CONCLUSION OF MODULE 6

Privacy frameworks must treat **cybersecurity vulnerabilities and algorithmic imprecision within one unified regulatory model**.

MODULE 7

Measuring Benefits and Risks of Data-driven Automated Decision-Making (Surveillance)

7.1 Surveillance capitalism

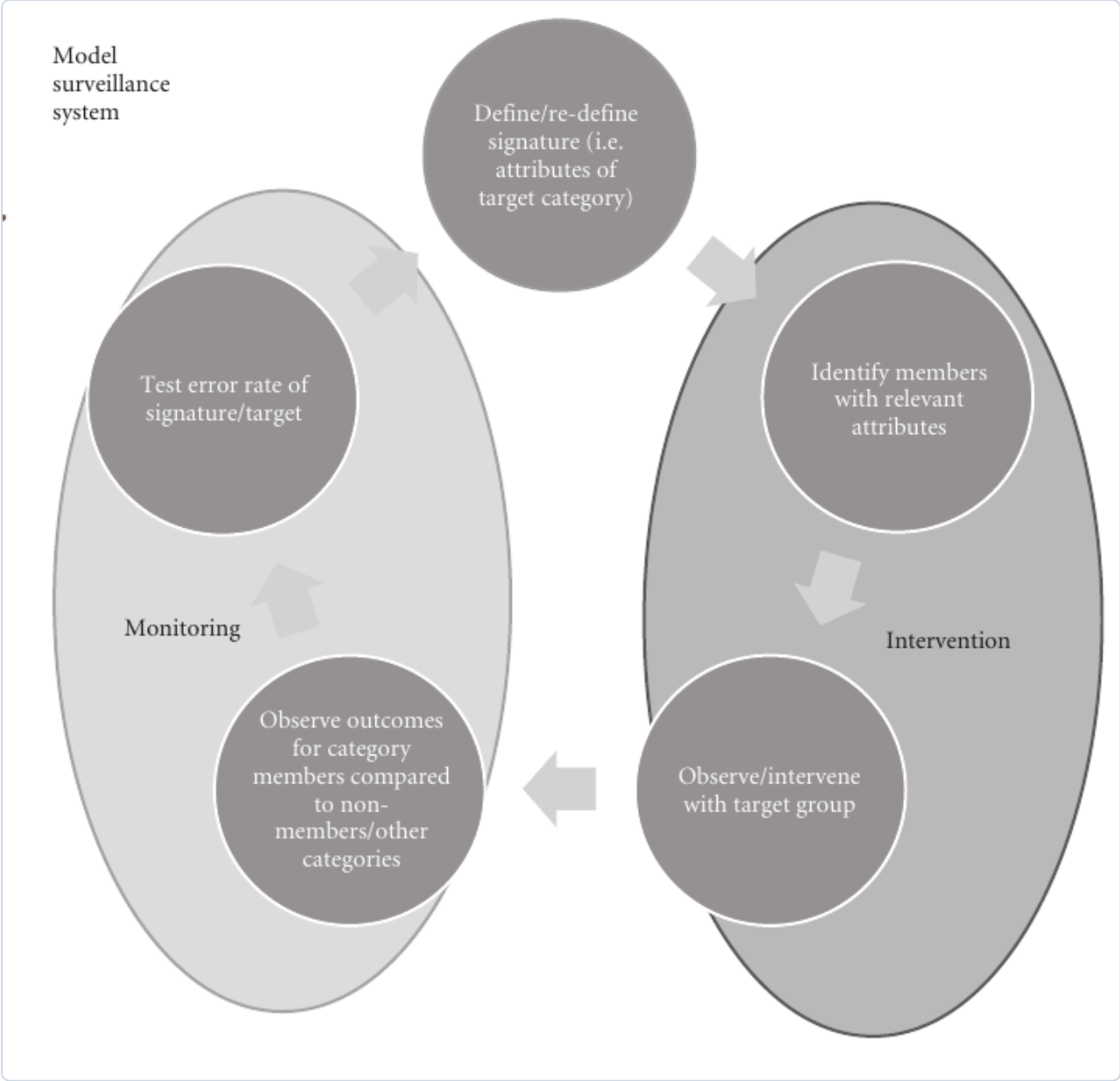
DEFINITION (SHOSHANA ZUBOFF)

Surveillance capitalism = gathering behavioural data, segmenting populations, predicting actions, and tailoring commercial offerings to maximise monetisation.

- Primary business model of search engines (**Google**), social media (**Facebook**) and digital services (**Amazon, Spotify**).
- Governments use matching techniques for digital policing, intelligence gathering and public-sector programmes.
- **Dynamic surveillance systems** continually adapt and refine their internal models.

7.2 Model surveillance system — DIIOT

A five-step lifecycle: **D**efine · **I**dentify · **I**ntervene · **O**bserve outcomes · **T**est error rate.



Model surveillance system — a loop with two phases: **Intervention** (identify members → observe/intervene with target group) and **Monitoring** (observe outcomes → test error rate), feeding back into "define / re-define signature". SURVEILLANCE TEXT

Step	What the system does	Examples
1 · Define (define / re-define signature)	Defines a behavioural tendency or outcome of interest (propensity to buy, respond to medication, commit a crime) and finds statistical associations with historical attributes.	**Security:** likelihood of criminal involvement from phone metadata. **E-commerce:** likelihood of buying shoes from browsing. **Healthcare:** likelihood of heart disease from BP and family history.
2 · Identify (members with relevant attributes)	Collects attributes across the population and runs **clustering** to sort people into segments with similar characteristics.	Labels like "terrorist threat", "working-class commuter", "hypertensive patient".

Step	What the system does	Examples
3 · Intervene (observe/intervene with target group)	Applies specific actions to each segment. **Static limitation:** traditional systems **stop here**, applying fixed rules without checking whether decisions worked.	Wiretaps on high-risk suspects; targeted ads to likely buyers; BP medication to specific patients.
4 · Observe outcomes (compare members to non-members)	Measures real outcomes to verify predictions. **Best practice:** monitor both the treated group and an **untreated control group**.	Stroke rates among medicated vs unmedicated patients; sales conversions of shoppers who saw an ad vs those who didn't.
5 · Test error rate (of signature/target)	Uses outcome data to calculate **sensitivity** (true-positive rate) and **specificity** (true-negative rate); finds attributes that caused wrong predictions; assigns economic/social **cost to errors** and balances against correct predictions → **net benefit**.	—

EXAM ALERT

What makes a **dynamic** surveillance system better than a **static** one is steps 4–5 (monitoring with control groups and error-rate testing) that feed back into step 1. A system that stops at step 3 never learns whether it helps or harms. HIGH-YIELD

7.3 Estimating the net benefit of a surveillance system

$$\text{Net Benefit} = (\text{Value of True Positives} + \text{Value of True Negatives}) - (\text{Cost of False Positives} + \text{Cost of False Negatives})$$

Core error metric	Meaning
False-positive rate	How often the system intervenes when it shouldn't.
False-negative rate	How often it misses someone who needed an intervention.
Cost per error	The physical, emotional or financial harm of each type of error.

Outcome grid ADDED

	Actually has the condition	Does not
Flagged / intervened	**True positive** (correct)	**False positive** (harm: needless intervention)
Not flagged	**False negative** (harm: missed case)	**True negative** (correct)

Sensitivity = TP ÷ (TP + FN) · Specificity = TN ÷ (TN + FP).

CASE STUDY — BREAST-CANCER SCREENING

- Mammography screening was long assumed to give clear medical value.
- **Meta-analyses** showed routine screening can cause **net harm** across broad populations.
- **Why:** many **false positives** subjected healthy women to invasive biopsies, radiation and psychological stress that outweighed the benefit of early detection.
- **Privacy lesson:** reviewing the *legal purpose* (detecting cancer) could never reveal whether the programme helped or harmed; that required measuring the real-world false-positive rate.
- The same error-rate arithmetic applies to algorithms recommending news, investments, fitness routines and diets (e.g. does a smart-watch cardio recommendation improve heart health or raise injury risk?).

7.4 Risks of surveillance systems resulting in net harm

Even well-intentioned systems can cause net harm if statistical precision is left unmonitored.

Proxy optimisation in commercial markets

Algorithms rarely optimise for the user's true well-being; they optimise **commercial proxies** — engagement, clicks, subscription renewals.

- **Fitness app:** maximises 30-day renewals, so recommends easy, fun workouts that don't meet health goals.
- **News aggregator:** promises to inform but optimises click-through, serving sensational, bias-confirming articles → users end up worse informed.

Misaligned error rates (corporate vs social optimum)

What is mathematically optimal for the operator is often undesirable for consumers. *Price optimisation:* the consumer wants the lowest price; the platform finds the price that maximises **its** margin while keeping the customer from leaving. Harm is greatest in **addictive markets** — online gambling, high-interest personal loans, alcohol delivery — where algorithms identify and exploit vulnerable people.

CONCLUSION ON THE FUTURE OF AI

Data-protection frameworks cannot serve humanity if they police only data *security* and ignore algorithmic *imprecision*. As automated decisions expand into diagnostics, autonomous vehicles, recruitment and finance, deploying personal data without algorithmic auditing risks widespread harm.

MODULE 8

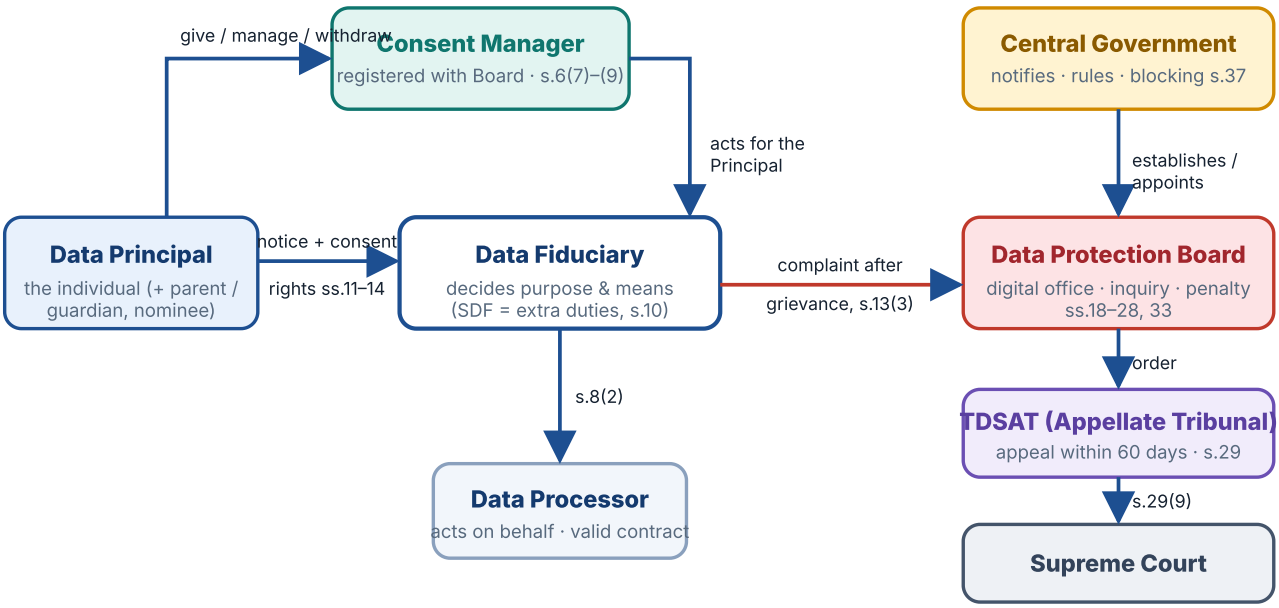
The Digital Personal Data Protection Act, 2023

LONG TITLE (PREAMBLE)

*"An Act to provide for the processing of digital personal data in a manner that recognises both the **right of individuals to protect their personal data** and the **need to process such personal data for lawful purposes** and for matters connected therewith or incidental thereto."*

8.0 The Act at a glance

Fact	Detail
Citation	**Act No. 22 of 2023** · Gazette of India Extraordinary, Part II, Section 1, No. 25 · 11 Aug 2023
Assent	President's assent on **11 August 2023**
Structure	**9 Chapters · 44 Sections · 1 Schedule** (penalties, referred to in s.33(1))
Scope	**Digital** personal data only (collected digitally, or collected non-digitally and digitised) — s.3
Regulator	**Data Protection Board of India** (digital office) → appeals to **TDSAT** → Supreme Court
Model	**Notice + consent** as the main ground, with **"certain legitimate uses"** (s.7) as the only alternative. No "legitimate interests" ground as in the GDPR.
Penalty style	Fixed **maximum rupee caps** in the Schedule (up to ₹250 crore), not % of turnover



Who's who under the Act — the individual deals with the Data Fiduciary (directly or via a Consent Manager); processors work only under contract; the Board enforces; appeals climb to TDSAT and the Supreme Court; the Central Government notifies and makes rules.

Chapter map

Chapter	Sections	Topic
I	1–3	Preliminary — title/commencement, definitions, application
II	4–10	Obligations of Data Fiduciary — grounds, notice, consent, legitimate uses, general obligations, children, Significant Data Fiduciary
III	11–15	Rights and duties of Data Principal — access, correction & erasure, grievance redressal, nomination, duties
IV	16–17	Special provisions — cross-border transfer, exemptions
V	18–26	Data Protection Board of India — establishment, composition, service conditions, disqualification, resignation, proceedings, staff, public servants, Chairperson's powers
VI	27–28	Powers, functions and procedure of the Board
VII	29–32	Appeal and alternate dispute resolution — TDSAT, execution, mediation, voluntary undertaking
VIII	33–34	Penalties and adjudication — penalty factors, Consolidated Fund
IX	35–44	Miscellaneous — good-faith protection, information, blocking, other laws, bar of jurisdiction, rules, laying, Schedule amendment, removal of difficulties, amendments to other Acts
Schedule	s.33(1)	Seven penalty entries (₹10,000 to ₹250 crore)

EXAM ALERT — KNOW THE CHAPTER TITLES

Questions like "Which chapter deals with…?" are easy marks. Memorise the ranges **1–3 · 4–10 · 11–15 · 16–17 · 18–26 · 27–28 · 29–32 · 33–34 · 35–44**.

Chapter I — Preliminary (ss.1–3)

S.1 SHORT TITLE AND COMMENCEMENT

- **(1)** Called the **Digital Personal Data Protection Act, 2023** (DPDP Act).
- **(2)** Comes into force on such date as the Central Government appoints by **notification in the Official Gazette**; **different dates** may be appointed for different provisions.

Plain: phased roll-out. *Example:* set up the Board first, switch on compliance duties months later.

S.2 DEFINITIONS (A) – (ZB)

All 28 definitions, with the Act's own wording condensed and a plain-language reading.

cl.	Term	Meaning under the Act	Plain reading / example
(a)	**Appellate Tribunal**	The **Telecom Disputes Settlement and Appellate Tribunal (TDSAT)** established under s.14 of the TRAI Act, 1997.	Hears appeals against Board orders — e.g. an e-commerce firm fined ₹50 crore appeals here.
(b)	**automated**	Any digital process capable of operating automatically in response to instructions given (or otherwise) for processing data.	Scripts/algorithms running without a human per action — e.g. a bank script that auto-approves cards.
(c)	**Board**	The **Data Protection Board of India** established by the Central Government under s.18.	Enforcement body where complaints are filed.
(d)	**certain legitimate uses**	The uses referred to in **s.7**.	Processing allowed **without consent** — e.g. treating an unconscious accident victim.
(e)	**Chairperson**	Chairperson of the Board.	Head of the Board.
(f)	**child**	An individual who has **not completed 18 years**.	A 16-year-old downloading a gaming app is a child → parental consent.
(g)	**Consent Manager**	A person **registered with the Board** who acts as a **single point of contact** enabling a Data Principal to **give, manage, review and withdraw** consent through an **accessible, transparent and interoperable platform**.	A dashboard showing every bank/insurer/shop holding your data with on/off toggles.
(h)	**data**	A representation of information, facts, concepts, opinions or instructions suitable for communication, interpretation or processing by humans or automated means.	A row such as "Age 29, Pune, Teacher".
(i)	**Data Fiduciary**	Any person who **alone or in conjunction with others determines the purpose and means** of processing personal data.	The bank or ride-hailing company deciding what to collect and why.
(j)	**Data Principal**	The individual to whom the personal data relates; where the individual is (i) a **child** — includes the **parents or lawful guardian**; (ii) a **person with disability** — includes her **lawful guardian** acting on her behalf.	The airline passenger or clinic patient (data owner).

cl.	Term	Meaning under the Act	Plain reading / example
(k)	**Data Processor**	Any person who processes personal data **on behalf of** a Data Fiduciary.	AWS hosting an insurer's database; a vendor printing statements.
(l)	**Data Protection Officer**	An individual appointed by a **Significant** Data Fiduciary under **s.10(2)(a)**.	India-based senior officer who answers privacy complaints.
(m)	**digital office**	An office that adopts an **online mechanism** where proceedings — from receipt of intimation, complaint, reference, directions or appeal to disposal — are conducted online.	Hearings by video conference, orders by secure e-mail/portal.
(n)	**digital personal data**	Personal data in digital form.	Data on servers, computers, phones.
(o)	**gain**	(i) a gain in **property or supply of services**, temporary or permanent; or (ii) an opportunity to earn remuneration or greater remuneration or to gain a financial advantage otherwise than by legitimate remuneration.	Employee selling a list of wealthy depositors to a marketer.
(p)	**loss**	(i) a loss in property or interruption in supply of services, temporary or permanent; or (ii) loss of opportunity to earn remuneration or greater remuneration or gain a financial advantage otherwise than by legitimate remuneration.	Damage suffered because data was mishandled. (gain/loss feed the penalty factor in s.33(2)(d))
(q)	**Member**	A Member of the Board, **includes the Chairperson**.	—
(r)	**notification**	A notification published in the **Official Gazette**; "notify/notified" construed accordingly.	—
(s)	**person**	Includes (i) an individual; (ii) a **Hindu undivided family**; (iii) a company; (iv) a firm; (v) an association of persons / body of individuals, incorporated or not; (vi) **the State**; (vii) every artificial juristic person not otherwise covered.	Any legal actor with rights and liabilities — the State can be a Data Fiduciary.
(t)	**personal data**	Any data **about an individual who is identifiable by or in relation to such data**.	Name, mobile number, biometric, address, vehicle number.
(u)	**personal data breach**	Any **unauthorised processing** or **accidental disclosure, acquisition, sharing, use, alteration, destruction or loss of access** to personal data that compromises its **confidentiality, integrity or availability**.	Misconfigured database exposing passwords. **Note:** the CIA triad of Module 4 is written into the definition.
(v)	**prescribed**	Prescribed by **rules** made under this Act.	—
(w)	**proceeding**	Any **action taken by the Board** under the Act.	—
(x)	**processing**	A **wholly or partly automated** operation or set of operations on digital personal data; includes **collection, recording, organisation, structuring, storage, adaptation, retrieval, use, alignment or combination, indexing, sharing, disclosure by transmission, dissemination or otherwise making available, restriction, erasure or destruction**. CORRECTED	Everything done with data from collection to erasure.
(y)	**she**	In relation to an individual includes the reference to such individual **irrespective of gender**.	Gender-neutral "she/her" used throughout.
(z)	**Significant Data Fiduciary**	Any Data Fiduciary or class of Data Fiduciaries **notified by the Central Government under s.10**.	Big platforms, large telecoms, major banks.

cl.	Term	Meaning under the Act	Plain reading / example
(za)	**specified purpose**	The purpose mentioned in the **notice** given by the Data Fiduciary to the Data Principal.	Address collected only to deliver a parcel.
(zb)	**State**	The State as defined in **Article 12** of the Constitution.	Governments, Parliament, legislatures, local and other authorities.

EXAM ALERT

- **Fiduciary vs Processor vs Principal** is the #1 definitions question: **Principal** = whose data; **Fiduciary** = decides purpose & **means**; **Processor** = processes **on behalf of** the Fiduciary.
- **Child = under 18** (not 16 as in the GDPR default). "Data Principal" widens to include parents/guardians.
- **"Person" includes the State**, so government bodies are Data Fiduciaries too (subject to s.7 and s.17).
- **DPO** exists only for **Significant** Data Fiduciaries by definition (s.2(l), s.10(2)(a)). HIGH-YIELD

S.3 APPLICATION OF THE ACT

- **(a) Inside India:** applies to processing of digital personal data within India where data is collected (i) in digital form, or (ii) in non-digital form and **digitised subsequently**.
- **(b) Outside India:** also applies to processing outside India if connected with **offering goods or services to Data Principals within India**.
- **(c) Does NOT apply to:** (i) personal data processed by an individual for **personal or domestic purpose**; (ii) personal data made publicly available by (A) the **Data Principal herself**, or (B) any other person under a **legal obligation** in India to make it public.

STATUTORY ILLUSTRATION

X, an individual, while blogging her views, has publicly made available her personal data on social media. The Act does not apply to that data.

Examples: a paper hospital form typed into a computer (3(a)(ii)); a US streaming service serving Indian users (3(b)); a friend's number in your phone (3(c)(i)); company directors' details on a public registry (3(c)(ii)(B)).

EXAM ALERT

The Act covers **digitised paper data** but not **purely offline** data; it has **extra-territorial reach only when offering goods/services to people in India** (not for merely *monitoring* behaviour, unlike the GDPR's Art. 3(2)(b)); and **publicly-available data** is excluded only if made public by the Principal herself or under a legal obligation. HIGH-YIELD

Chapter II — Obligations of Data Fiduciary (ss.4–10)

S.4 GROUNDS FOR PROCESSING PERSONAL DATA

- **(1)** A person may process personal data only in accordance with the Act and for a **lawful purpose**, (a) for which the Data Principal has given **consent**; or (b) for **certain legitimate uses**.
- **(2)** "Lawful purpose" = **any purpose which is not expressly forbidden by law**.

Example: processing identity records to sell stolen goods is unlawful; processing payment details to fulfil an order is lawful.

S.5 NOTICE

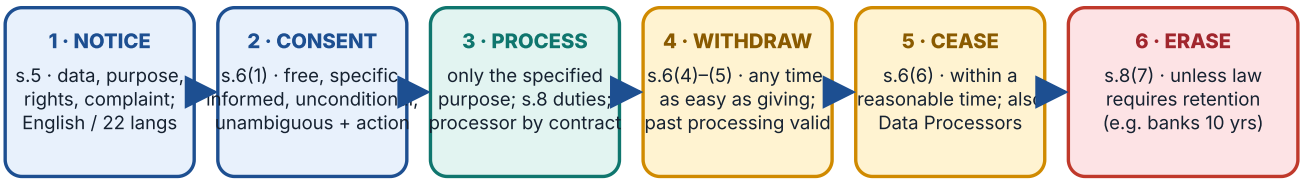
- **(1)** Every consent request under s.6 must be **accompanied or preceded by a notice** telling the Principal: (i) the **personal data and purpose**; (ii) the **manner of exercising rights** under s.6(4) (withdrawal) and s.13 (grievance); (iii) the manner of **complaining to the Board** — in the prescribed manner.
- **(2) Legacy consents (given before commencement):** (a) the Fiduciary must give notice **as soon as reasonably practicable** with the same three items; (b) it **may continue processing until the Principal withdraws** consent.
- **(3)** The Principal gets the option to read the notice in **English or any language in the Eighth Schedule** of the Constitution (22 languages).

STATUTORY ILLUSTRATIONS

(1) X opens a bank account via Y's app using live video KYC; Y must accompany or precede the request with a notice describing the data and purpose. **(2)** X consented to an online shopping app before the Act; once the Act commences Y must as soon as practicable inform X by e-mail, in-app notification or other effective method.

S.6 CONSENT — THE HEART OF CHAPTER II

1. **(1) Standard:** consent must be **free, specific, informed, unconditional and unambiguous with a clear affirmative action**, signify agreement to processing for the **specified purpose**, and be **limited to personal data necessary** for that purpose.
2. **(2) Partial invalidity:** any part of consent that infringes the Act, its rules or any other law is **invalid to the extent of the infringement**.
3. **(3) Language & contact:** every consent request in **clear and plain language**, with option to read in English or an Eighth-Schedule language, and giving **contact details of the DPO (where applicable) or another authorised person**.
4. **(4) Withdrawal:** may be withdrawn **at any time**, with ease of withdrawing **comparable to** the ease of giving consent.
5. **(5) Consequences:** borne by the Principal; withdrawal **does not affect the legality** of processing done before withdrawal.
6. **(6) Cessation:** on withdrawal the Fiduciary must, **within a reasonable time**, **cease and cause its Data Processors to cease** processing, unless processing without consent is required or authorised by this Act, its rules or any other law in force in India.
7. **(7) Consent Manager route:** the Principal may give, manage, review or withdraw consent through a Consent Manager.
8. **(8) Accountability:** the Consent Manager is **accountable to the Data Principal** and acts on her behalf, subject to prescribed obligations.
9. **(9) Registration:** every Consent Manager must be **registered with the Board** on prescribed technical, operational, financial and other conditions.
10. **(10) Burden of proof:** where consent is the basis and a question arises in a proceeding, the **Data Fiduciary must prove** that **notice was given** and **consent was given** in accordance with the Act and rules.



Burden of proof for steps 1–2 lies on the Data Fiduciary — s.6(10)

Consent lifecycle — from notice to erasure, with the section governing each step.

STATUTORY ILLUSTRATIONS TO REMEMBER (S.6)

- **Telemedicine app (6(1)):** asks consent for (i) telemedicine data and (ii) phone contacts; X agrees to both → consent is **limited to (i)**, since contacts aren't necessary.
- **Insurer (6(2)):** consent includes waiving the right to complain to the Board → that part is **invalid** (policy consent otherwise stands).
- **E-commerce (6(5)):** X withdraws after ordering and paying → Y may stop her placing *new* orders but **may not stop processing for goods already ordered and paid**.
- **Telecom (6(6)):** Z moves to app-only billing → X (telecom) must itself cease, and make processor Y cease, e-mailing bills.

MNEMONIC — CONSENT STANDARD, S.6(1)

F · S · I · U · U + A

Free · **S**pecific · **I**nformed · **U**nconditional · **U**nambiguous — **+ A**ffirmative action, limited to **necessary** data for the **specified purpose**.

EXAM ALERT HIGH-YIELD

- Withdrawal must be **as easy as giving** consent (s.6(4)) — "comparable ease", not necessarily identical.
- **Burden of proof is on the Fiduciary** (s.6(10)): it must prove notice *and* consent.
- **Consent Managers** are accountable **to the Data Principal** and must be **registered with the Board**.
- Invalid parts of consent are **severed** (s.6(2)); the rest can survive.

S.7 CERTAIN LEGITIMATE USES — PROCESSING WITHOUT CONSENT

A Data Fiduciary may process personal data for any of the following uses:

cl.	Use	What the Act says	Illustration / example
(a)	**Voluntarily provided data**	For the **specified purpose** for which the Principal **voluntarily provided** her data, **and has not indicated that she does not consent** to its use.	(I) Pharmacy customer gives her number and asks for an SMS receipt → pharmacy may use it to send the receipt. (II) A client messages a rental broker for help; after she says she no longer needs it, the broker **must cease**.

cl.	Use	What the Act says	Illustration / example
(b)	**State subsidies, benefits, services, certificates, licences, permits**	For the State/instrumentalities to provide such **prescribed** benefits where (i) she **previously consented** to such processing; or (ii) the data is in a State-maintained database/register/book/document **notified by the Central Government**; subject to standards in Central policy or law.	A pregnant woman enrols for maternity benefits with consent; Government may process her data to determine eligibility for other prescribed benefits.
(c)	**State functions; sovereignty & security**	For performance by the State of any function under **any law in force**, or in the interest of **sovereignty and integrity of India or security of the State**.	Border identity verification; passport screening.
(d)	**Legal obligation to disclose to the State**	To fulfil any obligation under law on **any person to disclose information to the State**, in accordance with that law's disclosure provisions.	Stockbroker sharing transaction logs with tax authorities.
(e)	**Judgments, decrees, orders**	For compliance with any **judgment, decree or order** under Indian law, or any judgment/order on **contractual or civil claims under law outside India**.	Bank freezing and sharing balance data under a court order.
(f)	**Medical emergency**	To respond to a medical emergency involving a **threat to life or immediate threat to health** of the Principal or any other individual.	ER doctor processing an unconscious crash victim's blood group.
(g)	**Epidemic / public-health threat**	To take measures to provide **medical treatment or health services** during an epidemic, outbreak of disease or other threat to public health.	Tracing infection chains.
(h)	**Disaster / breakdown of public order**	To ensure **safety of, or provide assistance or services to**, any individual during any **disaster** or breakdown of public order. "Disaster" = as in s.2(d) of the **Disaster Management Act, 2005**.	Relief agencies logging evacuees in a flood.
(i)	**Employment**	For **employment** or purposes related to **safeguarding the employer from loss or liability** — e.g. prevention of corporate espionage, confidentiality of trade secrets, IP and classified information — or provision of any **service or benefit sought by an employee**.	IT firm monitoring key-cards and network logs to stop IP theft.

MNEMONIC — NINE LEGITIMATE USES (A)–(I)

V · S · S · L · C · M · E · D · E

Voluntary · **S**ubsidies · **S**tate functions · **L**egal disclosure · **C**ourt orders · **M**edical emergency · **E**pidemic · **D**isaster · **E**mployment

EXAM ALERT HIGH-YIELD

s.7 is the **only** alternative to consent. Remember: (a) is conditioned on **no objection**; (b) needs a **prior-consent** or **notified-database** condition; (e) includes **foreign** civil/contractual judgments; (i) covers both employer protection *and* employee services. The related s.17 exemptions are different — they switch off most obligations; s.7 only removes the need for consent.

S.8 GENERAL OBLIGATIONS OF DATA FIDUCIARY

Sub-s.	Obligation	Content	Example
(1)	**Ultimate responsibility**	Responsible for compliance **irrespective of any agreement to the contrary or failure of a Data Principal** to perform her duties — including processing by its Data Processor.	A bank is liable even if its vendor leaked the data.
(2)	**Valid contract with processors**	May engage a Data Processor for offering goods/services to Principals **only under a valid contract**.	Grocery app signs a data-processing agreement with its dispatch vendor.
(3)	**Data quality**	Where data is **likely to be (a) used to make a decision that affects the Principal**, or **(b) disclosed to another Data Fiduciary**, ensure **completeness, accuracy and consistency**.	Credit agency verifies repayment records before scoring.
(4)	**Technical & organisational measures**	Implement **appropriate technical and organisational measures** to ensure effective observance of the Act and rules.	Role-based access, encryption, policies, training.
(5)	**Security safeguards**	Protect data in its possession or control (including processed by its Processor) by **reasonable security safeguards to prevent a personal data breach**. Penalty: up to ₹250 crore.	Firewalls, MFA, encrypted databases.
(6)	**Breach intimation**	On a personal data breach, give the **Board and each affected Data Principal** intimation in the **prescribed form and manner**. Penalty: up to ₹200 crore.	Hackers access card files → inform Board and every affected customer.
(7)	**Erasure (storage limitation)**	Unless retention is **necessary for compliance with law**: (a) **erase** data when the Principal withdraws consent **or** as soon as it is reasonable to assume the specified purpose is no longer served, **whichever is earlier**; and (b) **cause its Processor to erase** data it made available.	(I) Used-car sale concluded → marketplace stops retaining listing data. (II) Bank must retain KYC for **ten years** after account closure by banking law → may retain.
(8)	**When is purpose "no longer served"?**	Deemed so if the Principal does **not (a) approach the Fiduciary for the specified purpose and (b) exercise any of her rights** for the **prescribed time period** (different periods for different classes and purposes).	Dormant user for the prescribed period → erase.

Sub-s.	Obligation	Content	Example
(9)	**Publish contact**	Publish, as prescribed, the **business contact information of the DPO (if applicable) or a person able to answer** the Principal's questions.	Privacy contact on website footer.
(10)	**Grievance mechanism**	Establish an **effective mechanism to redress grievances** of Data Principals.	Help-desk, ticketing, escalation.
(11)	**Clarification on inactivity**	A Principal is "not having approached" the Fiduciary in any period she has **not initiated contact** — in person or by electronic/physical communication.	No login or e-mail for the prescribed period.

EXAM ALERT HIGH-YIELD

- s.8(1): **Fiduciary stays accountable** for processors; contract is mandatory (8(2)).
- The two most expensive breaches: **8(5) security safeguards — ₹250 crore**; **8(6) breach intimation — ₹200 crore**.
- Breach intimation goes to **both** the Board **and** every affected Principal.
- Erasure trigger = **earlier of** withdrawal or purpose served — but **law-required retention overrides**.

S.9 PROCESSING OF PERSONAL DATA OF CHILDREN

- **(1) Verifiable parental consent:** before processing personal data of a **child** or a **person with disability who has a lawful guardian**, obtain **verifiable consent of the parent / lawful guardian**, in the prescribed manner.
- **(2) No detrimental processing:** shall not process data in a way likely to cause **detrimental effect on the well-being of a child**.
- **(3) No tracking:** shall not undertake **tracking or behavioural monitoring of children or targeted advertising directed at children**.
- **(4) Prescribed exemptions:** sub-sections **(1) and (3)** do not apply to such **classes of Fiduciaries or purposes**, on such conditions, as prescribed.
- **(5) Verifiably safe processing:** the Central Government may, if satisfied that a Fiduciary processes children's data in a verifiably safe manner, **notify the age above which** that Fiduciary is exempt from all or any of the obligations in (1) and (3).

Example: an online game requires the parent to verify via OTP, card authorisation or government ID before opening an account for a 12-year-old; an educational app may not track a student's browsing to serve toy ads.

Penalty for breach of s.9: up to ₹200 crore.

EXAM ALERT HIGH-YIELD CORRECTED

Exemptions in s.9(4) and (5) can lift **only (1) and (3)** (consent and tracking/ads) — **never (2)**, the "no detrimental effect on well-being" rule. And s.9(5) names an age *above which* exemption applies (it does not simply "lower the threshold").

S.10 ADDITIONAL OBLIGATIONS OF SIGNIFICANT DATA FIDUCIARY (SDF)

(1) DESIGNATION — BY THE CENTRAL GOVERNMENT, BY NOTIFICATION, AFTER ASSESSING FACTORS INCLUDING:

a. volume and sensitivity of personal data processed;
b. risk to the rights of Data Principals;
c. potential impact on sovereignty and integrity of India;
d. risk to electoral democracy;
e. security of the State; and
f. public order.

(2) AN SDF SHALL:

- **(a) Appoint a Data Protection Officer** who (i) **represents** the SDF under the Act; (ii) is **based in India**; (iii) is an **individual responsible to the Board of Directors or similar governing body**; (iv) is the **point of contact for grievance redressal**.
- **(b) Appoint an independent data auditor** to carry out a data audit evaluating the SDF's compliance.
- **(c) Undertake other measures:** (i) periodic **Data Protection Impact Assessment (DPIA)** — a process comprising a description of the rights of Principals and the purpose of processing, and assessment and management of risk to those rights, plus prescribed matters; (ii) **periodic audit**; (iii) other prescribed measures.

Penalty for breach of s.10: up to ₹150 crore.

KEY TAKEAWAY — SDF IN ONE LINE

D-A-P: **D**PO (India-based, reports to the Board of Directors) · independent **A**uditor · **P**eriodic DPIA & audit. Designated by the **Central Government** (not self-declared) on volume/sensitivity, risk to Principals, sovereignty, electoral democracy, State security, public order.

Fiduciary vs Significant Data Fiduciary

	Data Fiduciary	Significant Data Fiduciary
Designation	Automatic by role	Notified by the Central Government (s.10(1))
DPO	Publish contact of DPO "if applicable" or an answering person (s.8(9))	**Mandatory** India-based DPO (s.10(2)(a))
Audit	—	Independent data auditor + periodic audit
DPIA	—	Periodic DPIA
Penalty cap for extra duties	—	₹150 crore

Chapter III — Rights and Duties of the Data Principal (ss.11–15)

S.11 **RIGHT TO ACCESS INFORMATION ABOUT PERSONAL DATA**

- **(1)** The Principal may obtain, on a request in the prescribed manner, from the Data Fiduciary **to whom she has previously given consent** (including consent under s.7(a)): **(a)** a **summary** of personal data being processed and the processing activities; **(b)** the **identities of all other Data**

Fiduciaries and Data Processors with whom the data has been shared, with a description of the data shared; **(c)** any other prescribed information. CORRECTED

- **(2) Law-enforcement carve-out:** clauses (b) and (c) do **not** apply where the Fiduciary shared data with another Data Fiduciary **authorised by law** to obtain it, on a **written request** for prevention, detection or investigation of offences or cyber incidents, or prosecution or punishment of offences.

Example: asking an app which third-party marketers received your profile — except sharing with an investigating authority.

S.12 RIGHT TO CORRECTION AND ERASURE OF PERSONAL DATA

- **(1)** Right to **correction, completion, updating and erasure** of personal data for processing to which she previously consented (including s.7(a)), per any procedure under law.
- **(2)** On request for correction/completion/updating the Fiduciary shall: **(a)** correct inaccurate or misleading data; **(b)** complete incomplete data; **(c)** update the data.
- **(3)** Erasure: request in the prescribed manner; the Fiduciary **shall erase unless retention is necessary for the specified purpose or for compliance with law**. CORRECTED

Examples: fixing a typo in an address or updating a mobile number; deleting a matrimony profile removes photos and details.

S.13 RIGHT OF GRIEVANCE REDRESSAL

- **(1)** Right to **readily available means of grievance redressal** from the Data Fiduciary **or Consent Manager** for any act or omission regarding its obligations or the exercise of her rights.
- **(2)** The Fiduciary / Consent Manager must respond within the **prescribed period**.
- **(3)** The Principal must **exhaust** this opportunity **before approaching the Board**.

S.14 RIGHT TO NOMINATE

- **(1)** Right to **nominate any other individual**, in the prescribed manner, who will exercise her rights in the event of her **death or incapacity**.
- **(2)** "Incapacity" = inability to exercise the rights due to **unsoundness of mind or infirmity of body**.

Example: naming a relative to close your online accounts after death.

S.15 DUTIES OF THE DATA PRINCIPAL

a. Comply with **all applicable laws** while exercising rights.
b. **Not impersonate** another person when providing personal data for a specified purpose.
c. **Not suppress any material information** when providing personal data for any **document, unique identifier, proof of identity or proof of address** issued by the State or its instrumentalities.
d. **Not register a false or frivolous grievance or complaint** with a Data Fiduciary or the Board.
e. **Furnish only verifiably authentic information** when exercising the right to correction or erasure.

Breach of duties: penalty up to ₹10,000 (Schedule, entry 5).

Rights at a glance

Right	Section	Against whom / how	Limits / conditions

Right	Section	Against whom / how	Limits / conditions
Access to information	11	Data Fiduciary to whom consent was given (incl. s.7(a) cases): summary, sharing identities	No disclosure of sharing with authorities for crime/cyber-incident investigation
Correction, completion, updating	12(1)–(2)	Data Fiduciary; must correct, complete, update	Only for consent-based / s.7(a) processing
Erasure	12(3)	Request in prescribed manner	Refused if retention needed for **specified purpose or law**
Grievance redressal	13	Data Fiduciary or Consent Manager first, then Board	Must **exhaust** internal remedy first
Nominate	14	Any individual, for death or incapacity	Prescribed manner
Withdraw consent	6(4)	Data Fiduciary (or via Consent Manager)	Past processing stays lawful; consequences borne by Principal

EXAM ALERT HIGH-YIELD

- The Act gives **five** Chapter-III provisions: access (11), correction & erasure (12), grievance redressal (13), nomination (14) — and **duties** (15). The Act has **no** right to data portability or to object/restrict processing (unlike the GDPR).
- **Exhaustion rule (s.13(3))** — go to the Fiduciary / Consent Manager before the Board.
- Duties are enforceable: up to **₹10,000**.

Chapter IV — Special Provisions (ss.16–17)

S.16 PROCESSING OF PERSONAL DATA OUTSIDE INDIA

- **(1)** The Central Government may, **by notification, restrict the transfer** of personal data by a Data Fiduciary for processing to **such country or territory outside India as may be notified**.
- **(2)** Nothing restricts any **other Indian law** that gives a **higher degree of protection** or restriction on transfer (e.g. RBI payment-data localisation).

Plain: transfers abroad are **permitted by default** unless the destination is notified (a "negative list"). Notifications under s.16 are laid before Parliament (s.41).

S.17(1) EXEMPTIONS — SWITCHING OFF CHAPTERS II (EXCEPT SS.8(1), 8(5)), III AND S.16

The provisions of **Chapter II, except sub-sections (1) and (5) of section 8**, **Chapter III** and **section 16** do not apply where: CORRECTED

cl.	Situation	Example
(a)	Processing is **necessary for enforcing any legal right or claim**.	Evidence gathering for a lawsuit.

cl.	Situation	Example
(b)	Processing by any **court, tribunal or other body in India entrusted by law with a judicial, quasi-judicial, regulatory or supervisory function**, where necessary for that function.	A regulator processing complaints.
(c)	In the interest of **prevention, detection, investigation or prosecution of any offence** or contravention of law in force in India.	Police investigation data.
(d)	Personal data of Data Principals **not within India** processed under a **contract with a person outside India** by a person based in India.	Bengaluru IT/BPO firm managing German hospital patients' data under an outsourcing contract.
(e)	Processing necessary for a **scheme of compromise, arrangement, merger, amalgamation, demerger or transfer of undertaking** approved by a competent court/tribunal/authority.	Due diligence in a court-sanctioned merger.
(f)	Processing to **ascertain financial information, assets and liabilities of a loan defaulter** of a financial institution (terms "default" and "financial institution" as in the Insolvency and Bankruptcy Code, 2016).	Illustration: X defaults on an instalment; bank Y may process her data to ascertain her financial position and assets/liabilities.

WHY SS.8(1) AND 8(5) SURVIVE

Even in exempt situations the Fiduciary remains **responsible for compliance** (8(1)) and must keep **reasonable security safeguards** (8(5)). The exemption removes duties like notice, consent and rights — not basic accountability and security.

S.17(2)–(5) FURTHER EXEMPTIONS

Sub-s.	Who / what	What stops applying
17(2)(a)	**Notified State instrumentalities**, in the interests of sovereignty and integrity of India, security of the State, friendly relations with foreign States, maintenance of public order, or preventing incitement to any cognizable offence relating to these; plus processing by the Central Government of data such instrumentalities furnish.	**The whole Act** does not apply.
17(2)(b)	Processing **necessary for research, archiving or statistical purposes**, if the data is **not used to take any decision specific to a Data Principal** and prescribed standards are followed.	**The whole Act** does not apply.
17(3)	**Notified Data Fiduciaries or classes** (having regard to volume and nature of data), **including startups**. "Startup" = private limited company, partnership firm or LLP incorporated in India and recognised as such under criteria notified by the relevant department. CORRECTED	Section **5** (notice), **8(3)** (data quality), **8(7)** (erasure), **10** (SDF duties) and **11** (access) do not apply.

Sub-s.	Who / what	What stops applying
17(4)	**Processing by the State** or its instrumentalities.	**8(7)** (erasure) and **12(3)** (erasure right) do not apply; and where the purpose does **not include a decision affecting the Principal**, **12(2)** (correction/completion/updating) does not apply either.
17(5)	Central Government may, **before expiry of five years from the date of commencement** of the Act, by notification declare that **any provision** shall not apply to specified Fiduciaries/classes **for the period specified**. CORRECTED	Any provision, for a specified period (window = 5 years from *commencement*, not enactment).

EXAM ALERT HIGH-YIELD

- Distinguish **17(1)** (six situations; Chapter II minus 8(1)/8(5), Chapter III, s.16 switched off) from **17(2)** (**entire Act** disapplied).
- **Startup relief 17(3):** five provisions — **5, 8(3), 8(7), 10, 11**. Mnemonic: **"Notice-Quality-Erase-SDF-Access"**.
- **State relief 17(4):** erasure only (8(7), 12(3)) + correction where no decision is made about the Principal.
- Compare with s.7: legitimate uses waive only *consent*; s.17 waives *obligations/rights*.

Chapter V — Data Protection Board of India (ss.18–26)

s.	Topic	Provision
18	**Establishment**	(1) With effect from a date notified by the Central Government, a Board called the **Data Protection Board of India** is established. (2) A **body corporate** with **perpetual succession and a common seal**; can acquire, hold and dispose of movable and immovable property, contract, and sue or be sued. (3) **Headquarters** at a place notified by the Central Government.
19	**Composition & qualifications**	(1) A **Chairperson and such number of Members as the Central Government notifies**. (2) Appointed by the Central Government in the prescribed manner. (3) Persons of **ability, integrity and standing** with special knowledge or practical experience in **data governance; administration/implementation of laws on social or consumer protection; dispute resolution; information and communication technology; digital economy; law; regulation or techno-regulation**, or any other useful field; **at least one must be an expert in law**.
20	**Salary & term**	(1) Salary, allowances and conditions as prescribed; **not varied to disadvantage after appointment**. (2) Term: **two years**, eligible for **re-appointment**.
21	**Disqualification**	(1) Disqualified if she: (a) is an **adjudged insolvent**; (b) convicted of an offence which, in the Central Government's opinion, involves **moral turpitude**; (c) has become **physically or mentally incapable**; (d) has acquired a **financial or other interest** likely to affect her functions prejudicially; (e) has **abused her position** so as to make continuance prejudicial to the public interest. (2) **No removal without an opportunity of being heard.**

s.	Topic	Provision
22	**Resignation, vacancy, cooling-off**	(1) Written notice of resignation to the Central Government; effective on the **earliest** of: the date the Government permits her to relinquish office; **three months** from receipt of notice; a **duly appointed successor** entering office; or **expiry of her term**. (2) Vacancies (resignation, removal, death or otherwise) filled by **fresh appointment**. (3) **For one year after ceasing office** neither the Chairperson nor a Member may **accept any employment** without the Government's previous approval, and she must **disclose** to the Government any later employment with a Data Fiduciary against whom proceedings were initiated by or before her. CORRECTED
23	**Proceedings of the Board**	(1) Procedure for meetings **including by digital means**, and authentication of orders, as prescribed. (2) No act or proceeding is invalid merely due to **vacancy or defect in constitution**, **defect in appointment**, or **procedural irregularity that doesn't affect the merits**. (3) If the Chairperson is absent/ill, the **senior-most Member** discharges her functions.
24	**Officers & employees**	Board may appoint officers and employees **with the previous approval of the Central Government**, on prescribed terms.
25	**Public servants**	Chairperson, Members, officers and employees are deemed **public servants** within s.21 of the **Indian Penal Code** when acting or purporting to act under the Act. (The IPC has since been replaced by the Bharatiya Nyaya Sanhita, 2023; the Act's text still reads "IPC".) ADDED
26	**Powers of Chairperson**	(a) **General superintendence** and direction on all administrative matters; (b) **authorise officers to scrutinise** any intimation, complaint, reference or correspondence; (c) **authorise individual Members or groups of Members** to perform Board functions/conduct proceedings and **allocate proceedings** among them (benches).

EXAM ALERT HIGH-YIELD

Item	Value
Term of office (s.20)	**2 years**, re-appointable
Resignation notice (s.22(1))	**3 months** (earliest of four triggers)
Cooling-off (s.22(3))	**1 year** — no employment without Government approval
Legal expert on Board (s.19(3))	**At least one** Member
Removal (s.21(2))	Only after **opportunity to be heard**
Status (s.25)	**Public servants**
Appointments & number of Members	**Central Government** (notified)

Chapter VI — Powers, Functions and Procedure of the Board (ss.27–28)

S.27 **POWERS AND FUNCTIONS OF THE BOARD**

(1) THE BOARD SHALL:

a. on receipt of a **breach intimation under s.8(6)**: direct **urgent remedial or mitigation measures**, inquire into the breach and impose penalty;

b. on a **complaint by a Data Principal** about a personal data breach, or a breach by a Data Fiduciary of its obligations or her rights, or on a **reference by the Central or a State Government** or in compliance with a **court's directions**: inquire and impose penalty;

c. on a complaint by a Principal about a **Consent Manager's** breach of its obligations: inquire and impose penalty;

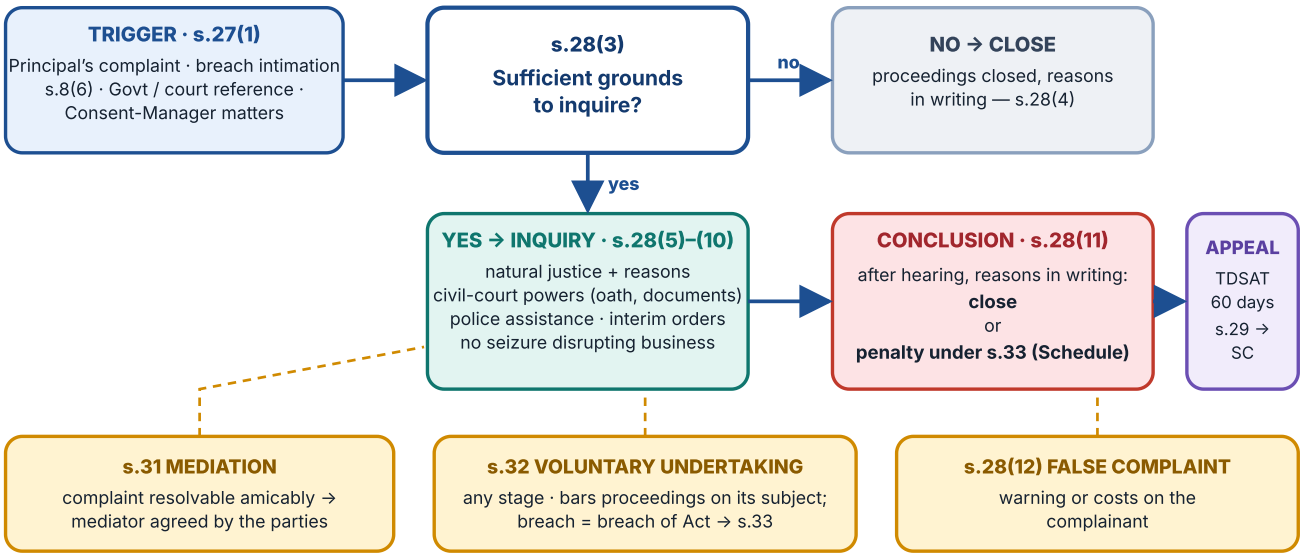
d. on intimation of breach of any **condition of registration of a Consent Manager**: inquire and impose penalty;

e. on a **reference by the Central Government** about an **intermediary's** non-compliance with s.37(2): inquire and impose penalty.

- **(2)** After **hearing** the person concerned and **recording reasons in writing**, the Board may issue directions, and the person is **bound to comply**.
- **(3)** On a representation by an affected person or a Government reference, it may **modify, suspend, withdraw or cancel** a direction, imposing conditions.

S.28 PROCEDURE TO BE FOLLOWED BY THE BOARD

1. **(1)** Functions as an **independent body** and, as far as practicable, a **digital office** — receipt of complaints and allocation, hearing and pronouncement of decisions **digital by design**; adopts prescribed **techno-legal measures**.
2. **(2)** Acts on intimations, complaints, references or directions referred to in s.27(1).
3. **(3)** Determines whether there are **sufficient grounds** to proceed with an inquiry.
4. **(4)** If insufficient — **closes proceedings** with reasons recorded in writing.
5. **(5)** If sufficient — records reasons and **inquires** into the affairs of any person to ascertain compliance.
6. **(6)** Follows the **principles of natural justice** and records reasons.
7. **(7)** Has **civil-court powers (CPC, 1908)** for: (a) summoning and enforcing attendance and examining on **oath**; (b) receiving evidence by **affidavit** and requiring discovery and production of **documents**; (c) **inspecting** data, books, documents, registers, books of account; (d) other prescribed matters.
8. **(8)** The Board or its officers **shall not prevent access to premises or take into custody any equipment or item** that may adversely affect the **day-to-day functioning** of a person.
9. **(9)** May require the services of **police or any Central/State Government officer**, who must comply.
10. **(10)** May issue **interim orders** during inquiry, for recorded reasons, **after giving an opportunity of being heard**.
11. **(11)** On completion, after hearing and with reasons in writing, **closes the proceedings or proceeds under s.33** (penalty).
12. **(12)** If a complaint appears **false or frivolous**, at any stage may issue a **warning or impose costs on the complainant**.



Life of a Board proceeding — main track (solid) and side tracks (dashed): mediation, voluntary undertaking, and action against false complaints.

EXAM ALERT HIGH-YIELD

- The Board is a **digital office** and **independent body** (s.28(1)); it has **civil-court powers** (s.28(7)) but **may not seize equipment** that disrupts day-to-day functioning (s.28(8)).
- Directions and interim orders need a **hearing** and **written reasons** (ss.27(2), 28(10)).
- **Natural justice** is mandatory (s.28(6)); false/frivolous complaints attract **warning or costs** (s.28(12)).

Chapter VII — Appeal and Alternate Dispute Resolution (ss.29–32)

S.29 APPEAL TO APPELLATE TRIBUNAL (TDSAT)

1. **(1)** Any person **aggrieved by an order or direction of the Board** may appeal to the Appellate Tribunal.
2. **(2)** File within **60 days** from receipt of the order/direction, in the prescribed form and manner, with the prescribed **fee**.
3. **(3)** The Tribunal may entertain a late appeal on **sufficient cause** for delay.
4. **(4)** After hearing the parties it may **confirm, modify or set aside** the order.
5. **(5)** Sends a copy of every order to the Board and the parties.
6. **(6)** Deal with the appeal **as expeditiously as possible**; **endeavour to dispose of it within six months** of presentation.
7. **(7)** If not disposed of in six months, **record reasons in writing**.
8. **(8)** Subject to ss.14A and 16 of the TRAI Act, 1997, follows the **prescribed procedure**.
9. **(9)** Appeals against the Tribunal's orders: **s.18 of the TRAI Act, 1997** applies (appeal to the **Supreme Court**; that section sets a 90-day window ADDED).
10. **(10)** The Tribunal functions, as far as practicable, as a **digital office** for these appeals.

S.30 ORDERS OF THE APPELLATE TRIBUNAL EXECUTABLE AS A DECREE

(1) Its order is **executable by it as a decree of a civil court**; it has all powers of a civil court for this.
(2) It may **transmit** the order to a **civil court having local jurisdiction**, which executes it as if it were

its own decree.

S.31 ALTERNATE DISPUTE RESOLUTION

If the Board thinks a complaint may be resolved by **mediation**, it may direct the parties to attempt resolution through a mediator **agreed by the parties** or as provided under any law in force in India. *Example:* an individual billing-data dispute settled by an independent mediator without full regulatory litigation.

S.32 VOLUNTARY UNDERTAKING

- **(1)** The Board may accept a voluntary undertaking about observance of the Act from **any person at any stage of a proceeding under s.28**.
- **(2)** It may include an undertaking to **take action within a time** set by the Board, **refrain** from action, and/or **publicise** the undertaking.
- **(3)** Terms may be **varied** by the Board **with the consent** of the person.
- **(4)** Acceptance is a **bar on proceedings** under the Act about the **contents** of the undertaking (except under (5)).
- **(5)** If the person **fails to adhere** to any term, it is **deemed a breach of the Act**; after a hearing, the Board may proceed under **s.33**.

Dispute-resolution ladder and time limits

Step	Forum	Time / rule
1	Data Fiduciary / Consent Manager grievance system (s.13)	Respond within prescribed period; must be **exhausted first**
2	Data Protection Board (ss.27–28)	Optional **mediation** (s.31) or **voluntary undertaking** (s.32)
3	TDSAT (s.29)	**60 days** to appeal (+ delay if sufficient cause); target disposal **6 months**
4	Supreme Court (s.29(9) → TRAI Act s.18)	On appeal from TDSAT

EXAM ALERT HIGH-YIELD

60 days (appeal) · **6 months** (target disposal; reasons if exceeded) · TDSAT order = **civil-court decree** · **civil courts barred** from Board matters (s.39) · a **voluntary undertaking bars** parallel proceedings on that matter, but **breach revives** penalties under s.33.

Chapter VIII — Penalties and Adjudication (ss.33–34)

S.33 PENALTIES

- **(1)** If the Board determines on conclusion of an inquiry that a breach of the Act or its rules is **significant**, it may, **after giving an opportunity of being heard**, impose the monetary penalty **specified in the Schedule**.
- **(2)** In fixing the amount the Board shall have regard to:
  a. the **nature, gravity and duration** of the breach;
  b. the **type and nature of the personal data** affected;
  c. the **repetitive nature** of the breach;
  d. whether the person realised a **gain** or avoided any **loss**;

e. whether the person took action to **mitigate** the effects, and its **timeliness and effectiveness**;
f. whether the penalty is **proportionate and effective**, having regard to the need to secure observance and **deter** breach; and
g. the **likely impact** of the penalty on the person.

MNEMONIC — S.33(2) FACTORS

N · T · R · G · M · P · I

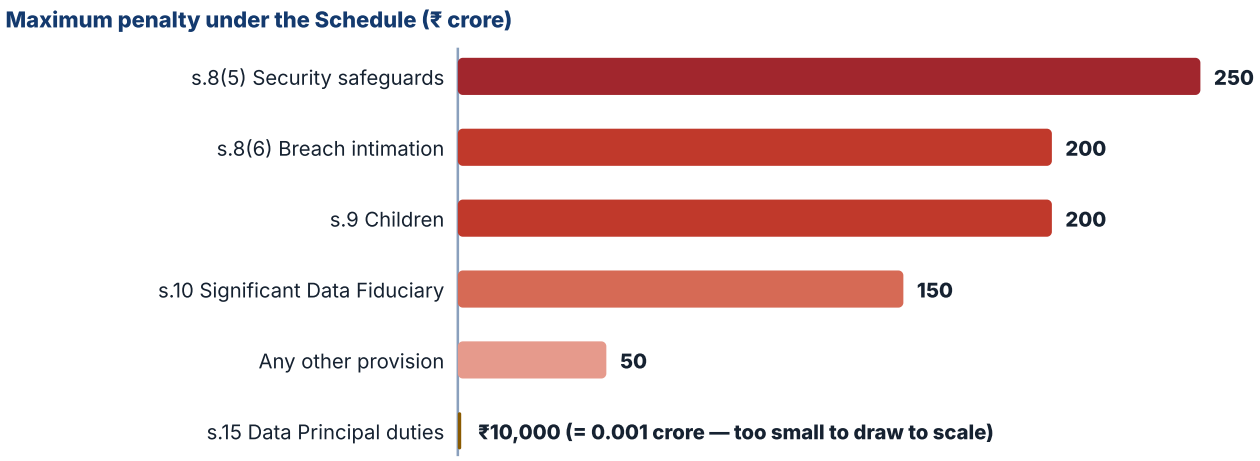
Nature/gravity/duration · **T**ype of data · **R**epetition · **G**ain/avoided loss · **M**itigation · **P**roportionality & deterrence · **I**mpact on the person

S.34 CREDITING SUMS REALISED BY WAY OF PENALTIES

All sums realised as penalties are **credited to the Consolidated Fund of India** (not to the Board, and not paid as compensation to the Principal).

The Schedule — penalties under s.33(1)

Sl.	Breach	Maximum penalty	Plain explanation & example
1	Failure to take **reasonable security safeguards** to prevent a personal data breach — s.8(5)	**₹250 crore**	No encryption / open, password-less customer database → mass theft.
2	Failure to **notify the Board and affected Data Principals** of a breach — s.8(6)	**₹200 crore**	Company conceals a major server hack.
3	Breach of **obligations relating to children** — s.9	**₹200 crore**	Video app targets behavioural ads at minors without verifiable parental consent.
4	Breach of **additional obligations of a Significant Data Fiduciary** — s.10	**₹150 crore**	Platform has no India-based DPO or skips the DPIA.
5	Breach of **duties of a Data Principal** — s.15	**₹10,000**	Forged identity documents or knowingly false, malicious complaints.
6	Breach of any term of a **voluntary undertaking** accepted by the Board — s.32	Up to the extent applicable for the breach in respect of which proceedings under s.28 were instituted	Firm promised a security upgrade in 3 months and didn't do it.
7	Breach of **any other provision** of the Act or rules	**₹50 crore**	Refusing a valid access or correction request.



Penalty ladder — drawn to scale: ₹250 crore ≫ ₹200 crore ≫ ₹150 crore ≫ ₹50 crore. The Data Principal's penalty is thousands of times smaller. (1 crore = 10 million rupees.)

EXAM ALERT HIGH-YIELD

- Order to memorise: **250 – 200 – 200 – 150 – 50 – 10,000 ↔ 8(5) – 8(6) – 9 – 10 – others – 15**. Mnemonic: **"Safe, Say, Safe-kids, Significant, Sundry, Self"** (Security, intimation notice, children, SDF, any other, Principal's duties).
- The Board may impose a penalty only if the breach is "**significant**", **after hearing**, with reasons; amounts **go to the Consolidated Fund of India**.
- Caps can be raised by notification (s.42) but **never beyond twice** the original figure.
- There is **no compensation** mechanism for Principals in the Act (s.43A IT Act was omitted by s.44(2)(a)).

Chapter IX — Miscellaneous (ss.35–44)

s.	Topic	Provision
35	**Protection of action taken in good faith**	No suit, prosecution or other legal proceeding lies against the **Central Government, the Board, its Chairperson, any Member, officer or employee** for anything done or intended to be done **in good faith** under the Act or rules.
36	**Power to call for information**	The Central Government may require the **Board and any Data Fiduciary or intermediary** to furnish such information as it may call for.
37	**Power of Central Government to issue directions (blocking)**	(1) On a **written reference from the Board** that (a) intimates **imposition of monetary penalty on a Data Fiduciary in two or more instances**, and (b) **advises, in the interests of the general public, blocking** of public access to information in a computer resource that enables the Fiduciary to carry on activity relating to offering goods or services to Principals in India — after **giving the Fiduciary an opportunity of being heard**, being satisfied it is necessary or expedient, with **reasons recorded in writing**, the Central Government (or its authorised officers) may by order **direct any Government agency or any intermediary to block** access. (2) Every **intermediary** receiving such a direction is **bound to comply**. (3) "Computer resource", "information", "intermediary" — meanings in the **Information Technology Act, 2000**. *Example:* blocking an offshore predatory loan app that repeatedly leaks users' contacts after multiple penalties.

s.	Topic	Provision
38	**Consistency with other laws**	(1) The Act is **in addition to, and not in derogation of**, any other law. (2) In a **conflict**, the **DPDP Act prevails to the extent of the conflict**.
39	**Bar of jurisdiction**	No **civil court** has jurisdiction to entertain any suit or proceeding on a matter the Board is empowered to decide; and **no injunction** shall be granted by any court or authority for any action taken or to be taken under the Act's powers.
41	**Laying of rules and certain notifications**	Every **rule** and every **notification under s.16 (cross-border) and s.42 (Schedule amendment)** is laid before **each House of Parliament** for a total of **30 days** (in one session or two or more successive sessions). If both Houses agree to a modification or to annul it, it has effect only in modified form or not at all — **without prejudice to the validity of anything previously done**.
42	**Power to amend Schedule**	(1) By notification, but **no increase of any penalty to more than twice** what was specified when the Act was originally enacted. (2) Amendments take effect as if enacted in the Act and **from the date of notification**.
43	**Power to remove difficulties**	(1) By **order published in the Gazette**, the Central Government may make provisions not inconsistent with the Act as necessary or expedient to remove a difficulty. (2) **No such order after three years** from the date of commencement. (3) Every order is **laid before each House of Parliament**.

S.40 POWER TO MAKE RULES

(1) The Central Government may, by notification and **subject to previous publication**, make rules not inconsistent with the Act. **(2)** In particular, rules may provide for the matters below:

cl.	Matter to be prescribed	Under
(a)	Manner in which the **notice** informs the Principal	5(1)
(b)	Manner of notice for **pre-commencement consents**	5(2)
(c)	**Accountability and obligations of Consent Manager**	6(8)
(d)	**Registration** of Consent Manager and conditions	6(9)
(e)	Subsidy, benefit, service, certificate, licence or permit for s.7(b)	7(b)
(f)	Form and manner of **breach intimation** to the Board	8(6)
(g)	Time period after which the **purpose is deemed no longer served**	8(8)
(h)	Manner of publishing **DPO / contact information**	8(9)
(i)	Manner of obtaining **verifiable consent** (children)	9(1)
(j)	Classes of Fiduciaries / purposes / conditions for **exemption** in children's data	9(4)
(k)	Other matters of the **DPIA** process	10(2)(c)(i)
(l)	**Other measures** an SDF shall undertake	10(2)(c)(iii)
(m)	Manner of **access request** and other information	11(1)
(n)	Manner of **erasure request**	12(3)
(o)	Period to **respond to grievances**	13(2)
(p)	Manner of **nomination**	14(1)
(q)	**Standards** for research / archiving / statistical exemption	17(2)(b)

cl.	Matter to be prescribed	Under
(r)	Manner of **appointing Chairperson and Members**	19(2)
(s)	**Salary, allowances and conditions** of service	20(1)
(t)	Manner of **authenticating** orders, directions and instruments	23(1)
(u)	**Terms of appointment** of Board officers and employees	24
(v)	**Techno-legal measures** by the Board	28(1)
(w)	Other evidential matters (civil-court powers)	28(7)(d)
(x)	**Form, manner and fee** for an appeal	29(2)
(y)	**Procedure** for dealing with an appeal	29(8)
(z)	Any other matter to be or that may be prescribed	—

S.44 AMENDMENTS TO CERTAIN ACTS

Act amended	Change made by s.44	Effect
Telecom Regulatory Authority of India Act, 1997 — 44(1)	In **s.14, clause (c)**, sub-clauses (i) and (ii) are substituted so the TDSAT's appellate jurisdiction covers: (i) the Appellate Tribunal under the IT Act, 2000; (ii) under the Airports Economic Regulatory Authority of India Act, 2008; and **(iii) the Appellate Tribunal under the Digital Personal Data Protection Act, 2023**. CORRECTED	Makes TDSAT the Appellate Tribunal for DPDP appeals.
Information Technology Act, 2000 — 44(2)	(a) **Section 43A omitted**; (b) in **s.81 proviso**, after "the Patents Act, 1970", insert "**or the Digital Personal Data Protection Act, 2023**"; (c) in s.87(2), **clause (ob) omitted**.	Ends compensation for failure to protect "sensitive personal data" under s.43A; DPDP Act placed alongside the Patents Act as outside the IT Act's overriding effect (s.81).
Right to Information Act, 2005 — 44(3)	In **s.8(1)**, clause **(j)** is substituted with: "**information which relates to personal information**;".	Personal information is exempt from RTI disclosure **without** the older public-interest balancing wording.

EXAM ALERT HIGH-YIELD

Three amended statutes: **TRAI Act** (TDSAT becomes appellate forum), **IT Act** (**s.43A omitted**, s.81 proviso, s.87(2)(ob) omitted), **RTI Act** (**s.8(1)(j)** rewritten). And three time limits: **30 days** (laying), **3 years** (removing difficulties), **twice** (cap on Schedule increases).

8.10 DPDP rapid-reference tables

Numbers to memorise

Number	Where
18 years	Child (s.2(f))
22 languages	Eighth Schedule (ss.5(3), 6(3))
10 years	Bank KYC retention illustration (s.8(7))
2 or more penalties	Before blocking reference (s.37)
2 years	Board member term (s.20)
3 months	Resignation notice (s.22)
1 year	Cooling-off (s.22(3))
60 days	Appeal to TDSAT (s.29)
6 months	Target disposal of appeal (s.29)
5 years	Window for exemption notifications (s.17(5))
3 years	Removal-of-difficulties limit (s.43)
30 days	Laying before Parliament (s.41)
2×	Max increase of any penalty (s.42)

Who acts? Government vs Board vs Rules

Actor	What
Central Government (by notification)	Commencement dates (1); designate SDF (10(1)); notify s.7(b) databases; restrict transfer abroad (16); exempt State bodies (17(2)(a)), startups (17(3)), 5-year relief (17(5)); establish Board, HQ, size (18, 19); amend Schedule (42); notify age under 9(5)
Central Government (by rules, s.40)	Notice form, consent-manager conditions, breach form, retention periods, parental-consent mechanism, DPIA details, request forms, grievance timeline, Board salaries/appointments, appeal fee & procedure
Board	Directs breach mitigation, inquires, interim orders, penalties (33), accepts undertakings (32), mediation (31), warns/costs on frivolous complainants (28(12))
TDSAT	Hears appeals; decrees executable (29–30)

Exemption map — which clause switches off what

Provision	Switched off	For whom / when
s.7 (legitimate uses)	Need for **consent** only (other duties continue)	Voluntary provision, State benefits/functions, legal disclosure, orders, emergencies, epidemics, disasters, employment
s.17(1)	Chapter II *except* 8(1), 8(5); Chapter III; s.16	Legal claims, judicial/regulatory functions, crime prevention, foreign-contract outsourcing, mergers, loan-defaulter checks
s.17(2)	**Entire Act**	Notified State instrumentalities (security etc.); research/archiving/statistics without individual decisions
s.17(3)	ss.5, 8(3), 8(7), 10, 11	Notified Fiduciaries incl. startups
s.17(4)	ss.8(7), 12(3) (and 12(2) if no decision affects the Principal)	State processing
s.17(5)	Any provision, for a notified period	Specified Fiduciaries, within 5 years of commencement
s.9(4)–(5)	s.9(1) and (3) only	Prescribed classes/purposes; verifiably safe processors above a notified age

8.11 DPDP Act vs GDPR ADDED

A frequent comparative question. Points below are standard differences between the 2023 Act and EU Regulation 2016/679; confirm emphasis with your lecturer.

Feature	DPDP Act, 2023 (India)	GDPR (EU)
Data covered	**Digital** personal data (incl. digitised paper)	Any personal data processed by automated means or in a filing system
Territorial reach	India; outside India only if **offering goods/services** to Principals in India	Also covers **monitoring behaviour** of people in the EU
Terms	Data Principal · Data Fiduciary · Data Processor	Data subject · Controller · Processor
Legal bases	**Consent** or **certain legitimate uses** (s.7) — no "legitimate interests" or contract ground	Six lawful bases incl. contract, legitimate interests
Sensitive data category	**None** — no separate "sensitive personal data"	"Special categories" (health, biometrics, beliefs…) with stricter rules
Child	Under **18**; verifiable parental consent; **no tracking / targeted ads**	Digital consent age 16 (member states may lower to 13); parental authorisation
Data-subject rights	Access, correction/erasure, grievance, **nominate**; plus **duties** of the Principal	Access, rectification, erasure, restriction, **portability**, objection, automated-decision rights; no duties
Breach notification	To the **Board and each affected Principal**, in prescribed form/manner (s.8(6))	To authority within **72 hours**; to individuals if high risk
DPO	Only **Significant Data Fiduciaries** (India-based)	Mandatory in specified cases (public bodies, large-scale monitoring/special data)
Cross-border	**Open by default**; negative list by notification (s.16)	Restricted unless adequacy / safeguards
Regulator & appeals	Data Protection Board (digital office) → TDSAT → Supreme Court	Independent supervisory authorities → national courts
Penalties	Fixed caps in Schedule — up to **₹250 crore**	Up to **€20 million or 4% of global turnover**, whichever is higher
Compensation to individuals	None in the Act (IT Act s.43A omitted)	Right to compensation (Art. 82)

8.12 Status and the DPDP Rules, 2025 ADDED

WHAT HAPPENED AFTER THE ACT (BEYOND THE ACT'S TEXT — CHECK AGAINST YOUR SYLLABUS)

- The Act (s.1(2)) is brought into force in phases by notification. The **Digital Personal Data Protection Rules, 2025** were notified by MeitY in **mid-November 2025** (reports give 13 or 14 Nov), with commencement phased over 12–18 months.
- **Immediately:** the Board-related provisions, definitions and initial rules. **After 12 months** (≈ Nov 2026): Consent Manager registration and obligations. **After 18 months** (≈ May 2027): the remaining substantive obligations on Data Fiduciaries.
- Reported features of the Rules: breach intimation "without delay" to affected Principals plus a detailed report to the Board within **72 hours**; Consent Managers must be India-incorporated companies with minimum net worth ₹2 crore; verifiable parental consent via reliable identity

information or a virtual token; fiduciaries retain data and logs for at least **one year**; SDFs conduct a DPIA and audit **every 12 months**; appeals filed digitally.

Sources: PTI report (The Week, 14 Nov 2025) and Conventus Law overview of the DPDP Rules, 2025. The exam text is the Act; treat this box as context.

MODULE 9

Rapid Revision Toolkit ADDED

Built for the last 24 hours before the exam. Everything here is a compression of Modules 1–8 — if a line feels unfamiliar, jump back using the section references. The "bridge" tables (9.3) are new synthesis, written to help with cross-module analytical questions.

9.1 One-page cheat sheet, module by module

Module	If you remember only this…
1 · Data privacy & anonymization	• Why: **leakage** (IDC: #1 threat, above malware) · **outsourcing** · **regulation** (HIPAA, FIPPA, SOX, EU directive). • Four attribute classes: **EI** (direct ID) · **QI** (identify when combined) · **SD** (secret facts) · **NSD** (harmless). Sweeney: ZIP + DOB + gender. • Anonymization pipeline: **mask EI → generalise/suppress QI → keep SD authentic**. • Privacy hides *facts*; anonymity hides *identity*. Crypto is binary, anonymization is shades of gray, tokenization = arbitrary surrogate + vault. • Five data types (multidimensional, transaction, longitudinal, graph, time series) — relational techniques fail on the last four. k-anonymity → l-diversity → t-closeness.
2 · Governance & sensitive data	• Governance = **People · Process · Technology**; "transfer of rights" metaphor; island-fortress figure. • Four pillars: **L-P-R-P** (Lineage · Policies · Reliability · Privacy & security). • Sensitive data tiers: **PII → person-related → proprietary**. GPS breadcrumbs and Facebook likes show that patterns identify. • PII discovery: regex · entropy · NLP/deep learning · toolkits (Presidio). "Shift privacy left".
3 · Privacy by Design	• Cavoukian's seven principles: **P-D-E-F-E-V-R** — Proactive · Default · Embedded · Full functionality (positive-sum) · End-to-end security · Visibility & transparency (3 parts) · Respect for user privacy (4 parts). • Default = *settings*; Embedded = *architecture*.
4 · InfoSec & cryptography	• CIA + authenticity + accountability. X.800: **attack** (2 passive + 4 active), **service** (6), **mechanism** (8). • Passive → **prevent** (encrypt); active → **detect & recover**. • Symmetric: one shared key, fast, key-distribution problem (5 ingredients). Asymmetric: key pair, slow, (6 ingredients). **Secrecy → recipient's public key; signature → sender's private key.** • Hash: fixed-size, one-way; preimage / second-preimage / collision. Signature = sign the **hash** with the private key. PKI = CA-signed X.509 certificates; 5 components.

Module	If you remember only this…
5 · Harms from loss of privacy	• Aristotle/Mill (autonomy) → Warren & Brandeis 1890 (right to be let alone) → Prosser 1960 (four torts) → FIPs 1973 → OECD 1980 → GDPR 2016. • Privacy paradox is better read as **resignation** (Annenberg 55% vs 43%). • Harm has two roots: **insecure use** (illegal/unauthorised) vs **imprecise use** (legal but inaccurate).
6 · Data-protection law	• FIPs, OECD and GDPR were built to stop *insecure* use; they leave *imprecise* use largely untouched (Recital 71 "inaccuracy" = factual error, not a poor prediction). • Right to explanation, Art. 22 and access don't audit accuracy; discrimination is banned but uniform imprecision isn't. • Notice-and-consent critique: complexity, power imbalance, bundling, false security, IoT. Medical consent discloses side-effects; data consent doesn't. • Privacy regulators vs consumer-protection agencies: should be handled in one unified model.
7 · Surveillance	• Surveillance capitalism (Zuboff). Model system: **D-I-I-O-T** — Define · Identify · Intervene · Observe outcomes · Test error rate. • Net benefit = (TP value + TN value) − (FP cost + FN cost). Breast-cancer screening shows net harm is possible. • Net-harm risks: proxy optimisation; misaligned error rates (price optimisation, addictive markets).
8 · DPDP Act, 2023	• 9 chapters · 44 sections · 1 Schedule. Digital personal data only. Notice + consent, or the nine s.7 legitimate uses. • Roles: **Principal** (whose data) · **Fiduciary** (decides purpose & means) · **Processor** (acts on behalf) · **Consent Manager** · **SDF** (notified; DPO, auditor, DPIA). • Child = under 18; no tracking / targeted ads. Rights: access, correction/erasure, grievance, nominate; duties in s.15. • Board → TDSAT (60 days) → Supreme Court. Penalties ₹250 / 200 / 200 / 150 / 50 crore / ₹10,000 — to the Consolidated Fund.

9.2 Mnemonic collection

The first ten are carried over from the modules; the last six are new (ADDED).

GOVERNANCE PILLARS · §2.3

L · P · R · P

Lineage · Policies & controls · Reliability & knowledge · Privacy & security

PRIVACY BY DESIGN · §3.2

P · D · E · F · E · V · R

Proactive · Default · Embedded · Full functionality · End-to-end · Visibility · Respect

SURVEILLANCE LOOP · §7.2

D · I · I · O · T

Define · Identify · Intervene · Observe outcomes · Test error rate

VALID CONSENT · S.6(1)

F · S · I · U · U + A

Free · Specific · Informed · Unconditional · Unambiguous + Affirmative action

LEGITIMATE USES · S.7(A)–(I)

V · S · S · L · C · M · E · D · E

Voluntary · Subsidies · State functions · Legal disclosure · Court orders · Medical emergency · Epidemic · Disaster · Employment

SIGNIFICANT DATA FIDUCIARY · S.10(2)

D · A · P

DPO · independent Auditor · Periodic DPIA & audit

STARTUP RELIEF · S.17(3)

N · Q · E · S · A

Notice (5) · Quality (8(3)) · Erasure (8(7)) · SDF (10) · Access (11)

PENALTY FACTORS · S.33(2)

N · T · R · G · M · P · I

Nature/gravity/duration · Type of data · Repetition · Gain/avoided loss · Mitigation · Proportionality · Impact on the person

SCHEDULE ORDER · S.33(1)

Safe · Say · Safe-kids · Significant · Sundry · Self

8(5) ₹250 · 8(6) ₹200 · s.9 ₹200 · s.10 ₹150 · any other ₹50 · s.15 ₹10,000

SECURITY OBJECTIVES · §4.2

C · I · A + A · A

Confidentiality · Integrity · Availability + Authenticity · Accountability

ACTIVE ATTACKS · §4.4 ADDED

M · R · M · D

Masquerade · Replay · Modification · Denial of service. (Passive = the two "peeks": contents, traffic.)

WHICH KEY? · §4.9 ADDED

Secrecy → THEIR public · Signature → MY private

Confidentiality: encrypt with the recipient's public key. Authentication/signature: use your own private key.

HASH RESISTANCE LADDER · §4.10 ADDED

h → x · x → y · any pair

Preimage: given the hash, find an input.
Second preimage: given an input, find another.
Collision: find any two.

ANONYMIZATION RECIPE · §1.4 ADDED

Mask EI · Generalise QI · Keep SD

Utility survives because the QI–SD correlation is (mostly) preserved.

RIGHTS OF THE PRINCIPAL · SS.11–14 ADDED

A · C · G · N (+ withdraw consent, + duties)

Access 11 · Correction & erasure 12 · Grievance 13 · Nominate 14 · (withdraw 6(4)) · duties 15

WHO'S WHO · S.2 ADDED

Principal owns · Fiduciary decides · Processor does

Data Principal = whose data · Data Fiduciary = purpose & means · Data Processor = on behalf of the Fiduciary.

9.3 Bridge tables — connecting modules ADDED

Exam setters love questions that make you link the theory (Modules 1–7) to the Act (Module 8). These tables are my own synthesis — they are consistent with your notes and the Act, but are not from the source text.

A · Security objective → service → attack → mechanism

Objective	Service (Table 1.1)	Typical attack it blocks	Typical mechanisms
Confidentiality	Data confidentiality	Release of message contents; traffic analysis (passive)	Encryption (cryptographic algorithms), traffic padding, routing control, access control
Integrity	Data integrity (connection-oriented / connectionless)	Data modification; replay (active)	Hash / MAC (data-integrity mechanism), digital signature
Authenticity	Authentication (peer-entity / data-origin)	Masquerade (active)	Authentication exchange, digital signature, certificates (PKI)
Availability	Availability service	Denial of service (active)	Access control, routing control, filtering/intrusion prevention
Accountability	Nonrepudiation (proof of origin / delivery); access control	Denying an action; untraceable misuse	Digital signature, notarization, audit logs

B · Hash-function requirements, side by side

Requirement	Attacker is given…	Attacker must find…	Generic work for an *n*-bit hash
Preimage resistance (one-way)	a hash value h	any y with $H(y) = h$	$\approx 2^n$
Second-preimage resistance (weak collision)	a specific input x	$y \neq x$ with $H(y) = H(x)$	$\approx 2^n$
Collision resistance (strong collision)	nothing	any pair (x, y) with $H(x) = H(y)$	$\approx 2^{n/2}$ (birthday bound)

C · Group-anonymity ladder

Model	Guarantee	Fixes the weakness of…	Still vulnerable to…
k-anonymity	each QI combination appears in ≥ k records	raw QI linking (Sweeney voter-list attack)	homogeneity and background-knowledge attacks
l-diversity	≥ l well-represented sensitive values per group	k-anonymity's homogeneity	skewed distributions; similar-value (similarity) attacks
t-closeness	group's SD distribution within distance t of the overall distribution	l-diversity's skewness	costs more utility; harder to reach

D · Theory → law bridge

Concept from Modules 1–7	DPDP hook	How they connect
Insecure use (unauthorised access, leaks)	`s.8(5)`, `s.8(6)`, Schedule 1–2	Reasonable security safeguards (₹250 cr) and breach intimation to Board + every affected Principal (₹200 cr). "Personal data breach" in `s.2(u)` literally lists confidentiality, integrity and availability.
Imprecise use (flawed algorithms, bad data)	`s.8(3)`, `s.10(2)`	Only data *quality* (completeness, accuracy, consistency) where data drives a decision about the Principal or is passed to another Fiduciary — nothing on the precision of the algorithm itself. SDFs get an auditor and DPIA (closest to the algorithm-audit idea). No Art. 22-style right on automated decisions.
Notice-and-consent critique	`s.5`, `s.6`, `s.7`	The Act tries to fix complexity (plain language; English or any Eighth-Schedule language; contact of DPO), bundling (limited to necessary data; invalid parts severed), power imbalance (burden of proof on the Fiduciary), withdrawal friction (as easy as giving) and Consent Managers. It still relies on consent as the main ground.
Privacy by Design — Default / minimisation	`s.6(1)` "limited to necessary data", `s.8(7)`	Collect only what the specified purpose needs; erase when the purpose is served.
PbD — Visibility & transparency; accountability	`s.8(1)`, `s.8(9)–(10)`, `s.5`	Ultimate responsibility, published contact, grievance mechanism, notice.
PbD — Respect for user privacy (consent, access, accuracy, redress)	`ss.6, 11, 12, 13`	Consent and withdrawal; access; correction/erasure; grievance redress — the four operational requirements of Principle 7.
Data governance — lineage, third-party contracts	`s.8(2)`, `s.8(1)`	Processors only under a valid contract; Fiduciary stays liable for them.

Concept from Modules 1–7	DPDP hook	How they connect
Data lifecycle (End-to-end security, secure disposal)	`s.8(7)–(8)`	Erasure at withdrawal or when purpose no longer served, whichever earlier; processors must erase too.
Children / vulnerable people; behavioural profiling harms	`s.9`	Verifiable parental consent; no detrimental processing; no tracking, behavioural monitoring or targeted ads for children.
Research utility vs anonymization	`s.17(2)(b)`	Research, archiving and statistics: whole Act disapplied if no decision is taken about a specific Principal and prescribed standards are followed.
Surveillance; State power	`s.7(b)–(c)`, `s.17(2)(a)`, `s.17(4)`	State processing for benefits/functions needs no consent; notified instrumentalities can be fully exempt — the net-benefit/net-harm debate of Module 7 applies to these provisions.
Regulatory accountability (not consumer burden)	`ss.18–28`, `s.33`	An independent, digital Board with civil-court powers and penalty-setting factors.
Contextual privacy; autonomy (Mill)	`s.3(c)`	No Act for personal/domestic use or data the Principal herself made public.

9.4 DPDP Act — "Which section deals with…?" finder

I need…	Go to
Short title, phased commencement	`s.1`
Definitions (Fiduciary, Principal, Processor, child, SDF, breach, processing…)	`s.2(a)–(zb)`
Scope: digital/digitised data; extra-territorial reach; exclusions (domestic, self-published)	`s.3`
Lawful purpose; consent or legitimate uses as the only grounds	`s.4`
Notice contents; legacy consents; language choice	`s.5`
Valid consent; withdrawal; Consent Manager; burden of proof	`s.6`
Processing without consent (nine uses)	`s.7`
Fiduciary's accountability; processor contract; data quality; security; breach notice; erasure; DPO contact; grievance	`s.8(1)–(10)`
Children and persons with disability under guardianship	`s.9`
Significant Data Fiduciary — designation, DPO, auditor, DPIA	`s.10`
Right to access information	`s.11`
Right to correction, completion, updating, erasure	`s.12`
Grievance redressal; exhaust internal remedy first	`s.13`
Nominate someone for death/incapacity	`s.14`
Duties of the Data Principal	`s.15`
Cross-border transfer (negative list)	`s.16`
Exemptions (legal claims, courts, crime, offshore outsourcing, mergers, defaulters; State; research; startups; 5-year relief)	`s.17(1)–(5)`

I need…	Go to
Establishing the Board; its members, term, disqualification, resignation, staff, status	`ss.18–26`
Board's powers and procedure; digital office; interim orders; frivolous complaints	`ss.27–28`
Appeal to TDSAT; execution as decree	`ss.29–30`
Mediation; voluntary undertaking	`ss.31–32`
Penalty factors; Schedule; where the money goes	`ss.33–34` + Schedule
Good-faith protection; call for information; blocking orders	`ss.35–37`
Overlap with other laws; civil-court bar	`ss.38–39`
Rule-making; laying before Parliament; amending the Schedule; removing difficulties	`ss.40–43`
Amendments to the TRAI Act, IT Act, RTI Act	`s.44`

9.5 Acronym & term glossary

Term	Expansion	One-line meaning
ACL	Access Control List	List of who may do what to a resource.
AES	Advanced Encryption Standard	NIST-approved symmetric block cipher, keys of 128/192/256 bits.
CA	Certification Authority	Trusted party that signs public-key certificates.
CIA	Confidentiality, Integrity, Availability	Foundational security triad (NIST FIPS 199).
CMVP	Cryptographic Module Validation Program	NIST scheme validating modules under FIPS 140-2.
CRL	Certificate Revocation List	List of certificates revoked before expiry; published by the CA.
DIIOT	Define · Identify · Intervene · Observe outcomes · Test error rate	Mnemonic for the five-step model surveillance system.
DoS	Denial of Service	Active attack that blocks normal use of a service.
DPDP	Digital Personal Data Protection (Act, 2023)	India's data-protection statute (Act 22 of 2023).
DPIA	Data Protection Impact Assessment	Periodic assessment of risk to Principals' rights — an SDF duty (s.10(2)(c)(i)).
DPO	Data Protection Officer	India-based individual appointed by an SDF (s.10(2)(a)).
DSS / DSA	Digital Signature Standard / Algorithm	FIPS 186-4; DSA with 2048-bit keys is one NIST-recommended option.
ECDSA	Elliptic Curve Digital Signature Algorithm	Same strength as DSA/RSA-2048 with a 224-bit key.
EI · QI · SD · NSD	Explicit identifier · Quasi-identifier · Sensitive data · Non-sensitive data	The four attribute classes of an enterprise dataset.
ENISA	EU Agency for Cybersecurity	Source of European crypto-selection guidance.
FIPs	Fair Information Practices	US HEW principles of 1973 — the ancestor of modern data-protection law.
FIPS	Federal Information Processing Standards	NIST standards, e.g., 199 (CIA), 186-4 (DSS), 140-2 (module validation).

Term	Expansion	One-line meaning
GDPR	General Data Protection Regulation (EU 2016/679)	EU regime; 4 % of turnover penalties.
HIPAA	Health Insurance Portability and Accountability Act (US)	Health-privacy law; 18 specified identifiers.
HMAC	Hash-based Message Authentication Code	MAC built from a hash and a shared secret key.
HSM	Hardware Security Module	Tamper-resistant device that stores keys.
IDC	International Data Corporation	Research firm cited for “leakage is the #1 threat”.
KDC / KMS	Key Distribution Centre / Key Management System	Third-party key generation & delivery; key-lifecycle management.
MAC	Message Authentication Code	Cryptographic checksum from message + shared secret key.
MeitY	Ministry of Electronics and Information Technology	Notified the DPDP Rules, 2025 (see 8.12).
MPC · ZKP	Secure Multiparty Computation · Zero-Knowledge Proof	Advanced crypto: joint computation without revealing inputs; prove a fact without revealing data.
NIST	National Institute of Standards and Technology	US standards body behind most recommendations in Module 4.
OECD	Organisation for Economic Co-operation and Development	1980 Privacy Guidelines.
PbD	Privacy by Design	Cavoukian’s seven foundational principles.
PCI DSS	Payment Card Industry Data Security Standard	Context for card-number tokenization.
PII	Personally Identifiable Information	Attributes that point (nearly) directly to an individual.
PKI	Public-Key Infrastructure	Policies, hardware, software and procedures that issue and manage certificates.
PRNG	Pseudorandom Number Generator	Keyless algorithm producing random-looking sequences.
RA	Registration Authority	Optional PKI component that verifies identity for the CA.
RSA	Rivest–Shamir–Adleman	Public-key algorithm; 2048-bit recommended; broken by Shor’s algorithm on a quantum computer.
SDF	Significant Data Fiduciary	Fiduciary notified by the Central Government under s.10.
SHA-2 / SHA-3	Secure Hash Algorithms	NIST hash families; digests of 224–512 bits.
TDSAT	Telecom Disputes Settlement and Appellate Tribunal	Appellate Tribunal for DPDP appeals.
TLS	Transport Layer Security	Protocol securing web traffic (peer-entity authentication, key exchange).
TRAI	Telecom Regulatory Authority of India	TRAI Act, 1997 created TDSAT; s.44(1) of the DPDP Act amended it.
X.509 · X.800	ITU-T standards	Certificate format · OSI security architecture (attacks, services, mechanisms).

9.6 Quick-fire number & fact drill

Cover the right-hand column and test yourself. (For the DPDP numbers see also the table in 8.10.)

Prompt	Answer
Sweeney: which three attributes?	ZIP + date of birth + gender (≈ 87 %)
HIPAA fields treated as PII	18
Attribute classes of a dataset	4 — EI, QI, SD, NSD
Protection methods in 1.5	3 — cryptography, anonymization, tokenization
Data types in 1.9	5
Governance pillars	4
PbD principles	7 (6 → 3 parts; 7 → 4 parts)
Challenges of information security	10
X.800 concepts	3 — attack, mechanism, service
Passive / active attack types	2 / 4
Security services / mechanisms	6 / 8
Ingredients: symmetric / asymmetric	5 / 6
Hash requirements	7
Brute force — average work	half the key space
Collision vs preimage work (n-bit)	$2^{n/2}$ vs 2^n
AES key sizes	128 / 192 / 256 bits
Digest lengths (SHA-2/3)	224–512 bits
Signature options (NIST)	DSA-2048 · RSA-2048 · ECDSA-224
FIPS 140-2 assurance levels	4
PKI components / requirements	5 / 4

Prompt	Answer
Warren & Brandeis	1890, Harvard Law Review
Prosser	1960 — four privacy torts
US HEW Fair Information Practices	1973
OECD guidelines	1980
GDPR	2016 (as given in your notes)
Facebook before the FTC	2010 — contextual privacy
Annenberg: against profiling vs sharing for discounts	55 % vs 43 %
Deloitte: tailored services vs public benefit	≈ 2 : 1
Melanoma apps audit	3 of 4 missed ≥ 30 % of melanomas
Surveillance loop steps	5 (D-I-I-O-T)
DPDP: chapters · sections · schedule	9 · 44 · 1
Definitions in s.2	28, (a)–(zb)
Child under the Act	< 18 years
Legitimate uses (s.7)	9, (a)–(i)
Schedule entries	7 (₹10,000 – ₹250 crore)
s.17(3) startup relief — sections	5, 8(3), 8(7), 10, 11
Board term · resignation notice · cooling-off	2 yrs · 3 months · 1 yr
TDSAT appeal · target disposal	60 days · 6 months
Parliament laying · difficulties order · penalty-cap increase	30 days · 3 yrs · ≤ 2×

9.7 Diagrams you should be able to draw from memory

Diagram	Where	What the examiner wants to see
Stakeholders of data privacy	1.2	Customer → company (production DB) → business-operations staff; anonymizer → anonymized DB → analyst, tester, adversary; government above.
Anonymization pipeline	1.4	D = [EI | QI | SD] → drop EI, T(QI), keep SD → D′.
Privacy–utility curve	1.6	Falling curve; crypto at the two extremes; shaded optimum between.
Governance island fortress	2.2	Tower, sentinel, PbD island, regulatory moat, privacy-technology bridge, users.
Seven PbD principles	3.2	Seven labelled boxes/petals in order.
CIA + authenticity + accountability	4.2	Five bubbles around "information & network security".
Passive vs active attack topologies	4.4	Client–server panels: normal, eavesdrop, man-in-the-middle, direct impersonation, replay.
Symmetric cryptosystem	4.8	X → encrypt (K) → Y → decrypt (K) → X; key source with a secure channel; adversary on the wire.
Asymmetric cryptosystem (a) and (b)	4.9	(a) Bob's public key encrypts, Bob's private key decrypts; (b) Alice's private key encrypts, her public key decrypts.
Hash + signature flow	4.10–4.11	Message → H → digest → S (private key) → signature; verify with V (public key).
PKI scenario	4.13	Bob → RA/CA → certificate; CA → repository (certificates, CRL); Alice (relying party) fetches and verifies.
Privacy timeline	5.1	Antiquity → 1890 → 1960 → 1973 → 1980 → 2010 → 2016 → 2023.
Insecure vs imprecise use	5.3	Root-cause tree with two branches and examples.
Model surveillance loop	7.2	Define → Identify → Intervene (intervention phase) → Observe outcomes → Test error rate (monitoring phase) → back to Define.
DPDP actors & consent lifecycle	8.0, 8.2	Principal ⇄ Fiduciary (± Consent Manager); Processor; Board; TDSAT; notice → consent → processing → withdrawal → cessation → erasure.
Board proceeding & appeal ladder	8.6–8.7	Complaint → grounds? → inquiry → penalty or closure; side tracks (mediation, undertaking); TDSAT → Supreme Court.

9.8 How to answer — command words and templates ADDED

Command word	What it asks for	Template
Define / State	A precise definition in the textbook's words.	1 sentence definition → 1 example. No more.
List / Name	The items only.	Numbered list, in the order of the source; add the section number for DPDP.
Explain / Describe	How or why — with detail.	Point → reason → example, repeated per point; add a labelled sketch where possible.

Command word	What it asks for	Template
Distinguish / Compare	Differences on the *same* criteria.	A small table with 4–6 rows; a one-line conclusion underneath.
Illustrate / Give an example	A concrete instance.	Use the standard ones: Sweeney voter list, GPS breadcrumbs, card token, melanoma apps, bank loan ML, Act illustrations.
Discuss / Evaluate / Critically examine	Both sides, then a judgement.	Thesis → arguments for (with evidence) → arguments against / limits → conclusion that takes a position.
Apply (case study)	Facts → rule → result.	Identify the actor (Principal / Fiduciary / Processor) → section → whether an exemption applies → consequence and penalty.

EXAM ALERT · TIME AND MARKS

- Rough rule: about **1.5 minutes per mark**. Two-mark questions need a definition plus an example, not a paragraph.
- For any DPDP answer, **cite the section number** (e.g., "s.8(5), up to ₹250 crore"). It is the quickest way to signal precision.
- For cross-module analytical questions, use the **bridge tables in 9.3** to link a theory point to a section of the Act.
- If a question mentions "Corrected" or "Added" topics, mention both versions if you are unsure what your lecturer used (e.g., Sweeney 83 % in your notes vs 87 % in the standard citation).

9.9 Delhi University syllabus map & gap-fillers ADDED

The University of Delhi's **Data Privacy** paper (Department of Computer Science GE/DSE; unique paper code **2343010010**) has four units. The table shows where each unit lives in these notes. Topics that your source notes did *not* cover — but that appear in the DU syllabus or in the DU previous-year paper (Module 10, group P) — are filled in section 9.10.

DU unit	Syllabus topics	Where in these notes
Unit 1 · Introduction to data privacy & privacy regulations	Definition of data privacy · historical context · types of sensitive data · privacy laws and regulations	1.3–1.4 (privacy vs anonymity), 5.1 (history), 2.4 & 1.3 (sensitive data), Modules 6 and 8 (law). **Gap-fillers:** 9.10-A laws at a glance (HIPAA, COPPA…), 9.10-B GDPR principles, 9.10-C what counts as PII.
Unit 2 · Attacks, cryptography & data protection	Types of attacks / data breaches · impact of breaches · introduction to cryptography · symmetric & asymmetric encryption · hashing & digital signatures	Module 4 (all), 5.3 (harms). **Gap-fillers:** 9.10-D classical ciphers (Caesar, rail fence), 9.10-E breach vectors and impact.
Unit 3 · Data collection, use & reuse	Harms from collection, use and reuse · introduction to anonymization · anonymization techniques · challenges	1.4–1.10, 5.3, 6.4. **Gap-fill:** 9.10-F how privacy is preserved for time-series, longitudinal, graph (and transaction) data.

DU unit	Syllabus topics	Where in these notes
Unit 4 · Ethical considerations	Privacy & surveillance · ethics of data collection and use · bias and discrimination in data analysis	Module 7, 6.2, 7.4. **Gap-fillers:** 9.10-G ethics of collection and use, 9.10-H bias and discrimination, 9.10-I PbD vs privacy engineering.

EXAM ALERT · DU PAPER PATTERN

The one DU end-semester paper I could find (B.Sc. (H) Computer Science, DSE, Sem VII; 3 hours, 90 marks) has **Section A** — one compulsory Question 1 made of about ten short parts — and **Section B** — attempt any four of six long questions. It mixes definitions, DPDP case-study application, a cipher calculation, an EI/QI/SD table exercise, a surveillance-model diagram and ethics. Only one paper was available to me, so treat the pattern as indicative, not guaranteed. See Module 10, group P for every question with a model answer.

9.10 Gap-fillers for the DU syllabus

A · Privacy laws at a glance (HIPAA, COPPA and friends)

Law	Where	What it does — remember this
HIPAA	USA · 1996	**H**ealth **I**nsurance **P**ortability and **A**ccountability **A**ct. Protects individually identifiable *health information* (PHI) held by health plans, healthcare providers and clearing-houses ("covered entities") and their business associates. Three rules: **Privacy Rule** (who may use/disclose PHI), **Security Rule** (safeguards for electronic PHI), **Breach Notification Rule**. De-identification by removing the **18 listed identifiers** (the "18 fields" in 1.6).
COPPA	USA · enacted 1998, in force 2000	**C**hildren's **O**nline **P**rivacy **P**rotection **A**ct. Protects the personal information of **children under 13** collected online. Operators of child-directed sites/apps (or with actual knowledge they collect from under-13s) must post a clear notice and obtain **verifiable parental consent** before collecting; enforced by the US Federal Trade Commission. *Contrast:* India's DPDP Act treats everyone under **18** as a child (s.2(f)) and bans tracking and targeted ads (s.9).
GDPR	EU · adopted 2016, applies from 25 May 2018	General Data Protection Regulation. Seven principles (9.10-B), six lawful bases, data-subject rights, 72-hour breach notice, fines up to €20 m or 4 % of global turnover.
FIPPA	Canada (provincial)	Freedom of Information and Protection of Privacy Act — public-sector privacy law; cited in 1.1 as one reason enterprises worry about compliance.
Sarbanes–Oxley (SOX)	USA · 2002	Corporate-governance law demanding reliable financial reporting and internal controls over the records behind it (so integrity and retention of data matter).
DPDP Act, 2023	India	Module 8. Digital personal data; consent or s.7 legitimate uses; Board → TDSAT; penalties to ₹250 crore.

Law	Where	What it does — remember this
IT Act, 2000	India	Cyber-law and e-signature statute. Its s.43A (compensation for failure to protect sensitive personal data) was **omitted** by DPDP s.44(2)(a).

B · GDPR — the major principles (Art. 5)

#	Principle	Meaning	Example
1	**Lawfulness, fairness and transparency**	Process only on a lawful basis (consent, contract, legal obligation, vital interests, public task, legitimate interests); do not mislead or cause unjustified harm; tell people clearly what is happening.	Clear privacy notice before an app collects location.
2	**Purpose limitation**	Collect for specified, explicit, legitimate purposes; no incompatible further use.	Delivery address not reused for ad profiling.
3	**Data minimisation**	Adequate, relevant and limited to what is necessary.	No date of birth for a newsletter sign-up.
4	**Accuracy**	Keep data accurate and up to date; erase or correct inaccuracies without delay.	Bank corrects a wrong repayment record.
5	**Storage limitation**	Keep identifiable data no longer than necessary.	Delete CVs of rejected candidates after the hiring window.
6	**Integrity and confidentiality**	Appropriate security against unauthorised processing, loss or damage.	Encryption and access control on a patient database.
7	**Accountability (Art. 5(2))**	The controller must be able to *demonstrate* compliance.	Records of processing, DPIAs, audits.

TRANSPARENCY · CONSENT · FAIR PROCESSING (GDPR) — TIE-BACK TO 6.3

Transparency = concise, plain-language notice of what is collected, why, who gets it, for how long and how to complain. **Consent** = freely given, specific, informed and unambiguous, and as easy to withdraw as to give. **Fair processing** = handling data in ways people would reasonably expect, without deception or unjustified adverse effects. Your Module 6.3 critique applies: notices are long and bundled, so "informed" consent is often a fiction and risks are shifted onto the consumer.

C · What counts as PII? (passport number, cookies, ...)

Test: can the item, alone or when combined with other information that is linked or linkable to a person, identify, single out or trace that individual? (Module 1's EI vs QI split, and the Act's definition of personal data in `s.2(t)`: data about an individual who is identifiable by or in relation to such data.)

Item	PII?	Reasoning
Passport number	**Yes** — explicit identifier	Unique, government-issued, directly tied to one person; also on the Tier-1 list in 2.4.

Item	PII?	Reasoning
Browser cookie	**Usually yes** — online identifier / quasi-identifier	A persistent or third-party cookie holds a unique ID that tracks one browser over time and can be linked to a profile, account or device; under GDPR (Recital 30) online identifiers such as cookie IDs can be personal data. A plain session cookie holding only cart contents, with no identifier, does not by itself identify anyone. Say both, then conclude "yes when linkable".
IP address	Often yes	Online identifier; identifies a connection, and the ISP can link it to a subscriber.
Email address	Yes	Usually contains or maps to a name; Tier 1 in 2.4.
Date of birth, gender, ZIP	Quasi-identifiers	Harmless alone; identifying together (Sweeney).
Account balance, diagnosis	Sensitive data (SD)	Not an identifier, but harmful when tied to an identity.
GPS trail, shopping history	Person-related data	Tier 2 in 2.4 — the pattern identifies.

D · Classical ciphers — Caesar and rail fence ADDED

Questions may ask you to *encrypt a phrase by hand*. Both ciphers below are **insecure today** but are the standard exam exercises. State your assumption (here: spaces are dropped and letters are upper-case).

Caesar cipher (substitution)

Rule: shift every letter forward by *k*; wrap Z → A. C = (P + k) mod 26. Decrypt: P = (C − k) mod 26.

```
                k = 6
Plain  : ABCDEFGHIJKLMNOPQRSTUVWXYZ
Cipher : GHIJKLMNOPQRSTUVWXYZABCDEF
```

"Data Privacy", k = 6
D→J · A→G · T→Z · A→G | P→V · R→X · I→O · V→B · A→G · C→I · Y→E

Ciphertext: JGZG VXOBGIE (JGZGVXOBGIE without the space).

Breaking it: (1) brute force — only 25 non-trivial keys, try all and read the one that makes sense; (2) frequency analysis — the commonest cipher letter probably stands for E (then T, A, O…), which gives the shift.

Rail-fence cipher (transposition)

Rule: write the plaintext in a zig-zag across *n* rails, then read the rails row by row. Letters keep their identity but change position.

"Data Privacy" (DATAPRIVACY), 4 rails

D						I				
	A				R		V			
		T		P				A		Y
			A						C	

Rail 1 = DI · Rail 2 = ARV · Rail 3 = TPAY · Rail 4 = AC

Ciphertext: DIARVTPAYAC

Extra practice (from a related DU paper, "I AM A STUDENT OF UNIVERSITY OF DELHI"): Caesar with key 5 → **N FR F XYZIJSY TK ZSNAJWXNYD TK IJQMN**; rail fence with 3 rails (spaces dropped) → **ISEFVIFH AATDNOUIESTODLI MUTNRYE** read as **ISEFVIFHAATDNOUIESTODLIMUTNRYE** (rail 1, 2, 3 in turn). Both were machine-checked.

EXAM ALERT

Caesar = **substitution** (letters replaced, positions unchanged); rail fence = **transposition** (positions rearranged, letters unchanged). Show the working (mapping row or zig-zag grid) — method marks are usually awarded even if one letter slips. Link to Module 4: these are symmetric ciphers (one shared "key": the shift or the number of rails), and their tiny key-space is why modern ciphers use 128–256-bit keys (brute force needs on average half the key space).

E · Data breaches — common vectors and impact

Vector	How it leaks data	Typical defence
Phishing / social engineering	User is tricked into giving credentials or opening a malicious file.	Multi-factor authentication, training.
Malware / ransomware	Steals or encrypts data; logic bombs trigger on a date or condition.	Patching, anti-malware, offline backups.
Insider (careless or malicious)	Authorised staff misuse, mis-send or copy data.	Least privilege, audit logs, data-loss prevention.
SQL injection / web flaws	Malicious SQL typed into an input field runs against the back-end database.	Parameterised queries, input validation.
Misconfiguration	Public cloud bucket, password-less database, unencrypted drive left exposed (cf. the hospital example in 5.3).	Secure defaults (PbD Principle 2), configuration audits.
Lost or stolen devices	Unencrypted laptop, phone or backup is taken.	Full-disk encryption, remote wipe.
Weak or reused passwords	Credential stuffing and guessing.	Salted hashing, MFA, password managers.
Third-party / processor failure	Vendor or outsourcing partner is breached.	Contracts and oversight — DPDP s.8(1)–(2).
Eavesdropping / man-in-the-middle	Passive reading or active interception on the network (4.4).	TLS / encryption, PKI certificates.
Denial of service	Floods or oversized packets (e.g., a "ping of death" — IP packets larger than 65,535 bytes) block availability.	Filtering, rate-limiting, redundancy.

Impact of a breach or of wrongful profiling

On	Harm
Individuals	Identity theft and fraud; direct financial loss; denial of credit, insurance or jobs; higher prices through price discrimination; harassment or stalking; distress and loss of control (see 5.2–5.3).
Organisations	Investigation, notification and remediation costs; **regulatory penalties** (DPDP up to ₹250 crore for missing safeguards, ₹200 crore for not notifying; GDPR 4 % of turnover); lawsuits; lost customers and revenue; reputational damage; operational downtime.
Society	Falling trust in digital services; chilling effect on speech and participation; national-security risk if critical or government data leaks.

THREE ECONOMIC HARMS (TYPICAL 3-MARK ANSWER)

(1) **Direct financial loss** — fraud and identity theft after a leak. (2) **Unfair economic outcomes** — loans, insurance or jobs refused, or prices raised, because of wrong or biased profiles. (3) **Costs to the organisation** — fines, compensation claims, remediation and lost business.

F · How privacy is preserved for each non-tabular data type

Data type	Techniques used	What must survive
Time series	Mask the identifiers (name, address); add calibrated noise (perturbation) or smooth/aggregate the curves; group similar series so each hides among ≥ k others; differential-privacy noise on released statistics.	Mean, variance, trend, seasonality, autocorrelation, range queries (1.9.5).
Longitudinal	Mask EI; generalise QI (age bands, ZIP prefix); suppress rare events; **shift dates by a random per-person offset** so intervals stay intact; group patients with similar sequences (k-anonymity over the whole sequence).	Temporal order and clinical trends; time gaps between events (1.9.3).
Graph	Replacing names by labels is **not enough**; perturb edges (add / delete / swap); **k-degree anonymity** (each node shares its degree with ≥ k–1 others); merge nodes into super-nodes (generalisation); differential privacy for graph statistics.	Centrality, path lengths, degree distribution, cluster structure (1.9.4).
Transaction	Generalise or suppress items (e.g., "glucose monitor" → "health device"); k^m-anonymity (any m known items match ≥ k baskets).	Association patterns and frequent item-sets (1.9.2).

Always close such an answer with the trade-off: the more edges, values or items you distort to hide identities, the more the analytical properties change (privacy–utility, 1.6).

G · Ethics of data collection and use

Ethical consideration	What goes wrong	How to address it in practice
1 · Informed consent & autonomy	People cannot foresee downstream uses; consent is bundled or buried (6.3).	Plain-language notice; granular, withdrawable consent; no dark patterns. `ss.5–6`
2 · Purpose limitation & minimisation	"Collect everything just in case"; function creep and reuse beyond the original purpose.	Collect only what the specified purpose needs; set retention limits; delete when done. `s.6(1)`, `s.8(7)`
3 · Fairness & non-discrimination	Biased data and proxies lead to unequal treatment (see H below).	Bias audits, representative data, human review of high-impact decisions, monitoring of error rates by group (7.2 step 5).
4 · Transparency & accountability	Opaque algorithms; nobody answerable when harm occurs.	Document data lineage (2.3); name a responsible person (DPO); DPIA and independent audit for high-risk processing. `s.8(1)`, `s.10`

Ethical consideration	What goes wrong	How to address it in practice
5 · Privacy, security & confidentiality	Breaches, re-identification of "anonymous" data.	Encryption, access control, anonymization or tokenization; breach response plan. `s.8(5)–(6)`
6 · Context & vulnerable groups	Data shared in one context used in another; children and patients are most exposed.	Respect contextual norms (2.5, 5.1); verifiable parental consent and no tracking of children. `s.9`
7 · Beneficence vs harm	Benefits (security, health, convenience) are weighed against net harm (7.3–7.4).	Measure outcomes, not intentions: test error rates and compute net benefit before and during deployment.

Privacy and surveillance — the ethical balance. *For:* crime prevention, fraud detection, public health, personalised services. *Against:* chilling effect on behaviour, loss of autonomy, function creep, discrimination through error-prone profiling, and the power imbalance between watcher and watched (Module 7).

H · Bias and discrimination in data analysis

Source of bias	How it arises
Historical bias	Training data records past discrimination, so the model learns to repeat it.
Sampling / representation bias	Some groups are under-represented, so the model is less accurate for them.
Measurement & label bias	The proxy measured (arrests, clicks) is not the true target; human labels carry prejudice.
Proxy variables	Neutral-looking fields (ZIP code, device type, name) stand in for protected traits.
Algorithmic / aggregation bias	One model fits the majority pattern and fails minority sub-groups.
Feedback loops	Decisions change the future data (more policing → more recorded crime → more policing).

- **Harms:** unfair loan refusals, hiring filters, differential insurance pricing, policing and welfare errors, filter bubbles (5.3, 7.4).
- **Mitigation:** diverse and audited data; drop or test proxies; fairness metrics such as *demographic parity* (equal positive-decision rates across groups) and *equalised odds* (equal true- and false-positive rates); human oversight; explanation and appeal routes; continuous monitoring (the DIIOT loop's steps 4–5); DPIA for high-risk systems.
- **Legal link:** GDPR bans discrimination on protected characteristics but not uniform imprecision (6.2); the DPDP Act has only data-quality duties, `s.8(3)`, and no right against automated decisions, so ethics fills the gap.
- Commonly cited cases: a recruiting tool that learned to down-rank women's CVs; recidivism-scoring software with unequal error rates across racial groups — good one-line examples.

I · Privacy by Design vs privacy engineering

Aspect	Privacy by Design (PbD)	Privacy engineering
Nature	A philosophy / framework: seven foundational principles (Cavoukian).	A discipline: turning privacy goals into concrete requirements, designs and controls.
Answers	Why and what — "be proactive, default to privacy, embed it…".	How — data-flow mapping, threat modelling, privacy requirements, testing.
Typical tools	Policy, culture, defaults, transparency, positive-sum thinking.	Minimised schemas, pseudonymization / tokenization, encryption, access control, differential privacy, retention automation, DPIA.
Output	Principles and commitments.	Architectures, code, configurations and audit evidence.
Relationship	PbD sets the objectives; privacy engineering delivers them. Principles without engineering stay slogans; engineering without principles becomes ad-hoc patching.	

MODULE 10 · QUESTION BANK

Expected Exam Questions with Model Answers

This bank has **116 questions** in eight groups. Click a question to open its model answer; the toolbar at the top of the page expands or collapses everything, and the PDF prints with every answer open. Mark values are *indicative* (about 1.5 minutes per mark), except in group P where they are copied from the DU paper wherever the scan was legible.

Group	What it contains	Use it for
P	**Delhi University previous-year paper** — Data Privacy (B.Sc. (H) Computer Science, DSE, Sem VII)	Real exam style; solve under timed conditions first
R	Related DU paper — Information Security & Cyber Laws (GE)	Extra cryptography / attack practice
A	Direct questions — define, state, list (2–3 marks)	Quick recall of definitions and numbers
B	Short-answer questions (5 marks)	Explain / distinguish / describe
C	Analytical long answers (10 marks)	Discuss / critically evaluate; cross-module links
D	DPDP case studies and application	Facts → section → consequence
E	True / false — spot the error	Trap-proofing
F	Numerical, matching and fill-in drills	Calculation and memory

Group P · Delhi University previous-year paper (Data Privacy)

HIGH-YIELD ADDED

ABOUT THIS PAPER

Paper: Data Privacy · B.Sc. (Hons.) Computer Science · DSE · NEP-UGCF · Semester VII · unique paper code 2343010010 · 3 hours · 90 marks. **Instructions:** two sections; Section A (Question 1, about ten short parts) is compulsory; attempt any four of the six questions in Section B (Q2–Q7); all parts of a question together.

How these questions were obtained and how to read them. I could find *one* DU Data Privacy end-semester paper online (hosted by a DU college library as a scanned PDF); the DU Examination Branch's own question-paper portal could not be searched from here. The scan's text was partly garbled, so the questions below are **paraphrased**, part letters are approximate, and marks are quoted only where they were legible. The session (month/year) is not printed on the extract. If your lecturer gave you more papers, send them and I will add them.

Sources: Ramanujan College Library paper — library.ramanujancollege.ac.in/media/question_papers/.../B._Sc._H_Computer_Science_-_Data_Privacy_Semester_7th.pdf · DU Dept. of Computer Science syllabus — cs.du.ac.in/uploads/syllabus/NEP/pdfs/GE/Data_Privacy.pdf · Indraprastha College course plan (paper code) — ipcollege.ac.in/uploads/work-plan/WP_BA(P)_Sem_V_DP_VP_docx.pdf

Section A — Question 1 (compulsory, short parts)

Q1 **Define a denial-of-service (DoS) attack. Is it an active or a passive attack? Justify.** ***(DU Q1 · 3 marks)*** DU · SEC A –

MODEL ANSWER

Definition. A DoS attack prevents or inhibits the normal use or management of communications, servers or facilities — for example, flooding a web service with millions of dummy connection requests per second (§4.4).

Active. Passive attacks only observe (release of contents, traffic analysis) and change nothing. A DoS actively disrupts the system and damages *availability*. Like all active attacks it is detectable, so the defence is **detection and rapid recovery** (plus filtering and redundancy), not just prevention.

Q2 **Which sections of the DPDP Act are violated if an organisation collects personal data without explicit consent? Explain briefly.** ***(DU Q1 · 3 marks)*** DU · SEC A –

MODEL ANSWER

- `s.4(1)` — personal data may be processed only for a lawful purpose and either with the Principal's consent or for a s.7 "certain legitimate use". Neither exists here.
- `s.6(1)` — consent must be free, specific, informed, unconditional and unambiguous, with a clear affirmative action, limited to data necessary for the specified purpose.
- `s.5` — every consent request must be accompanied or preceded by a notice (data, purpose, how to withdraw and complain).
- `s.6(10)` — the Fiduciary bears the burden of proving that notice and consent were given.

Consequence: the Board may inquire and penalise (`ss.27, 33`); breaches of these provisions fall under "any other provision" — up to **₹50 crore** (Schedule entry 7); if the data subject is a child, s.9 applies and the cap is ₹200 crore.

Q3 **Distinguish between imprecise use and insecure use of data.** ***(DU Q1)*** DU · SEC A –

MODEL ANSWER

	Insecure use	Imprecise use
Meaning	Unauthorised, illegal or accidental access, loss or theft of personal data.	Lawful, authorised processing that still produces wrong, damaging or misleading results (bad algorithm, poor data).
Harm	Fraud, identity theft, leaks.	Unfair loan refusal, wrong diagnosis, discrimination, nuisance ads.
Example	Hospital leaves an unencrypted drive of records online.	A bank's legal credit-scoring model misclassifies a creditworthy borrower.
Law's coverage	Well covered (security, breach rules).	Largely uncovered by FIPs/GDPR/DPDP (§5.3, §6.2).

Q4 Explain how digital signatures provide authenticity, integrity and non-repudiation. *(DU Q1 · 3 marks)* DU · SEC A –

MODEL ANSWER

Mechanism (§4.11). The sender hashes the message and feeds the digest plus the **private key** into the signing algorithm; the recipient re-hashes the received message and checks the signature with the sender's **public key**.

- **Authenticity** — only the holder of the private key can produce a signature that verifies; a CA-signed certificate binds the public key to the real identity.
- **Integrity** — change a single bit and the recomputed hash no longer matches, so verification fails.
- **Non-repudiation** — the private key is exclusively the signer's, and anyone can verify with the public key, so the signer cannot credibly deny signing.

Q5 Why must a cryptographic hash function be collision-resistant? How does it support security? *(DU Q1)* DU · SEC A –

MODEL ANSWER

Collision resistance means it is infeasible to find any two different inputs $x \neq y$ with H(x) = H(y). Signatures and integrity checks sign or compare the **hash**, not the whole message. If an attacker could craft two messages with one hash, they could get a harmless message signed and then substitute the malicious one — the signature would still verify. Because the attacker chooses both inputs, a collision is the easiest property to attack (birthday bound $\approx 2^{n/2}$ work versus 2^n for a preimage), which is why digests of 224–512 bits (SHA-2/SHA-3) are recommended (§4.10, §4.12, bridge table 9.3-B).

Q6 List three economic harms that can arise from data leaks or incorrect data profiling. *(DU Q1)* DU · SEC A –

MODEL ANSWER

1. **Direct financial loss** — fraud, account takeover and identity theft after a leak.
2. **Unfair economic outcomes** — loans, insurance or jobs refused, or higher prices charged (algorithmic price discrimination), because of wrong or biased profiles (§5.3).
3. **Costs to the organisation** — fines (DPDP up to ₹250 crore), compensation claims, remediation and lost customers (§9.10-E).

Q7 Expand HIPAA and COPPA and briefly explain each. *(DU Q1)* DU · SEC A –

MODEL ANSWER

HIPAA — Health Insurance Portability and Accountability Act (USA, 1996). Protects identifiable health information held by health plans, providers and clearing-houses; Privacy, Security and Breach Notification Rules; de-identification by removing 18 listed identifiers.

COPPA — Children's Online Privacy Protection Act (USA, 1998; in force 2000). Protects children **under 13** online: operators must give notice and obtain verifiable parental consent before collecting their personal data; enforced by the FTC (§9.10-A).

Q8 Explain transparency, consent and fair processing under the GDPR. *(DU Q1)* DU · SEC A –

MODEL ANSWER

Transparency — plain-language information on what is collected, why, who receives it, how long it is kept and how to complain. **Consent** — freely given, specific, informed, unambiguous, and as easy to withdraw as to give. **Fair processing** — using data in ways people reasonably expect, without deception or unjustified adverse effects. Together they form the "notice-and-consent" model; critics note that long, bundled notices make the consent weak, loading risk on consumers and creating a false sense of security (§6.3, §9.10-B).

Q9 "Privacy and anonymity are two sides of the same coin." Justify or refute. *(DU Q1 · 3 marks)* DU · SEC A –

MODEL ANSWER

Largely yes — but they are not the same side. Both aim to stop an adversary from linking a *person* to a *sensitive fact*. **Privacy** hides the sensitive facts while identity may be visible (balances and card numbers masked — Table 1.5). **Anonymity** hides the identity while the facts stay visible and useful (patient records for research — Table 1.4).

Each alone is insufficient: masked balances next to a visible name still reveal who the customer is; hidden names next to intact quasi-identifiers can be re-linked (Sweeney: ZIP + DOB + gender). They differ in columns protected (SD vs EI/QI) and in techniques (masking/tokenization vs generalisation/k-anonymity). Good protection needs both (§1.4).

Section B — long questions (attempt any four of six)

Q10 (Q2a) Explain the CIA triad and how authenticity and accountability complement it. *(DU Q2)* — DU · SEC B — –

MODEL ANSWER

Objective	Meaning	Example
Confidentiality	No disclosure to unauthorised parties	Encrypting card data at checkout
Integrity	Data and systems altered only in an authorised way	A $50 transfer cannot become $5,000 in transit
Availability	Authorised users get timely access	Hospital database reachable 24/7
Authenticity (extra)	Users, messages and sources are genuine and verifiable	Two-factor login
Accountability (extra)	Every action is traceable to one actor — supports non-repudiation, forensics and legal action	Audit log: "Admin_Bob changed permissions at 10:14"

How they complement CIA: the triad says *what* must be protected; authenticity confirms *who* is acting or sending, and accountability ensures *every action can be attributed*, so that violations deter, can be investigated and prosecuted (§4.2, bridge table 9.3-A).

Q11 (Q2b) Explain the major principles of the GDPR. *(DU Q2)* — DU · SEC B — –

MODEL ANSWER

Article 5 lists seven: **(1)** lawfulness, fairness and transparency; **(2)** purpose limitation; **(3)** data minimisation; **(4)** accuracy; **(5)** storage limitation; **(6)** integrity and confidentiality; **(7)** accountability. Give one line and one example for each (table in §9.10-B). Add the six lawful bases (consent, contract, legal obligation, vital interests, public task, legitimate interests), the data-subject rights (access, rectification, erasure, restriction, portability, objection, automated-decision rights) and fines up to €20 m or 4 % of global turnover to round off a 5–6 mark answer. Mention the gap discussed in Module 6: the principles police *insecure* use more than *imprecise* use.

Q12 (Q3a — fitness app) A fitness app stores users' heart-rate and exercise-location data in plain text in a cloud database. A team member accidentally publishes a snapshot of the dataset to a public repository. The company waits three months, citing reputational concerns, before informing affected users and the Data Protection Board. Identify the DPDP Act sections that are violated or applicable, describe each and explain why. *(DU Q3 · 7 marks for the part)*

DU · SEC B · CASE –

MODEL ANSWER

Provision	Why it applies
`s.2(u)`	Accidental public disclosure is a **personal data breach**: it compromises confidentiality (and the data is digital personal data, s.3).
`s.8(5)`	Plain-text storage and a lax release process show no **reasonable security safeguards** (no encryption, access control or secret scanning). Penalty up to **₹250 crore** (Schedule 1).
`s.8(6)`	On a breach the Fiduciary must inform the **Board and each affected Principal** in the prescribed form and manner. A three-month delay for reputational reasons is no excuse. Penalty up to **₹200 crore** (Schedule 2). ADDED Under the 2025 Rules, Principals are told without delay and the Board gets a detailed report within 72 hours (§8.12).
`s.8(1)`, `s.8(4)`	The Fiduciary remains responsible for the acts of its employees and any cloud Processor, and must adopt appropriate technical and organisational measures (code review, access control, training).
`s.8(2)`	If the cloud host is a Processor, a valid contract is required.
`ss.27–28, 33`	The Board will direct urgent remedial measures, inquire and, if the breach is significant, penalise after a hearing, weighing: nature, gravity and duration (three-month delay), type of data (health/location), repetition, gain or avoided loss, mitigation, proportionality and impact.
`s.10` (if notified)	If the app is a Significant Data Fiduciary: DPO, independent audit and periodic DPIA — up to ₹150 crore for breach.

Note: the Act has no separate "sensitive data" class, so health and location data are treated as ordinary personal data — but the Board must consider "type and nature of data" when fixing the penalty. There is no compensation route for users in the Act (IT Act s.43A was omitted).

Q13 **(Q3a — smart toy) A smart-toy maker collects children's voice recordings to improve speech recognition. Its privacy policy does not mention voice recording and parental consent was not obtained. The recordings are used to train a commercial speech model sold to advertisers. Apply the DPDP Act. *(DU Q3)***

DU · SEC B · CASE –

MODEL ANSWER

1. **Who is a child?** Under 18 (`s.2(f)`); the toy's users clearly qualify, so s.9 applies.
2. `s.9(1)` — **verifiable parental consent** is mandatory before processing a child's data; none was obtained.
3. `s.9(3)` — no tracking, behavioural monitoring or **targeted advertising directed at children**; selling a model trained on children's voices to advertisers is exactly the mischief targeted. `s.9(2)` — no processing that is likely to harm a child's well-being.
4. `s.5` — the notice failed to state the data (voice recordings) and purpose, so the consent request was not valid.
5. `s.6(1)` and `s.4` — consent must be specific, informed and limited to data necessary for the **specified purpose**; "improving recognition" does not cover commercial sale. The Fiduciary carries the burden of proof (`s.6(10)`).
6. **Penalty:** s.9 breaches — up to **₹200 crore** (Schedule 3); notice/consent breaches — up to ₹50 crore (entry 7).

Exam tip: the s.9(4)/(5) exemptions can lift only s.9(1) and (3), never s.9(2), and only for prescribed classes or notified "verifiably safe" processors — none applies on these facts.

Q14 **(Q3b) Define Personally Identifiable Information (PII). Does a passport number qualify? Do browser cookies? *(DU Q3)***

DU · SEC B –

MODEL ANSWER

PII is information that identifies, or can be used to distinguish or trace, a specific individual, alone or combined with other linked or linkable information (name, SSN, biometrics, IP/email addresses, ID cards — Tier 1 in §2.4). The DPDP Act's counterpart is "personal data": data about an individual who is identifiable by or in relation to such data (`s.2(t)`).

- **Passport number — yes.** Unique and government-issued: an explicit identifier.
- **Browser cookies — usually yes.** A persistent or third-party cookie carries a unique ID that tracks a browser over time and can be linked to a profile or account (GDPR Recital 30 treats online identifiers such as cookie IDs as personal data). A bare session cookie with no identifier does not identify anyone alone. Conclusion: personal data **when linkable to an individual** (§9.10-C).

Q15 **(Q3/Q4) How is privacy preserved for time-series, longitudinal and graph data? *(DU Sec B)*** DU · SEC B –

MODEL ANSWER

- **Time series** — mask identifiers; add calibrated noise or smooth/aggregate; group similar series (k-anonymity); keep mean, variance, trend, seasonality and range queries.
- **Longitudinal** — mask EI, generalise QI, suppress rare events, shift dates by a random per-person offset to keep intervals, group similar sequences; keep temporal order and clinical trends.
- **Graph** — relabelling nodes is not enough; perturb edges, apply k-degree anonymity, merge nodes into super-nodes; keep centrality and path-length structure.

Close with the trade-off: each distortion that hides identity also changes analytical properties (§1.6, §9.10-F).

Q16 **(Q4a) Explain (i) generalization, (ii) suppression and (iii) k-anonymity as anonymization techniques, with examples. *(DU Q4)*** DU · SEC B –

MODEL ANSWER

- **Generalization** — replace a precise value by a broader one: age 34 → 30–39; ZIP 46001 → 460**; DOB → age range.
- **Suppression** — remove a value or record altogether (e.g., drop a unique outlier or replace a ZIP by *). Costs data and may bias results.
- **k-anonymity** — every combination of quasi-identifier values appears in at least k records, so each person hides among ≥ k−1 others. Example: raw rows (46001, F, 34, Cancer), (46001, F, 38, Flu), (46005, M, 29, Asthma), (46011, M, 31, Asthma). Generalise ZIP → 460** and age → 20–39 and the table becomes 2-anonymous. **Weakness:** both males have Asthma, so the sensitive value is still revealed (homogeneity attack) — hence l-diversity and t-closeness (§1.10).

Q17 **(Q4b) A bank keeps two related tables (customer and account). Analyse how they can be linked, which attributes are EI/QI/SD, and how they should be anonymised. *(DU Q4 — the scan cut off the table details)***

DU · SEC B · TABLE –

MODEL ANSWER

The extract of this sub-part was cut off after the sentence introducing the tables, so here is the standard method with the textbook tables (Tables 1.1–1.3).

1. **Classify.** Customer table: ID, first name → EI; DOB, gender, address, ZIP, phone → QI. Account table: account number, type, balance, credit limit → SD.
2. **Link.** The shared customer ID joins the tables into one logical dataset D = [EI | QI | SD] (Table 1.3), so a harmless demographic table becomes a confidential financial profile.
3. **Anonymise.** D′ = T(D): drop EI, generalise/suppress QI (DOB → age band, ZIP → prefix), keep SD authentic so the QI–SD correlation survives.
4. **Check.** Test for unique QI combinations (k-anonymity), homogeneous SD groups (l-diversity) and utility loss (statistical distance between Q and Q′).

Q18 **(Q4c) Compare symmetric and asymmetric encryption; and compare privacy by design with privacy engineering. *(DU Q4)***

DU · SEC B –

MODEL ANSWER

	Symmetric	Asymmetric
Keys	One shared secret key	Key pair: public (open) + private (secret)
Speed	Fast — bulk data (AES)	Slow — small payloads (session keys, hashes)
Key distribution	Hard: secret must be shared safely first	Easier: publish the public key (trust via PKI)
Gives	Confidentiality (and MAC integrity)	Confidentiality, signatures, key exchange
Which key?	Same key both ways	Secrecy → recipient's public key; signature → sender's private key

PbD vs privacy engineering: PbD is the philosophy (seven principles: proactive, default, embedded…); privacy engineering is the discipline that implements it with data-flow mapping, threat modelling, minimised schemas, pseudonymization, encryption, differential privacy and DPIAs. PbD sets the "why/what", engineering delivers the "how" (§9.10-I).

Q19 **(Q5a) Encrypt "Data Privacy" using (i) a Caesar cipher with shift 6 and (ii) a rail-fence cipher with 4 rails. *(DU Q5)*** DU · SEC B · CALC –

MODEL ANSWER

Assumption: upper-case, spaces dropped.

(i) Caesar, k = 6 (C = (P + 6) mod 26): D→J, A→G, T→Z, A→G, P→V, R→X, I→O, V→B, A→G, C→I, Y→E. **Ciphertext: JGZGVXOBGIE** (JGZG VXOBGIE with the word break).

(ii) Rail fence, 4 rails: zig-zag positions give Rail 1 = D, I; Rail 2 = A, R, V; Rail 3 = T, P, A, Y; Rail 4 = A, C. **Ciphertext: DIARVTPAYAC**.

D						I				
	A				R		V			
		T		P				A		Y
			A						C	

Caesar is a substitution cipher (25 possible keys, broken by brute force or frequency analysis); rail fence is a transposition cipher. Both were machine-checked (§9.10-D).

Q20 **(Q5b) Explain cryptographic hash functions and their role in digital signatures and message integrity. *(DU Q5)*** DU · SEC B –

MODEL ANSWER

What: H maps a message of any length to a fixed-length digest h = H(x); it is many-to-one and easy to compute. **Requirements:** variable input size, fixed output size, efficiency, preimage resistance (one-way), second-preimage resistance, collision resistance, pseudorandomness (avalanche).

Message integrity: the sender sends M with H(M) protected by a shared key (encrypted digest or HMAC); the receiver recomputes the hash and compares — any alteration changes the digest; timestamps/sequence numbers add replay protection (§4.10(a)).

Digital signature: hash M, sign the digest with the private key, send both; the verifier re-hashes and validates with the public key — giving origin authentication, integrity and non-repudiation. Signing the short hash rather than the message is what makes signatures efficient (§4.11).

Q21 (Q6) Describe the model surveillance system with a diagram. A bank has a Customer table (Name, Age, Phone number, Address) and an Accounts table (Account balance, Loan status, ATM usage). (i) Classify the customer attributes as EI or QI. (ii) Which account attributes are sensitive data? (iii) Why is combining QI with SD a serious privacy threat? (iv) Distinguish EI from QI. *(DU Q6)*

DU · SEC B · TABLE + DIAGRAM –

MODEL ANSWER

Diagram / description (draw the loop of §7.2).

1. **Define** (define / re-define signature) — e.g., "likelihood of loan default" found from historical attributes.
2. **Identify** members with the relevant attributes — cluster customers into segments such as "high-risk borrower".
3. **Intervene** with the target group — refuse or price-up loans, send offers (intervention phase).
4. **Observe outcomes** — compare treated customers with non-members/control group (monitoring phase).
5. **Test error rate** — sensitivity and specificity, cost of false positives and negatives → net benefit; feed back into Define.

(i) EI: Name. **QI:** Age, Address, Phone number (the textbook's Table 1.1 lists phone as a QI; if the number is unique and public, many practitioners treat it as an EI — say so). **(ii) SD:** Account balance, loan status, ATM usage (ATM usage also reveals location and habits).

(iii) QIs are harmless alone but jointly can single out a person (Sweeney: ZIP + DOB + gender ≈ 87 %). An adversary can join them with a public list (voter roll) to re-identify the record, and then the linked SD — balance, loan status — is exposed; confidential facts become attached to a named individual, enabling fraud, discrimination or blackmail. **(iv)** EI identify directly and unambiguously (name, SSN, ID); QI identify only in combination and need linkage.

Q22 (Q7a) Describe three harms that arise from improper data collection and how each can be prevented. *(DU Q7 · 4 marks)* DU · SEC B –

MODEL ANSWER

Harm	Prevention
Privacy violation and fraud — over-collected or insecurely stored data is leaked and used for identity theft.	Data minimisation, encryption/tokenization, access control, breach plan (`s.8(5)–(6)`).
Unfair or discriminatory decisions — inaccurate or biased data produces wrong credit, hiring or pricing outcomes.	Data-quality checks, bias audits, human review (`s.8(3)`, §9.10-H).
Loss of autonomy and trust — hidden collection, tracking or reuse without informed consent.	Clear notice, specific consent, purpose limitation, withdrawal (`ss.5–6`), special care for children (`s.9`).

Q23 (Q7b) Discuss four ethical considerations in data collection and use and how to address them in practice. *(DU Q7 · 8 marks)* DU · SEC B · 8 MARKS –

MODEL ANSWER

Pick four from §9.10-G and give **issue → practice → example → law** for each (2 marks each):

1. **Informed consent and autonomy** — people cannot foresee uses of bundled consents. *Practice:* plain-language, granular, withdrawable consent. *Law:* DPDP ss.5–6.
2. **Purpose limitation and minimisation** — function creep. *Practice:* collect only what the stated purpose needs; set retention limits. *Law:* s.6(1), s.8(7).
3. **Fairness and non-discrimination** — biased data and proxies. *Practice:* bias audits, representative data, monitored error rates, human review.
4. **Transparency and accountability** — opaque algorithms. *Practice:* documented lineage, DPO, DPIA, independent audit. *Law:* s.8(1), s.10.

Alternatives: security/confidentiality (s.8(5)), respect for context and vulnerable groups (s.9), beneficence vs harm (net benefit, §7.3). Open with one sentence defining "ethics of data use = what we *should* do beyond what we legally *must* do".

Group R · Related DU paper — Information Security & Cyber Laws (GE, Sem IV) ADDED

A neighbouring DU Computer Science GE paper (unique paper code 32345402; 3 hours, 75 marks) that overlaps heavily with Unit 2. Questions are paraphrased from a scanned copy; use them as extra practice for cryptography and attacks.

Q24 Define cryptography, cryptanalysis and cryptology. *(3 marks)* DU GE · SEC A –

MODEL ANSWER

Cryptography — principles, means and methods for transforming data to hide its meaning and protect it from unauthorised use or undetected change (designing ciphers). **Cryptanalysis** — the study of breaking ciphers: recovering plaintext or keys without being given the key. **Cryptology** — the umbrella science covering both.

Q25 Name the three goals of data security. *(3 marks)* DU GE · SEC A –

MODEL ANSWER

Confidentiality, integrity, availability (the CIA triad), with authenticity and accountability as the two further objectives (§4.2).

Q26 What is a passive attack? To defend against it, should you prefer prevention or detection? Why? *(4 marks)* DU GE · SEC A –

MODEL ANSWER

A passive attack eavesdrops on or monitors transmissions to gain information without altering anything — release of message contents and traffic analysis. Because nothing is changed, neither party notices, so **detection is practically impossible**; the effort goes into **prevention**, mainly encryption (and traffic padding against traffic analysis). Active attacks are the reverse: prevention is impractical on every link, so detection and recovery are emphasised (§4.4).

Q27 Identify: (i) the attack that pings a target with IP packets larger than 65,535 bytes; (ii) malicious code attached to an application that fires on a logical condition or date; (iii) the attack that feeds crafted input to an application so that malicious SQL runs on the back-end database. *(3 marks)* DU GE · SEC A –

MODEL ANSWER

(i) **Ping of death** — an oversized-packet denial-of-service attack. (ii) **Logic bomb**. (iii) **SQL injection** (defence: parameterised queries and input validation) (§9.10-E).

Q28 Define "digital signature" under the IT Act (as amended in 2008) with an example. *(2 marks)* DU GE · SEC A –

MODEL ANSWER

Under s.2(1)(p) of the IT Act, a digital signature is the **authentication of an electronic record by a subscriber by means of an electronic method or procedure under section 3**; s.3 requires an asymmetric crypto system and a hash function — the record is hashed and the hash is signed with the subscriber's private key and verified with the public key. *Example:* a company director e-files returns with a digital signature certificate token. ADDED This is outside your source notes; check wording against your lecturer's slides.

Q29 Encrypt "I AM A STUDENT OF UNIVERSITY OF DELHI" with (a) a Caesar cipher, key 5, and (b) a rail-fence cipher, 3 rails. *(5 + 5 marks)* DU GE · SEC B · CALC –

MODEL ANSWER

(a) Shift every letter by 5, keeping word breaks: **N FR F XYZIJSY TK ZSNAJWXNYD TK IJQMN**. To *break* a Caesar cipher: try all 25 shifts, or use frequency analysis.

(b) Drop spaces, zig-zag over 3 rails and read the rows: Rail 1 = ISEFVIFH, Rail 2 = AATDNOUIESTODLI, Rail 3 = MUTNRYE → **ISEFVIFHAATDNOUIESTODLIMUTNRYE**. (Different conventions about spaces give different strings — state yours.)

Q30 What is the difference between public-key and private-key encryption? *(4 marks)* DU GE · SEC B –

MODEL ANSWER

Private-key (symmetric) encryption uses one shared secret key — fast, but the key must be distributed securely. Public-key (asymmetric) encryption uses a key pair: encrypt with the recipient's public key for confidentiality, or sign with your private key for authentication — slower, but it removes the need to share a secret in advance (table in §4.9).

Group A · Direct questions — define, state, list HIGH-YIELD

Q31 Define explicit identifiers, quasi-identifiers, sensitive data and non-sensitive data, with one example each. 3 MARKS · M1 –

MODEL ANSWER

- **EI** — fields that pinpoint a record owner directly: name, SSN, customer ID.
- **QI** — public/demographic attributes that identify a person only when linked: date of birth, gender, ZIP code.
- **SD** — critical private facts that must not leak: account balance, credit limit, diagnosis, salary.
- **NSD** — contextual information that poses no privacy risk: administrative flags, system counters.

Q32 Differentiate between data masking and de-identification in the anonymization pipeline. — 2 MARKS · M1 —

MODEL ANSWER

Data masking removes or scrambles **explicit identifiers** (names, SSNs) so they are dropped from D′. **De-identification** modifies **quasi-identifiers** by generalisation and suppression (exact DOB → age range). Sensitive data are left authentic, so analytic value is preserved ($D' = [T(D_{QI}) \mid D_{SD}]$).

Q33 What is tokenization? How does it differ from encryption? — 3 MARKS · M1 —

MODEL ANSWER

Tokenization replaces a sensitive value with a non-sensitive surrogate (token) that keeps the original format and length — e.g., card 4111 2222 3333 4444 → 9876 5432 1098 7654; the real value sits in a secured vault. **Difference:** a token has *no mathematical relationship* to the original (no key can reverse it — only a vault lookup), whereas ciphertext is derived from the plaintext with an algorithm and key and is reversible with that key; ciphertext usually breaks the format, tokens keep it, so legacy systems work unchanged.

Q34 State the three main reasons why data privacy matters to enterprises. — 3 MARKS · M1 —

MODEL ANSWER

Leakage (IDC ranks data leakage as the number-one threat, ahead of malware); **outsourcing exposure** (offshore testing, development and BPO); **regulatory compliance** (HIPAA, FIPPA, Sarbanes–Oxley, EU data-protection directive) with fines, lawsuits and reputational loss for non-compliance.

Q35 Define data governance and name its core triad. — 2 MARKS · M2 —

MODEL ANSWER

Data governance is the overarching framework that defines how an organisation manages, protects, enhances and disposes of data across its lifecycle. Core triad: **People · Process · Technology**. Metaphor: customers "transfer rights" over their data to the organisation, which assumes a custodial obligation (§2.1).

Q36 Name the three tiers of sensitive data with an example of each. — 3 MARKS · M2 —

MODEL ANSWER

1. PII — name, SSN, biometrics, IP/email. **2. Person-related data** — GPS breadcrumbs, shopping history, search queries; harmless singly but identifying as a pattern. **3. Proprietary and confidential business data** — trade algorithms, merger records, internal benchmarks.

Q37 Name the seven foundational principles of Privacy by Design and its originator. — 3 MARKS · M3 —

MODEL ANSWER

Originator: Dr Ann Cavoukian (Information and Privacy Commissioner of Ontario). **P-D-E-F-E-V-R:** (1) Proactive not reactive; preventative not remedial; (2) Privacy as the default; (3) Privacy embedded into design; (4) Full functionality — positive-sum, not zero-sum; (5) End-to-end security — lifecycle protection; (6) Visibility and transparency; (7) Respect for user privacy.

Q38 Distinguish a threat from an attack, with an example. — 2 MARKS · M4 —

MODEL ANSWER

A **threat** is a potential circumstance or event that can harm assets (sensitive backups on an unpatched server). An **attack** is an actual malicious attempt to collect, disrupt, deny, degrade or destroy resources (an intruder exploiting that server to download the backups).

Q39 Name the passive and active attacks classified under X.800. — 3 MARKS · M4 —

MODEL ANSWER

Passive (2): release of message contents; traffic analysis. **Active (4):** masquerade; replay; modification of messages; denial of service.

Q40 List the six security services and the one-line purpose of each. — 3 MARKS · M4 —

MODEL ANSWER

1. **Authentication** — establish identity before access.
2. **Access control** — allow or deny use of resources.
3. **Data confidentiality** — only intended persons can read.
4. **Data integrity** — only authorised, appropriate modification.
5. **Nonrepudiation** — a person cannot deny an action.
6. **Availability** — systems ready and performing when needed.

Q41 What is a public-key certificate? Name the five components of a PKI. — 3 MARKS · M4 —

MODEL ANSWER

A digital document (standard X.509) that identifies an entity, holds that entity's public key, and is signed by a trusted Certification Authority with the CA's private key — so anyone can verify it with the CA's public key. **PKI components:** end entity · certification authority (CA) · registration authority (RA, optional identity checker) · repository (stores certificates and CRLs) · relying party.

Q42 Define the “privacy paradox”. 2 MARKS · M5 –

MODEL ANSWER

People claim high concern for privacy in surveys yet readily adopt services, apps and loyalty cards that need extensive personal data (Annenberg: 55 % opposed predictive profiling but 43 % of the same people shared grocery history for discounts). Better read as **resignation** under take-it-or-leave-it terms than as hypocrisy.

Q43 Define surveillance capitalism and list the five steps of the model surveillance system. 3 MARKS · M7 –

MODEL ANSWER

Zuboff: gathering behavioural data, segmenting populations, predicting actions and tailoring offerings to maximise monetisation. Steps (**D-I-I-O-T**): Define the signature → Identify members → Intervene → Observe outcomes (with a control group) → Test error rate (sensitivity, specificity, cost of errors), feeding back into Define.

Q44 Under the DPDP Act define Data Principal, Data Fiduciary, Data Processor and Consent Manager. 4 MARKS · M8 · S.2 –

MODEL ANSWER

- **Data Principal** (`s.2(j)`) — the individual to whom the data relates; for a child includes parents/lawful guardian; for a person with disability includes her lawful guardian.
- **Data Fiduciary** (`s.2(i)`) — any person who alone or with others determines the purpose and means of processing.
- **Data Processor** (`s.2(k)`) — any person who processes personal data on behalf of a Fiduciary.
- **Consent Manager** (`s.2(g)`) — a person registered with the Board who is the Principal’s single point of contact to give, manage, review and withdraw consent through an accessible, transparent, interoperable platform.

Q45 What is a Significant Data Fiduciary? Who designates it and what additional obligations does it have? 4 MARKS · M8 · S.10 –

MODEL ANSWER

A Data Fiduciary or class notified by the **Central Government** (`s.10(1)`) after considering volume and sensitivity of data, risk to Principals’ rights, sovereignty and integrity of India, risk to electoral democracy, State security and public order. Obligations (`s.10(2)`, **D-A-P**): appoint an **India-based Data Protection Officer** responsible to the board of directors; appoint an **independent data auditor**; undertake periodic **DPIA**, periodic audit and other prescribed measures. Breach: up to ₹150 crore.

Q46 What is the maximum penalty for failure to take reasonable security safeguards? List the other Schedule entries. 3 MARKS · M8 · SCHEDULE –

MODEL ANSWER

₹250 crore — s.8(5). Others: failure to notify a breach (s.8(6)) ₹200 crore; children's obligations (s.9) ₹200 crore; additional SDF obligations (s.10) ₹150 crore; breach of a Principal's duties (s.15) ₹10,000; breach of a voluntary undertaking (s.32) up to the extent applicable to the original breach; any other provision ₹50 crore. Imposed only for a *significant* breach, after a hearing; sums go to the Consolidated Fund of India.

Q47 State the territorial and material scope of the DPDP Act and what it excludes (s.3). 3 MARKS · M8 · S.3 –

MODEL ANSWER

Applies to: processing of digital personal data within India (collected digitally or collected non-digitally and later digitised); and processing outside India if connected with offering goods or services to Principals in India. **Does not apply to:** data processed by an individual for personal or domestic purposes; data made publicly available by the Principal herself or by another person under a legal obligation to publish it. Purely offline data are outside the Act.

Group B · Short-answer questions (5 marks)

Q48 Compare cryptography, anonymization and tokenization as methods of protecting data. 5 MARKS · M1 · HIGH-YIELD –

MODEL ANSWER

	Cryptography	Anonymization	Tokenization
Core idea	Scramble with algorithm + key	Alter values so they no longer identify, preserving syntax and semantics	Swap value for arbitrary surrogate
Link to original	Mathematical, reversible with key	No exact link (distorted)	None — vault lookup only
Utility	Binary: zero until decrypted	Tunable "shades of gray"	Good for routing; limited analytics
Weak point	Key management	Over- or under-modification	Vault security
Use	Data in transit and at rest	Test and analytics data	Run-time (payments, BPO agents)

Q49 Explain the privacy–utility trade-off. Why is it "binary" for cryptography but "shades of gray" for anonymization? Illustrate with two designs. — 5 MARKS · M1 · HIGH-YIELD

MODEL ANSWER

Anonymization must hide identity and links while keeping the statistical correlation between QI and SD so data remain useful. **Cryptography:** encrypted → privacy 1, utility 0; decrypted → utility 1, privacy 0 — two extremes only. **Anonymization:** a continuum; the aim is minimal distortion that still meets privacy constraints (constrained optimisation).

Design 1 (Table 1.7: names replaced, ZIPs generalised to 56000/56010, incomes kept) — good privacy, moderate utility loss. **Design 2** (all names "XXXX", all ZIPs 56001, all genders Male) — near-perfect privacy but severe utility loss: female representation and geographic variance vanish. HIPAA example: anonymising admission dates protects privacy but prevents measuring recovery time.

Q50 How are privacy and utility of anonymized data measured? Illustrate the weakness of a unique QI combination with an example. — 5 MARKS · M1

MODEL ANSWER

Privacy is relative (compare D1'...Dn'): *statistical methods* — variance added to perturbed attributes (more variance = more privacy); *probabilistic methods* — an adversary with background knowledge tries to re-identify. **Utility** — statistical distance between the QI distribution Q in D and Q' in D'; for testing, over-anonymising lowers coverage.

Example: Bob knows Alice lives in ZIP 46001, is female and smokes; Table 1.8 has only one female in ZIP 46001, so Alice has Cancer. Unique QI values leak SD — fixed by group techniques such as k-anonymity.

Q51 Describe the five types of enterprise data and one anonymization challenge for each. — 5 MARKS · M1

MODEL ANSWER

Type	Nature	Challenge
Multidimensional	Tables; independent rows	QI/SD boundary, high dimensionality, clusters in SD
Transaction	Sparse, high-dimensional baskets	Thousands of items, mostly zeros; relational methods fail
Longitudinal	Repeated measures per individual over time	Preserve trends; sequences link to external records
Graph	G = (V, E)	Topology identifies nodes; rewiring changes network properties
Time series	Continuous values at regular intervals	Retain statistics and queries; linkage to public curves

Q52 Explain the four pillars of data governance for data scientists, with an example for each. — 5 MARKS · M2 —

MODEL ANSWER

L-P-R-P. Lineage & origin — where data came from and how it changed (trace a partner's training data to confirm ML use was permitted). **Policies & controls** — laws and terms under which it was collected (did app terms allow targeted ads?). **Reliability & knowledge** — documented, understood, debuggable data (audit transformation scripts for dropped values). **Privacy & security** — access management, breach detection, rights handling (a pipeline step that honours erasure requests).

Q53 What does the GPS tracking example and Kosinski's study show about "sensitive data"? — 5 MARKS · M2 —

MODEL ANSWER

Single points are harmless, but four location points (3 AM, 9 AM, 1 PM, 7 PM) reveal home, workplace and routine; speed and stops add more. Kosinski et al. (2013) predicted sexual orientation, political views, religion and other traits from Facebook likes. Lesson: sensitivity is a property of **patterns and inference**, not just of obviously sensitive fields — hence Tier 2 "person-related data", and privacy depends on context (contextual privacy). Practical implication: treat free text and behavioural streams as sensitive, discover PII with regex, entropy analysis and NLP tools, and shift privacy left.

Q54 Distinguish PbD Principle 2 (privacy as default) from Principle 3 (embedded into design); and compare the components of Principles 6 and 7. — 5 MARKS · M3 · HIGH-YIELD —

MODEL ANSWER

Default is about *settings* — privacy works without user action (optional fields and location sharing off at registration; minimum data collected). **Embedded** is about *architecture* — privacy is part of schemas and workflows (encrypt/tokenize SSNs at ingestion rather than masking later).

Principle 6 (visibility & transparency): accountability, openness, compliance/redress — **3** parts. **Principle 7** (respect for user privacy): consent, accuracy, access, compliance/redress — **4** parts.

Q55 **Describe the symmetric cryptosystem: its five ingredients, two requirements for secure use and options for key distribution.** 5 MARKS · M4 –

MODEL ANSWER

Ingredients: plaintext, encryption algorithm, secret key, ciphertext, decryption algorithm (Y = E(K, X); X = D(K, Y)). **Requirements:** (1) a strong algorithm — an opponent knowing it and holding ciphertexts cannot recover the plaintext or key; (2) the key must be obtained and kept secret by both parties.

Key distribution: one party generates and delivers securely; both run a key-exchange protocol (Diffie–Hellman); or a trusted third party delivers (KDC). **Attacks:** cryptanalysis; brute force (half the key space on average — infeasible for 256-bit keys).

Q56 **Explain how asymmetric encryption provides (a) confidentiality and (b) authentication. State which key is used at each step.** 5 MARKS · M4 · HIGH-YIELD –

MODEL ANSWER

Goal	Encrypt with	Decrypt with	Why it works
(a) Confidentiality — Alice → Bob	Bob's **public** key	Bob's **private** key	Only Bob holds his private key
(b) Authentication — proves Alice sent	Alice's **private** key	Alice's **public** key	Only Alice holds her private key

Steps: each user generates a key pair; publishes the public key (key ring/certificate); keeps the private key secret. Combined use (sign then encrypt) gives both properties (Fig 1.6).

Q57 **Describe the roles of the CA, RA, repository, CRL and relying party in a PKI, and how Alice verifies a document signed by Bob.** 5 MARKS · M4 –

MODEL ANSWER

Bob applies through the **RA**, which checks his identity; the **CA** signs a certificate binding his identity to his public key and publishes it, with **CRLs** of revoked certificates, to the **repository**. **Alice**, the relying party, (1) fetches Bob's certificate and checks it is current and not on the CRL; (2) verifies the CA's signature on it with the CA's public key; (3) takes Bob's public key from it and verifies Bob's signature on the document. Trust scales through hierarchical CAs, with root certificates pre-installed in browsers and operating systems.

Q58 Trace the evolution of the idea of privacy harm from Aristotle to Prosser. — 5 MARKS · M5 —

MODEL ANSWER

Antiquity: Aristotle's public polis vs private household; Mill's principle of autonomy — privacy as a boundary against state interference. **1890:** Warren & Brandeis, "The Right to Privacy" — provoked by portable cameras and tabloids; the "right to be let alone"; the harm is humiliation and injured peace of mind, not slander. **1960:** Prosser classified US case law into four torts: intrusion upon seclusion; public disclosure of embarrassing private facts; false light; appropriation of name or likeness. The remedies differ for each harm; AI and profiling now create new harms that old remedies do not solve (§5.1).

Q59 Explain the privacy paradox and critique the usual interpretation. — 5 MARKS · M5 · HIGH-YIELD —

MODEL ANSWER

Define: expressed privacy concern vs readily sharing data. **Evidence:** Annenberg 55 % opposed to predictive profiling yet 43 % shared grocery histories for discounts; consumers like personalisation but dislike trackers; 41 % think companies explain data use clearly yet hesitate because they do not know what happens to it; Deloitte: tailored services outrank public benefit about 2:1 as a reason to share.

Critique: not necessarily irrational — it is **resignation**: opt-out is impractical, terms are take-it-or-leave-it, and essential services (banking, utilities, social platforms) require sharing. Example: the young parent who keeps scanning a loyalty card to afford discounts despite disliking the tracking.

Q60 Why do the GDPR's right to explanation, Article 22 and right of access fail to address imprecise use? — 5 MARKS · M6 · HIGH-YIELD —

MODEL ANSWER

- **Explanation (Arts 13–15, 22):** gives a high-level account of consequences, not an audit of accuracy — a lender can say "we use an automated score; if low, no loan".
- **Art. 22 (opt out of automated decisions):** useless to those who want the service but need it to be accurate (e.g., an X-ray scanner).
- **Access (Art. 15):** your file cannot show whether an algorithm is broken; that needs population-level performance analysis.
- **Recital 71:** "inaccuracy" means a wrong factual record, not a poor prediction — the doctor analogy (a misdiagnosis is still an accurate note of what the doctor said).
- **Discrimination vs imprecision:** an algorithm overcharging one ethnic group is unlawful; one that overcharges everyone equally is not.

Q61 Critically examine the "notice and consent" model. How does medical consent differ from data-protection consent? — 5 MARKS · M6 · HIGH-YIELD

MODEL ANSWER

Assumption: informed users can weigh risks and choose rationally. **Critique:** dense legal jargon; power imbalance with platforms; bundled, broad consents; false sense of security — notices work as liability shields; IoT devices collect continuously, so when to ask is unclear. Critics want legal responsibility shifted to providers.

	Medical consent	Data-protection consent
Tells you	What will happen and why	What is collected and the legal purpose
Risks disclosed	Inherent risks even if all goes to plan	Only breach/unlawful-leak risks
Oversight	Clinical oversight, professional standards	No check on whether algorithms decide precisely

Q62 What makes consent valid under s.6 of the DPDP Act? Explain withdrawal, burden of proof and Consent Managers. — 5 MARKS · M8 · HIGH-YIELD

MODEL ANSWER

F-S-I-U-U + A: free, specific, informed, unconditional, unambiguous, with a clear affirmative action, for a specified purpose and limited to necessary data (`s.6(1)`). Infringing parts are invalid to that extent (6(2)); requests in plain language, English or an Eighth-Schedule language, with DPO contact (6(3)).

Withdrawal: any time, as easy as giving consent (6(4)); consequences borne by the Principal and past processing remains lawful (6(5)); the Fiduciary must cease, and make its Processors cease, within a reasonable time unless law requires continuation (6(6)). **Consent Managers** (registered with the Board, accountable to the Principal) let her give, manage, review and withdraw consent (6(7)–(9)). **Burden of proof** that notice and consent were valid lies on the Fiduciary (6(10)).

Q63 Explain the "certain legitimate uses" under s.7 of the DPDP Act. — 5 MARKS · M8 · HIGH-YIELD

MODEL ANSWER

The only alternative to consent; a Fiduciary may process without consent for (**V-S-S-L-C-M-E-D-E**): (a) **voluntarily provided** data for the specified purpose, if the Principal has not objected; (b) **State subsidies, benefits, licences** where she previously consented or data is in a notified State database; (c) **State functions** under law, sovereignty and security; (d) **legal obligation to disclose** to the State; (e) compliance with **judgments, decrees, orders** (including foreign civil/contract orders); (f) **medical emergency**; (g) **epidemic** or public-health threat; (h) **disaster** or breakdown of public order; (i) **employment** purposes and employer protection. Examples: pharmacy SMS receipt (a); ER doctor and an unconscious patient (f). Note: s.7 removes only the consent requirement — other duties continue.

Q64 Explain the obligations relating to children's data under s.9 and the permitted exemptions. **5 MARKS · M8 · HIGH-YIELD** –

MODEL ANSWER

"Child" = under 18 (`s.2(f)`). Before processing a child's (or a person with disability's) data: **verifiable parental/guardian consent** in the prescribed manner (9(1)); **no processing likely to harm the child's well-being** (9(2)); **no tracking, behavioural monitoring or targeted advertising** directed at children (9(3)). The Government may exempt prescribed classes/purposes from (1) and (3) (9(4)) and, for verifiably safe processors, notify an **age above which** exemption applies (9(5)). Exemptions never lift 9(2). Penalty up to ₹200 crore. Example: OTP/ID verification of a parent before opening a 12-year-old's gaming account.

Q65 Discuss the rights and duties of a Data Principal under the DPDP Act. **5 MARKS · M8** –

MODEL ANSWER

Right	Section	Key point
Access to information	s.11	Summary of data and processing; identities of other Fiduciaries/Processors with whom shared (not law-enforcement sharing)
Correction, completion, updating, erasure	s.12	Erasure unless retention needed for the specified purpose or law
Grievance redressal	s.13	Exhaust the Fiduciary/Consent Manager first, then the Board
Nominate	s.14	Someone to act on death or incapacity
Withdraw consent	s.6(4)	As easy as giving it

Duties (s.15): comply with laws; do not impersonate; do not suppress material information for State-issued documents; no false or frivolous complaints; furnish only verifiably authentic information for correction/erasure. Breach: up to ₹10,000. **Missing vs the GDPR:** no portability or right to object/restrict.

Q66 Explain the exemptions in s.17 of the DPDP Act. **5 MARKS · M8 · HIGH-YIELD** –

MODEL ANSWER

- **17(1)** — Chapter II (except **8(1)** and **8(5)**), Chapter III and s.16 do not apply for: enforcing legal claims; courts/regulators; prevention and investigation of offences; offshore-contract outsourcing; court-approved mergers; loan-defaulter financial checks.
- **17(2)** — the **whole Act** does not apply to notified State instrumentalities (security, public order…) and to research/archiving/statistics not used for decisions on a specific Principal.
- **17(3)** — notified Fiduciaries/startups: ss.5, 8(3), 8(7), 10, 11 (**N-Q-E-S-A**).
- **17(4)** — State processing: erasure (8(7), 12(3)); and 12(2) if no decision affects the Principal.
- **17(5)** — Central Government may exempt any provision for a period, within five years of commencement.

Q67 **Describe the composition and conditions of service of the Data Protection Board of India.** 5 MARKS · M8 –

MODEL ANSWER

Body corporate with perpetual succession, established by notification (`s.18`); a Chairperson and Members appointed by the Central Government, persons of ability, integrity and standing with expertise in data governance, law, dispute resolution, ICT, digital economy, regulation etc., with **at least one legal expert** (s.19). **Term 2 years**, re-appointable; pay not varied to disadvantage (s.20). **Disqualification**: insolvency, moral-turpitude conviction, incapacity, prejudicial interest, abuse of position; removal only after a hearing (s.21). **Resignation**: notice to the Government, effective on the earliest of four triggers (≈ 3 months); **1-year cooling-off** — no employment without prior approval (s.22). Members and staff are deemed public servants (s.25).

Q68 **Explain the dispute-resolution ladder under the DPDP Act, from grievance to Supreme Court.** 5 MARKS · M8 · HIGH-YIELD –

MODEL ANSWER

1. **Fiduciary / Consent Manager grievance system** (`s.13`) — respond within the prescribed period; must be exhausted first.
2. **Board** (`ss.27–28`) — digital office with civil-court powers; natural justice; interim orders; can warn or impose costs for frivolous complaints; **mediation** (s.31) or **voluntary undertaking** (s.32) possible; penalty under s.33.
3. **TDSAT** (`s.29`) — appeal within **60 days** (late appeal on sufficient cause); confirm, modify or set aside; target disposal in **6 months**, else record reasons; orders executable as a civil decree (s.30).
4. **Supreme Court** — appeal from TDSAT via s.18 of the TRAI Act (s.29(9)). Civil courts are barred from matters the Board can decide (`s.39`).

Q69 **Explain how the Board fixes penalties under s.33 and the Schedule. Where does the money go?** 5 MARKS · M8 · HIGH-YIELD –

MODEL ANSWER

After an inquiry, if the breach is **significant**, the Board may impose the Schedule penalty after giving a hearing (s.33(1)). **Factors (N-T-R-G-M-P-I):** nature, gravity and duration; type and nature of data; repetition; gain or avoided loss; mitigation and its timeliness; proportionality and deterrence; likely impact on the person. Schedule: 250 / 200 / 200 / 150 / 50 crore and ₹10,000 (plus the voluntary-undertaking entry). Sums are credited to the **Consolidated Fund of India** (s.34), not paid to the Principal — and the Act has no compensation route (IT Act s.43A omitted). Caps can be amended by notification but never raised above twice the original figure (s.42).

Group C · Analytical long answers (10 marks) HIGH-YIELD

Template for every "discuss / critically evaluate" answer: **thesis → evidence for → limits/evidence against → conclusion that takes a position**. Aim for 250–350 words, one table or diagram where it helps, and at least one cross-module link.

Q70 **"Anonymization is an optimisation problem, not a tool-selection problem." Discuss with reference to privacy–utility, design drivers and the HIPAA example.** 10 MARKS · M1 –

MODEL ANSWER

Thesis. Choosing software first is the wrong order. Anonymization is a constrained optimisation: minimise distortion subject to a privacy requirement set by data owners and regulators, while preserving the utility requirement set by data scientists.

- **Why blind tools fail:** over-strict filters meant to satisfy HIPAA or the Swiss Data Protection Act destroy utility; lax settings leave unique QI combinations open to linkage (Bob–Alice, ZIP 46001).
- **Drivers (Fig 1.6):** business domain, environment, **data semantics**, regulations, application, **privacy requirement**, **utility requirement**, data type/structure. Semantics decide which changes stay valid (generalising a ZIP keeps meaning; random digits do not).
- **Binary vs shades of gray:** cryptography is all-or-nothing; anonymization is a continuum — Design 1 (Table 1.7) balances; Design 2 (all "XXXX", one ZIP, all "Male") is private but useless.
- **HIPAA conflict:** anonymising admission dates protects patients but prevents measuring recovery time — a concrete trade-off.
- **Measurement:** privacy by variance/adversary models; utility by statistical distance between Q and Q′; for testing, structural fidelity.
- **Principles:** each design principle has a name, rationale and implications; normative principles guide the balance.

Conclusion. Specify the two requirements, pick techniques that fit the data type, measure both outcomes and iterate; the tool is the last choice.

Q71 **"Removing names makes a dataset anonymous." Critically evaluate across the five data types.** 10 MARKS · M1 · HIGH-YIELD –

MODEL ANSWER

Thesis. False: names are only the explicit identifiers; the rest of the record can still identify.

Data type	How it is re-identified after names are removed
Multidimensional	QI linkage — ZIP + DOB + gender (Sweeney ≈ 87 %) joined to a voter list; high dimensionality makes rows unique; clusters in SD leak even after generalising.
Transaction	Rare items (glucose monitor, HIV test) reveal health; sparse, high-dimensional rows are near-unique.
Longitudinal	A sequence of dates and measurements links to external records such as insurance claims.
Graph	Relabelling nodes A–F keeps topology and degrees; an adversary who knows a target's friend count maps identity back.
Time series	Curves match public financial disclosures or news.

Remedies and limits: group models (k-anonymity → l-diversity → t-closeness), perturbation and differential privacy — each with weaknesses (homogeneity, skew) and utility cost. Pseudonymization is not anonymization: the data remain personal data because they can be re-linked. Legally, under the DPDP Act data stay "personal" if the individual is identifiable by or in relation to them (`s.2(t)`).

Conclusion. Anonymity is a property of the whole dataset against a realistic adversary with background knowledge, not of a single column.

Q72 **Using the island-fortress metaphor, discuss how security, privacy by design, regulation and privacy technology together enable safe data use. Include the four governance pillars.** 10 MARKS · M2–M3 –

MODEL ANSWER

- **Protection tower and sentinel (security)** — physical defences, perimeters, encryption, permissions; continuous risk monitoring.
- **Privacy-by-Design island** — systems built from day one to minimise exposure rather than patched later (seven principles).
- **Policy/regulatory moat** — HIPAA, GDPR, DPDP keep boundaries legally enforced.
- **Privacy-technology bridge** — anonymization, tokenization, PETs let analysts cross the moat and reach insights without exposing identities.

Governance (People · Process · Technology) operationalises this via the four pillars: **L-P-R-P** — lineage (where data came from, whether ML use was permitted), policies (terms under which it was collected), reliability (documented, debuggable data) and privacy & security (access control, breach detection, rights handling).

Argument. Each element alone fails: a tower without a bridge blocks analytics; a bridge without a moat has no legal accountability; a moat without design just reacts to harm. **Link to the Act:** s.8(1) accountability, s.8(2) processor contracts, s.8(5) safeguards, s.8(7) erasure, s.10 audits. **Conclusion:** governance is the integrating layer that lets utility and privacy coexist.

Q73 **"Privacy by Design is a philosophy, not a feature." Discuss using the seven principles; relate to privacy engineering and the DPDP Act.** 10 MARKS · M3 –

MODEL ANSWER

Thesis. PbD is a design philosophy applied across architecture, infrastructure, processes and workflows; you cannot "add" it at the end.

- **Proactive:** threat-model in the design phase. **Default:** optional fields off; minimum data. **Embedded:** encrypt/tokenize at ingestion. **Positive-sum:** privacy-preserving analytics + tokenization instead of "watch everything to stop fraud". **End-to-end:** TLS, AES-256, role-based access, automated secure deletion. **Visibility:** accountability, openness, compliance/redress. **Respect:** consent, accuracy, access, redress.
- **Philosophy vs engineering:** the principles state objectives; privacy engineering implements them (data-flow mapping, minimised schemas, pseudonymization, DPIA).
- **Contrast with "security as afterthought"** — challenge 9 in §4.3; retrofitting authentication into live code.
- **DPDP echoes:** consent limited to necessary data (s.6(1)), erasure (s.8(7)), accountability (s.8(1)), grievance and DPO contact (s.8(9)–(10)), DPIA for SDFs (s.10).

Conclusion. The test of PbD is whether privacy would survive if no user ever touched a setting — that is why "default" and "embedded" are its engineering heart.

Q74 **Alice must send Bob a confidential contract that Bob can verify came from Alice and was not altered. Show how hashing, symmetric and asymmetric encryption, digital signatures and PKI combine.** 10 MARKS · M4 · HIGH-YIELD –

MODEL ANSWER

1. **Sign.** Alice computes digest = H(contract) and signs it with **her private key** → signature. (Integrity + authenticity + non-repudiation.)
2. **Encrypt bulk data.** She generates a random **symmetric session key K** and encrypts contract + signature with AES under K. (Fast confidentiality.)
3. **Trust Bob's key.** She fetches Bob's **certificate** from the repository, verifies the CA's signature on it with the CA's public key, and checks expiry and the CRL. (PKI binds the key to Bob.)
4. **Protect the key.** She encrypts K with **Bob's public key** — solving the symmetric key-distribution problem. She sends encrypted K + ciphertext.
5. **Receive.** Bob decrypts K with **his private key**, decrypts the contract, recomputes H(contract).
6. **Verify.** Using **Alice's public key** (from her certificate) he checks the signature against the hash. A match proves origin and integrity; Alice cannot deny signing.

Threats handled: eavesdropping (encryption), modification (hash/signature), masquerade (signature + certificate), replay (add timestamp/sequence numbers). **Why hybrid?** Asymmetric encryption is slow, so it protects only the small key and the hash; symmetric encryption handles the bulk. Collision resistance of H is essential — otherwise a signed harmless document could be swapped.

Q75 **Critically evaluate how far the FIPs, OECD guidelines and GDPR protect against harms from imprecise use of data. What reforms are suggested?** 10 MARKS · M6 · HIGH-YIELD –

MODEL ANSWER

Thesis. They were designed for *insecure* use (unauthorised access, unlawful repurposing) and cover imprecise automated decisions poorly.

- **Frameworks:** FIPs 1973 (know, correct, no repurposing); OECD 1980 (limited, lawful, purposeful collection); GDPR 2016 (processing unlawful unless a statutory ground; rights). All police *collection and purpose*, not algorithm precision.
- **GDPR gaps:** Recital 71 — "inaccuracy" means wrong factual records, not a poor propensity score; the explanation right is high-level; Art. 22 lets you opt out but does not assure accuracy; Art. 15 access cannot reveal a broken model; discrimination is banned but uniform imprecision is legal (insurance and advertising cases).
- **Why the gap matters:** complex AI uses thousands of variables, so unlike "income < $25,000 → reject", nobody can judge it from the policy; market competition does not fix it because engagement/profit ≠ accuracy.
- **Reforms:** put legal responsibility on providers (not consumers); audit precision and error rates, not only security; unify privacy and consumer-protection oversight; give regulators access to training data and logs; require outcome monitoring with control groups (steps 4–5 of the surveillance loop).

Conclusion. Data-protection law needs a precision dimension; otherwise it secures data without securing people.

Q76 **Should privacy regulation and consumer-protection regulation be kept separate? Argue the case, including the limits of external auditing.** 10 MARKS · M6 –

MODEL ANSWER

The conventional split. Privacy regulators handle *unauthorised* use (hacking, leaks, unlawful processing); consumer-protection agencies handle *authorised* use that is harmful, low-quality or unfair. Proponents add that competition will weed out imprecise algorithms.

Arguments against the split: (1) **Public perception** — people do not distinguish; they care about bad outcomes from data use. (2) **Shared remedies** — notices, transparency and meaningful consent serve both; splitting adds bureaucracy. (3) **Access to underlying data** — judging precision needs training data and behavioural logs; privacy regulators have the expertise and powers consumer agencies often lack. **Competition fails** because markets reward engagement and profit over accuracy.

Limits of external auditing: regulators can run dummy profiles through a service (the European Commission analysed Google's search outputs to show favouring of its own shopping service), but adaptive AI changes continuously, and measuring precision without inspecting training data is inefficient and unreliable.

Conclusion. A unified model that treats cybersecurity vulnerabilities and algorithmic imprecision together is better suited to modern automated decision-making.

Q77 **Evaluate the model surveillance system. Why can well-intentioned surveillance cause net harm?** 10 MARKS · M7 · HIGH-YIELD –

MODEL ANSWER

- **Model (D-I-I-O-T):** define a signature → identify members → intervene → observe outcomes → test error rate; steps 4–5 feed back to step 1. Static systems stop at step 3 and never learn whether they help.
- **Net benefit** = (value of TP + value of TN) − (cost of FP + cost of FN); needs sensitivity, specificity and a cost per error.
- **Case:** routine mammography was assumed beneficial, yet meta-analyses show net harm across broad populations because false positives cause biopsies, radiation and stress that outweigh early detection. Reviewing the *purpose* (detect cancer) could never reveal this; only measuring the error rate could.
- **Net-harm mechanisms:** *proxy optimisation* — algorithms maximise renewals or clicks, not well-being (fitness app, news aggregator); *misaligned error rates* — what is optimal for the operator (price optimisation) harms consumers, worst in addictive markets (gambling, high-interest loans).
- **Judgement:** value depends on measured precision and costs, not on intent; monitoring with control groups is the safeguard.

Link: under the DPDP Act the State's own surveillance-type processing is largely exempt (s.7(b)–(c), s.17(2)(a)); the Act has no outcome-audit duty except for SDFs.

Q78 **Critically analyse the DPDP Act's consent architecture against the criticisms of "notice and consent".** 10 MARKS · M6 + M8 · CROSS-MODULE –

MODEL ANSWER

This is an analytical synthesis (see bridge table 9.3-D), not text from the Act.

Criticism (§6.3)	DPDP response	Residual gap
Dense, complex notices	Notice in clear, plain language; English or any Eighth-Schedule language (s.5(3), 6(3)).	Notice can still be long; no readability test.
Bundled, broad consents	Consent limited to necessary data for the specified purpose; infringing parts invalid (6(1)–(2)); telemedicine illustration.	"Necessity" is judged case by case.
Power imbalance	Burden of proof on the Fiduciary (6(10)); withdrawal as easy as giving (6(4)).	Take-it-or-leave-it service terms remain possible.
Consent fatigue / IoT	Consent Managers as a single dashboard (6(7)–(9)).	Depends on adoption and registration.
False sense of security	Fiduciary stays accountable irrespective of agreements (8(1)); safeguards and breach notice (8(5)–(6)).	Consent still the main ground; State and s.7 uses bypass it.
Risks from accurate-but-harmful algorithms	Data quality only where decisions affect the Principal (8(3)); SDF DPIA/audit (10).	No algorithm-precision audit or automated-decision right.

Conclusion. The Act strengthens the *form* of consent and shifts proof to the Fiduciary, but, like the GDPR, still treats consent as the main gate and leaves imprecise use largely untouched.

Q79 **Evaluate the enforcement and redress framework of the DPDP Act (Board, TDSAT, penalties). Is it adequate for the individual?** 10 MARKS · M8 –

MODEL ANSWER

Strengths are from the Act's text; the concerns are commonly raised arguments — present them as such.

Strengths: a dedicated, digital-by-design Board with civil-court powers and natural-justice duties (ss.27–28); graded penalty factors and large caps (up to ₹250 crore); mediation and voluntary undertakings for quick compliance (ss.31–32); blocking power after repeated penalties (s.37); a two-tier appeal to TDSAT within 60 days and the Supreme Court; no overlapping civil-court jurisdiction (s.39); the Fiduciary must prove consent (6(10)).

Concerns: the Central Government appoints the Board and fixes its terms (s.19–20, 2-year term), raising independence questions; wide State exemptions (s.7(b)–(c), s.17(2)(a), s.17(4)); penalties go to the Consolidated Fund and the Act offers **no compensation** to the individual (IT Act s.43A omitted); penalties only for "significant" breach; Principals themselves face penalties for false complaints (s.15, s.28(12)); no portability or objection rights; the grievance-first rule (s.13(3)) delays access to the Board.

Conclusion. A credible enforcement skeleton, but redress for the individual is indirect — deterrence rather than compensation.

Q80 **Compare the DPDP Act and the GDPR. Which handles algorithmic imprecision better?** 10 MARKS · M8 · CROSS-MODULE –

MODEL ANSWER

Comparison (see table 8.11): scope (digital data only vs all data); extraterritorial reach (offering goods/services vs also monitoring behaviour); legal bases (consent + s.7 vs six bases incl. legitimate interests); special categories (none vs yes); child age (18 vs 16, lowerable to 13); rights (access, correction/erasure, grievance, nominate + duties vs wider rights incl. portability, objection, automated-decision); breach notice (Board and Principals in prescribed form vs 72 hours to the authority); DPO (SDFs only vs specified cases); cross-border (negative list vs adequacy); penalties (fixed caps to ₹250 crore vs €20 m/4 % turnover); compensation (none vs Art. 82).

Imprecision: GDPR has Recital 71 (appropriate statistical procedures), Art. 22 (automated decisions), explanation rights and DPIAs — yet, as Module 6 argues, none audits precision. The DPDP Act has only **s.8(3)** (accuracy, completeness, consistency of data used for decisions affecting the Principal) and, for SDFs, an independent auditor and periodic DPIA (**s.10**); it has no automated-decision right.

Verdict. Neither law regulates algorithm precision directly; the GDPR offers more tools, the DPDP Act relies on SDF audits and data-quality duties.

Q81 Discuss bias and discrimination in data analysis: sources, harms and mitigation. *(DU Unit 4)* — 10 MARKS · DU UNIT 4 —

MODEL ANSWER

- **Sources:** historical bias in training data; sampling/representation bias; measurement and label bias; proxy variables (ZIP code, device); aggregation bias (one model for all groups); feedback loops (policing example).
- **Harms:** unfair loan refusals, discriminatory hiring and pricing, policing and welfare errors, filter bubbles (§5.3, §7.4). Proxy optimisation can discriminate even without malice.
- **Law:** the GDPR bans discrimination on protected characteristics but not uniform imprecision (§6.2, the insurance and advertising cases); the DPDP Act has only a data-quality duty (s.8(3)).
- **Mitigation:** representative, audited data; test or drop proxies; fairness metrics (demographic parity, equalised odds); human oversight and appeal; explanation; monitoring of error rates by group (steps 4–5 of the surveillance loop); DPIA and independent audit for high-risk systems.

Cite one example (e.g., a recruiting tool that learned to down-rank women's CVs) and conclude that fairness must be measured, not assumed (§9.10-H).

Group D · DPDP case studies and application HIGH-YIELD

Method for every case: **(1)** name the actors (Principal / Fiduciary / Processor); **(2)** find the section; **(3)** check exemptions (s.7, s.17); **(4)** state the consequence and penalty.

Q82 A bank outsources statement printing to a vendor. The vendor's misconfigured server exposes customers' account details. Who is liable and under which sections? What must the bank do? — CASE · S.8 —

MODEL ANSWER

- **Actors:** bank = Data Fiduciary; vendor = Data Processor (`s.2(i),(k)`).
- `s.8(1)` — the bank is responsible for compliance **including processing by its Processor**, regardless of contract terms. `s.8(2)` — vendor must be engaged under a valid contract.
- `s.8(5)` — reasonable security safeguards cover data processed by the Processor too: up to ₹250 crore.
- `s.8(6)` — the bank must inform the **Board and every affected customer**; failure: up to ₹200 crore.
- The Board will direct remedial steps, inquire and may penalise after a hearing (`ss.27–28, 33`).

Q83 An ed-tech app for 12–16 year-olds tracks what each student watches and sells "interest segments" to toy advertisers. The company argues it has parental consent from sign-up. Discuss. Can the Government exempt it? CASE · S.9 –

MODEL ANSWER

Students are children (`s.2(f)`). Verifiable parental consent (`s.9(1)`) may satisfy only the consent limb. `s.9(3)` separately **prohibits tracking, behavioural monitoring and targeted advertising** directed at children, so consent does not cure the violation; `s.9(2)` also bars processing detrimental to well-being. The Government can exempt prescribed classes or purposes from s.9(1) and (3) (`s.9(4)`), and notify an age above which a verifiably safe Fiduciary is exempt (`s.9(5)`) — but **never from s.9(2)**. Penalty: up to ₹200 crore.

Q84 X orders goods on a shopping app, pays, then withdraws consent. Separately, Y closes a bank account and asks for erasure while banking law requires KYC retention for ten years. What happens in each case? CASE · SS.6, 8(7), 12 –

MODEL ANSWER

X: withdrawal is allowed any time, but consequences are borne by X and past processing stays lawful (`s.6(4)–(5)`). The app must stop *new* processing, but may continue processing needed for goods already ordered and paid (statutory illustration). It must cease and make its Processors cease within a reasonable time (`s.6(6)`), then erase once the purpose is served (`s.8(7)`).

Y: the right to erasure (`s.12(3)`) yields where retention is necessary for compliance with law (also `s.8(7)`). The bank may keep the KYC records for the legally required ten years, then must erase them and instruct Processors to do so.

Q85 A DPIIT-recognised startup (private limited company) says the DPDP Act does not apply to it at all. Is that right? CASE · S.17(3) –

MODEL ANSWER

No. `s.17(3)` lets the Central Government **notify** Data Fiduciaries or classes (including startups, having regard to volume and nature of data) for relief — and then only from **ss.5, 8(3), 8(7), 10 and 11** (notice, data quality, erasure, SDF duties, access: N-Q-E-S-A). Still applicable: consent (s.4, 6), accountability (s.8(1)), security (**s.8(5)**), breach intimation (**s.8(6)**), children's rules (s.9), most Principal rights (ss.12–14), and penalties. Relief exists only after notification.

Q86 **A Bengaluru BPO manages German hospital patients' records under a contract with a German firm. Which parts of the Act apply?** CASE · S.17(1)(D) –

MODEL ANSWER

The BPO processes digital personal data within India, so the Act applies in principle (`s.3(a)`). But `s.17(1)(d)` exempts processing of personal data of Principals **not within India** under a contract with a person outside India by a person based in India: Chapter II (except s.8(1) and s.8(5)), Chapter III and s.16 do not apply. The BPO therefore need not give notice or obtain consent under the Act, nor must it honour Chapter III rights, but it remains responsible for compliance (`s.8(1)`) and must keep reasonable security safeguards (`s.8(5)`, up to ₹250 crore).

Q87 **A Principal's correction request is ignored. She files a complaint with the Board at once; the Fiduciary says her earlier emails were false. Trace the correct route and consequences.** CASE · SS.12, 13, 15, 28, 29 –

MODEL ANSWER

1. `s.12(1)–(2)` — she has the right to correction/updating for consent-based processing; the Fiduciary must correct inaccurate data.
2. `s.13(3)` — she must first use the Fiduciary's grievance mechanism (response within the prescribed period); going straight to the Board is premature.
3. Then a Board complaint (`s.27`). If the complaint is found **false or frivolous**, the Board may warn or impose costs on her (`s.28(12)`); a knowingly false grievance also breaches her duty (`s.15`, up to ₹10,000).
4. If the Board decides against her (or the Fiduciary), either aggrieved person may appeal to **TDSAT within 60 days** (`s.29`). A refused correction is a breach of "any other provision" — up to ₹50 crore.

Q88 **A firm offers a voluntary undertaking during a Board inquiry, but later fails to complete the promised security upgrade. What follows?** CASE · SS.32–33 –

MODEL ANSWER

The Board may accept an undertaking at any stage (`s.32(1)`) — to act within a time, refrain from acting or publicise it. Acceptance **bars proceedings** on its subject matter (32(4)). But failure to adhere to any term is **deemed a breach of the Act**; after a hearing the Board may proceed under s.33 (32(5)); the Schedule fixes the penalty at up to the extent applicable to the breach for which proceedings under s.28 were instituted (e.g., up to ₹250 crore if the underlying breach was a s.8(5) failure).

Q89 Which s.7 ground (if any) permits each processing without consent? (a) An ER doctor reads an unconscious patient's blood group. (b) A pharmacy SMSes a receipt to a number the customer gave. (c) An IT firm monitors key-card and network logs to stop IP theft. (d) A broker keeps messaging a client who said she no longer needs help. CASE · S.7 –

MODEL ANSWER

- (a) `s.7(f)` — medical emergency (threat to life/immediate threat to health).
- (b) `s.7(a)` — voluntarily provided for the specified purpose, no objection.
- (c) `s.7(i)` — employment: safeguarding the employer from loss or liability (corporate espionage, trade secrets, IP).
- (d) **None** — under s.7(a) the ground lapses once she indicates she does not consent to further use; the broker must stop (statutory illustration II).

Q90 An offshore loan app is penalised twice for leaking users' contacts and continues to operate in India. What can the Government do, and by what procedure? CASE · S.37 –

MODEL ANSWER

Under `s.37`: (1) the Board must send the Central Government a **written reference** stating that a monetary penalty has been imposed on the Fiduciary in **two or more instances** and advising, in the general public interest, blocking of access to the computer resource enabling the app's activity; (2) the Government must give the Fiduciary an **opportunity of being heard**, be satisfied that blocking is necessary or expedient, and record reasons in writing; (3) it may then direct any Government agency or **intermediary** to block access, and the intermediary is bound to comply. Terms "computer resource", "information" and "intermediary" have IT Act, 2000 meanings.

Q91 A State department enrols citizens for maternity benefits and a notified security agency collects data for national-security purposes. Which grounds and exemptions apply? CASE · SS.7(B), 17 –

MODEL ANSWER

Department: processing without consent for subsidies, benefits, services — where the woman previously consented or the data is in a State-maintained notified database (`s.7(b)`), subject to Central standards. As a State instrumentality it also gets `s.17(4)`: no erasure obligation (ss.8(7), 12(3)); and no correction duty under s.12(2) where the purpose does not include a decision affecting her. Other duties (e.g., s.8(5) security) continue.

Security agency: if notified under `s.17(2)(a)` (sovereignty, security of the State, public order, relations with foreign States), the **entire Act** does not apply to it. Without notification only the s.7(c) ground (State function/security) is available.

Q92 A US streaming service sells subscriptions to users in India. X blogs under her own name, publishing personal details on social media. Does the Act apply to either? CASE · S.3 –

MODEL ANSWER

Streaming service — yes: processing outside India is covered if connected with offering goods or services to Data Principals in India (`s.3(b)`); the Act does *not* extend to mere behavioural monitoring (unlike GDPR Art. 3(2)(b)). **X's blog data — no:** personal data made publicly available by the Principal herself is excluded (`s.3(c)(ii)(A)`; statutory illustration). Data of another person that she publishes is not excluded unless made public under a legal obligation or by that person (s.3(c)(ii)).

Group E · True / false — spot the error

Say "False", then give the corrected statement. Each is a trap examiners (or the notes' common mistakes) set.

Q93 **Tokens are mathematically derived from the original value and can be reversed with a key.** T/F · M1 –

ANSWER

False. Tokens are arbitrary surrogates with no algorithmic relationship to the data; only a vault lookup maps them back. Encryption is the key-based, reversible method.

Q94 **In the anonymization pipeline, the sensitive data are masked so analysts cannot see them.** T/F · M1 –

ANSWER

False. EI are dropped, QI are transformed, and **SD are retained in authentic form** to keep analytic utility.

Q95 **A 2-anonymous table guarantees that sensitive values cannot be inferred.** T/F · M1 –

ANSWER

False. k-anonymity stops linking by QI but not a **homogeneity attack**: if all k records in a group share the same sensitive value, it is disclosed. l-diversity and t-closeness address this.

Q96 **Passive attacks are best handled by detection and recovery.** T/F · M4 –

ANSWER

False. They leave no trace, so they are almost undetectable; the defence is **prevention** (encryption). Active attacks are the ones handled by detection and recovery.

Q97 To prove that Alice sent a message, Alice encrypts it with Bob's public key. T/F · M4 –

ANSWER

False. Bob's public key gives *confidentiality*. Authentication/signature uses **Alice's private key**, verified with her public key.

Q98 Second-preimage resistance means it is infeasible to find any two inputs with the same hash. T/F · M4 –

ANSWER

False. That is **collision resistance**. Second-preimage resistance: given a specific x, it is infeasible to find $y \neq x$ with $H(y) = H(x)$. Preimage resistance: given h, find any input.

Q99 A public-key certificate is signed with the certificate owner's private key. T/F · M4 –

ANSWER

False. It is signed with the **CA's private key** and verified with the CA's public key.

Q100 Non-repudiation with proof of origin protects the sender. T/F · M4 –

ANSWER

False. Proof of origin protects the **receiver**; proof of **delivery** protects the sender.

Q101 The GDPR right of access lets individuals check whether an algorithm making decisions about them is accurate. T/F · M6 –

ANSWER

False. It shows the data held about you, not the algorithm's precision; that needs population-level performance analysis.

Q102 Under the DPDP Act a "child" is anyone below 16. T/F · M8 · S.2(F) –

ANSWER

False. A child is an individual who has **not completed 18 years**.

Q103 Section 17(1) exempts a Data Fiduciary from every obligation, including security safeguards. T/F · M8 · S.17 –

ANSWER

False. Sections **8(1)** (responsibility) and **8(5)** (security safeguards) still apply; the exemption removes the rest of Chapter II, Chapter III and s.16.

Q104 The DPDP Act applies to purely offline, paper-only records. T/F · M8 · S.3 –

ANSWER

False. It applies to digital personal data, including non-digital data that is **subsequently digitised**.

Q105 Penalties collected under the Act are paid to the affected Data Principal as compensation. T/F · M8 · S.34 –

ANSWER

False. They are credited to the **Consolidated Fund of India**; the Act has no compensation mechanism (IT Act s.43A was omitted by s.44(2)(a)).

Q106 An appeal against a Board order must be filed with TDSAT within 90 days. T/F · M8 · S.29 –

ANSWER

False. 60 days (late appeals allowed on sufficient cause); the 90-day figure belongs to the Supreme Court appeal window under TRAI Act s.18.

Q107 Every Data Fiduciary must appoint a Data Protection Officer based in India. T/F · M8 · S.10 –

ANSWER

False. Only a **Significant Data Fiduciary** must (s.10(2)(a)); other Fiduciaries publish contact details of a DPO "if applicable" or another person (s.8(9)).

Q108 Withdrawal of consent makes all earlier processing unlawful. T/F · M8 · S.6(5) –

ANSWER

False. The consequences are borne by the Principal and the **legality of earlier processing is not affected**.

Q109 The Board can fine a Fiduciary for any breach, however minor, without a hearing. T/F · M8 · S.33 –

ANSWER

False. Only for a **significant** breach found on conclusion of an inquiry, and **after an opportunity of being heard**, with reasons recorded.

Group F · Numerical, matching and fill-in drills

Q110 Table (ZIP, Age, Disease): (56001, 28, Flu), (56001, 31, Flu), (56002, 45, Cancer), (56002, 47, Asthma), (56003, 52, Cancer), (56003, 58, Cancer). Generalise ZIP → 5600* and age to bands 20–39 and 40–59. (a) Is the result 2-anonymous? (b) l-diverse for l = 2? (c) What can an adversary infer? NUMERICAL · M1 · HIGH-YIELD –

MODEL ANSWER

Group (5600*, age band)	Records	Diseases
20–39	2	Flu, Flu
40–59	4	Cancer, Asthma, Cancer, Cancer

(a) Smallest group has 2 records → **2-anonymous** (k = 2). **(b)** Group 1 has one distinct value, so the table is only **1-diverse**; it is not 2-diverse. **(c)** Anyone known to be in ZIP 5600* and aged 20–39 certainly has **Flu** (homogeneity attack). In group 2, Cancer has 75 % probability versus 50 % in the whole table (skewness) — which t-closeness would measure. Fix: widen the age bands or merge groups, accepting utility loss.

Q111 A screening programme tests 1,000 people: TP = 40, FN = 10, FP = 90, TN = 860. Compute sensitivity, specificity and the proportion of flagged people who are truly positive. With values TP = 100, TN = 1, FP cost = 20, FN cost = 200 compute the net benefit; recompute if FP cost = 60. NUMERICAL · M7 · HIGH-YIELD –

MODEL ANSWER

Sensitivity = TP/(TP+FN) = 40/50 = **80 %**. **Specificity** = TN/(TN+FP) = 860/950 = **90.5 %**. **Flagged who are truly positive** = 40/130 = **30.8 %** (most flags are false alarms).

Net benefit = (40×100 + 860×1) − (90×20 + 10×200) = 4,860 − 3,800 = **+1,060**. With FP cost 60: 4,860 − (90×60 + 2,000) = 4,860 − 7,400 = **−2,540** → net **harm**. Moral: whether surveillance helps depends on error costs, not on the programme's purpose (breast-screening case).

Q112 Match each DPDP provision with its maximum penalty: (1) s.8(5) · (2) s.8(6) · (3) s.9 · (4) s.10 · (5) s.15 · (6) any other provision. Options: (a) ₹10,000 · (b) ₹50 crore · (c) ₹150 crore · (d) ₹200 crore · (e) ₹250 crore. MATCHING · SCHEDULE –

ANSWER

Provision	Penalty
(1) s.8(5) security safeguards	(e) ₹250 crore
(2) s.8(6) breach intimation	(d) ₹200 crore
(3) s.9 children	(d) ₹200 crore
(4) s.10 SDF	(c) ₹150 crore
(5) s.15 Principal's duties	(a) ₹10,000
(6) any other provision	(b) ₹50 crore

Q113 Match each chapter of the DPDP Act with its sections: I · II · III · IV · V · VI · VII · VIII · IX. MATCHING · STRUCTURE –

ANSWER

Chapter	Sections	Topic
I	1–3	Preliminary
II	4–10	Obligations of Data Fiduciary
III	11–15	Rights and duties of Data Principal
IV	16–17	Special provisions (cross-border, exemptions)
V	18–26	Data Protection Board of India
VI	27–28	Powers, functions and procedure of the Board
VII	29–32	Appeal and alternate dispute resolution
VIII	33–34	Penalties and adjudication
IX	35–44	Miscellaneous

Q114 Fill in the blanks: (1) A child is below ___ years. (2) Board members' term is ___ years. (3) Appeal to TDSAT within ___ days. (4) Target disposal of appeals ___ months. (5) Cooling-off period ___ year(s). (6) Orders to remove difficulties: not after ___ years. (7) Rules and notifications are laid before Parliament for ___ days. (8) A Schedule penalty can be raised to at most ___ the original. (9) Blocking needs penalties in at least ___ instances. (10) Languages in the Eighth Schedule: ___. FILL-IN · M8 –

ANSWER

(1) **18** · (2) **2** · (3) **60** · (4) **6** · (5) **1** · (6) **3** (from commencement) · (7) **30** · (8) **twice** · (9) **two or more** · (10) **22**.

Q115 Cryptographic calculations: (a) How many non-trivial keys does a Caesar cipher have? (b) On average how many keys must a brute-force attacker try against a 128-bit key? (c) Approximate work for a generic collision and for a preimage on SHA-256?

NUMERICAL · M4 –

ANSWER

(a) **25** (shift 0 is no change) — trivially brute-forced. (b) Half the key space: $2^{128}/2 = \mathbf{2^{127}} \approx 1.7 \times 10^{38}$ keys — infeasible. (c) Collision ≈ $\mathbf{2^{128}}$ (birthday bound $2^{n/2}$); preimage ≈ $\mathbf{2^{256}}$.

Q116 Match each PbD principle with the example: (1) Proactive · (2) Default · (3) Embedded · (4) Positive-sum · (5) End-to-end · (6) Visibility · (7) Respect. Examples: (a) fraud detection with tokenization instead of watching everything; (b) plain-language privacy dashboard with a complaint contact; (c) optional phone/location fields off at sign-up; (d) design-phase code audits and risk assessment; (e) patient portal for download, correction and consent choices; (f) DB built from day one to encrypt SSNs at ingestion; (g) TLS in transit, AES at rest, automated purge after retention.

MATCHING · M3 –

ANSWER

(1)–(d) · (2)–(c) · (3)–(f) · (4)–(a) · (5)–(g) · (6)–(b) · (7)–(e).

End of notes · Modules 1–10. Keep Modules 9 and 10 for the final revision pass.